

营销业务管理平台(EUSD)

应用安全检测报告

初测

委托单位：东风汽车集团有限公司

测试人员：安全测试组

测试日期：2026年07月03日

东风汽车集团有限公司

检测概述

背景介绍

营销业务管理平台(EUSD)是东风汽车集团面向经销商和营销业务的核心管理系统，集成了统一身份认证(SSO)、租户管理、线索管理、业务流程等关键功能。该系统部署于 DEV 环境，通过域名 mbmp-dev.dfmc.com.cn 对外提供服务，前端采用 Vue 3 SPA 架构，后端通过 Spring Cloud Gateway 微服务网关转发至认证服务和租户服务。

为评估该平台的安全防护能力，识别潜在安全风险，依据国家标准和行业安全规范，对该平台开展全面的应用安全检测。本次检测结合黑盒渗透测试和灰盒测试(使用提供的管理员和普通用户测试账号)，从外部攻击者视角评估平台的安全态势。

参考标准

- 《OWASP 安全测试指南 V4.0》
- 《OWASP TOP10》
- 《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
- 《ISO/IEC 27001 信息安全管理》
- 《数据安全法》
- 《个人信息保护法》

适用说明

针对营销业务管理平台(EUSD)及其集成的统一身份认证、租户管理等服务开展应用安全检测，覆盖 Web 应用安全、API 安全、数据安全、认证授权等维度。

检测内容

该检测报告覆盖端口安全、基线安全、前端安全、传输安全、身份鉴别、权限管理、会话安全、密钥安全、异常处理、业务安全、日志审计、数据安全、常见漏洞等 13 个大类，共计 59 项安全检测内容。

注: 原模板 60 项中的 VULN-021(未授权浏览)已合并至 VULN-015(未授权访问)统一检测，二者检测内容完全一致，故实际检测 59 项。

检测工具

工具名称	工具类型	工具用途
cURL	接口测试	命令行 HTTP 客户端，API 安全测试、CORS 验证、安全头检测
OpenSSL	协议检测	SSL/TLS 协议版本、证书链、加密套件检测
Chrome DevTools/CDP	前端分析	前端代码分析、网络请求监控、DOM 审计
Playwright	自动化测试	浏览器自动化登录测试、Token 捕获、认证流程验证
Python 脚本	自动化测试	密码加密算法逆向分析、自动化安全检测脚本

风险评级标准

风险等级	定义	整改时限
严重	可直接获取系统控制权或大规模数据泄露,无需认证即可利用	24 小时内

高危	可获取敏感数据或绕过关键安全控制,利用条件较低	72 小时内
中危	存在安全隐患但利用需一定条件,或影响有限	2 周内
低危	安全加固建议,风险较小或需复杂利用条件	1 个月内

说明: 本报告中"风险等级"指该检测项的固有风险级别(即如果不符合时的严重程度), 与"测试结果"是两个独立维度。例如某项"风险等级=高危"且"测试结果=符合", 表示该领域属于高风险类别但系统已通过检测; 反之"风险等级=中危"且"测试结果=不符合", 表示该中等风险领域存在问题需要修复。

整改优先级建议

优先级	对应检测项	风险等级	整改说明
P0-立即修复	KEY-001, FRON-002, VULN-016	严重	密码加密密钥随密文传输+前端敏感信息泄露+多处信息泄露,24 小时内修复
P1-紧急修复	AUTH-001, SESS-002, VULN-006, TRAN-002, AUTH-002, VULN-003	高危	验证码关闭+CORS 宽松+CSRF 缺失+防重放缺失+弱口令,72 小时内修复
P2-72 小时	AUTH-003, AUTH-010, BUS-002, SESS-004, DATA-002	高/中危	MFA 未启用+用户标识泄露+文件下载+会话超时+数据脱敏,2 周内修复
P3-计划修复	SESS-001, TRAN-001, VULN-020	中危	Cookie 格式+版本信息泄露+URL 重定向,1 个月内修复

变更记录

版本	日期	变更内容	变更人
V1.0	2026-07-02	初测报告	安全测试组
V1.1	2026-07-03	补充管理员/普通用户真实登录截图; 据实更新角色越权(PER-002)、日志审计(AUD-001/002)、数据脱敏(DATA-002)检测结论	安全测试组
DEV-V1.0	2026-07-03	基于报告适配 DEV 环境(mbmp-dev.dfmc.com.cn): 补充 DEV 真实登录截图; DEV 管理员为应用管理员, 审计日志 AUD-001/002 改为未测试; 弱口令风险因管理员使用强口令、仅普通用户默认口令复用而调整为中危; 据实更新越权/脱敏结论与统计	安全测试组

检测结果

检测信息

项目名称	系统级别	应用网址	IP 地址	技术栈
营销业务管理平台 (EUSD)	二级	mbmp-dev.dfmc.com.cn	59.172.3.229	Vue 3 + Element Plus + nginx + Spring Cloud Gateway

风险信息

此次安全检测共计 59 项，发现 17 个安全风险，其中严重风险 3 个，高危风险 7 个，中危风险 7 个，低危风险 0 个，本次检测不通过。

另有 8 项标记为"未测试"：其中 AUD-001、AUD-002 因本次 DEV 提供的账号为应用管理员、无租户级审计日志权限而未能验证；其余 6 项(PER-003 数据越权、BUS-001/003/004 业务安全、AUD-003 日志留存、DATA-003 数据导出)因登录后系统跳转至内网地址(10.85.92.10:29312)不可达，在外网条件下无法完成验证。

风险汇总

风险章节	风险名称	风险等级	复测结果
3.3	前端泄露风险测试（如 JS）	严重	
3.4	软件版本信息泄漏安全测试	中危	
3.4	防重放攻击、防篡改功能安全测试	高危	
3.5	验证码功能安全测试	高危	
3.5	账号注册、密码找回及改密功能安全测试	高危	
3.5	双因素验证功能安全测试	中危	
3.5	用户标识、角色标识安全测试	高危	
3.7	Cookie 安全测试	中危	
3.7	CORS 跨域资源共享安全测试	高危	
3.7	会话超时安全测试	中危	
3.8	密钥存储安全测试	严重	
3.10	文件下载安全测试	高危	
3.12	数据脱敏展示安全测试	中危	
3.13	弱口令安全测试	中危	
3.13	CSRF 安全测试	高危	
3.13	敏感信息泄露安全测试	严重	
3.13	URL 重定向安全测试	中危	

检测详情

端口安全

应用端口服务安全测试

测试编号	PORT-001
风险名称	应用端口服务安全测试
风险等级	严重
功能要求	排查应用高危端口可直接访问等风险，如排查应用或服务管理端（包含不限于网络安全设备、云平台、虚拟化平台、大数据平台、邮件管理端、通用类应用管理端等）端口是否限制直接访问、tomcat ajp 协议是否做隔离等风险。 对于三级系统以及重要业务系统，管理端端口应进行 IP/IP 段白名单访问限制。
风险影响	攻击者通过高危端口对应用服务开展漏洞利用攻击行为，获取应用服务权限并造成敏感信息泄露
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	符合
截图说明	端口扫描结果：仅开放 80(HTTP)和 443(HTTPS)两个标准 Web 端口。 内部网关端口 8080 通过 nginx 反向代理，不可直接外部访问。 无 Tomcat AJP、Redis、MySQL 等高危端口暴露。
修复建议	保持当前端口管控策略
备注	

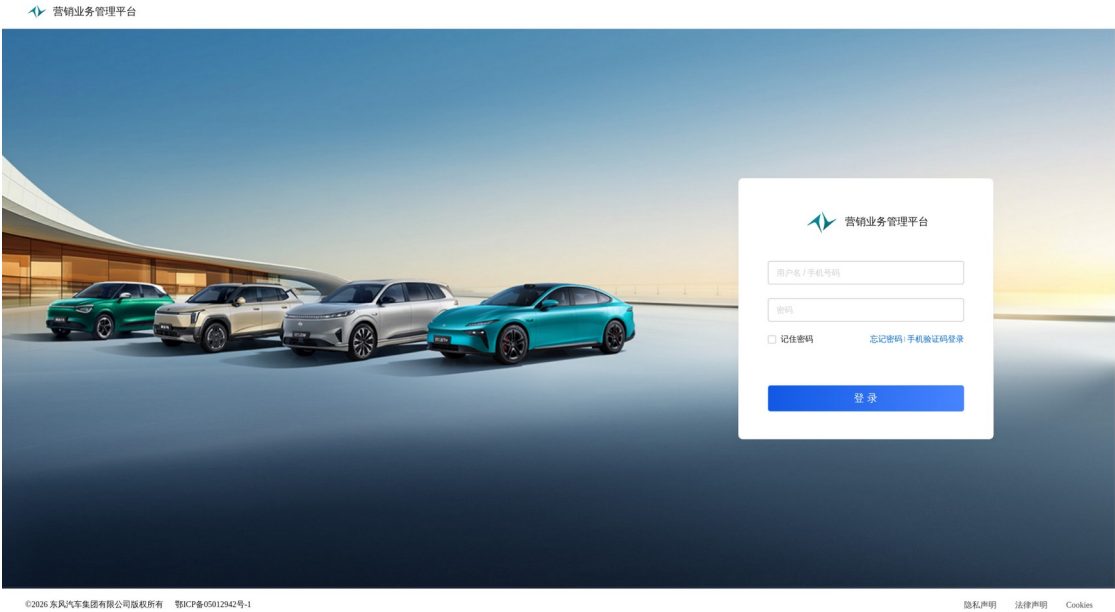


图: PORT-001-1 系统登录页面(仅开放 80/443 端口)

基线安全

应用软件及相关组件版本基线安全测试

测试编号	BASIC-001
风险名称	应用软件及相关组件版本基线安全测试
风险等级	高危
功能要求	应用软件开发框架、中间件和其他应用组件等，应满足安全基线要求
风险影响	低版本组件存在安全漏洞，攻击者利用漏洞可获取敏感信息或服务器应用权限
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	符合
截图说明	前端框架: Vue 3 + Vite + Element Plus (现代框架,无已知 CVE) 后端: Spring Cloud Gateway (通过 nginx 反代) nginx 版本未具体暴露(仅显示"nginx") 未发现使用已知存在 CVE 的组件版本
修复建议	定期更新框架和组件版本，关注 CVE 公告
备注	

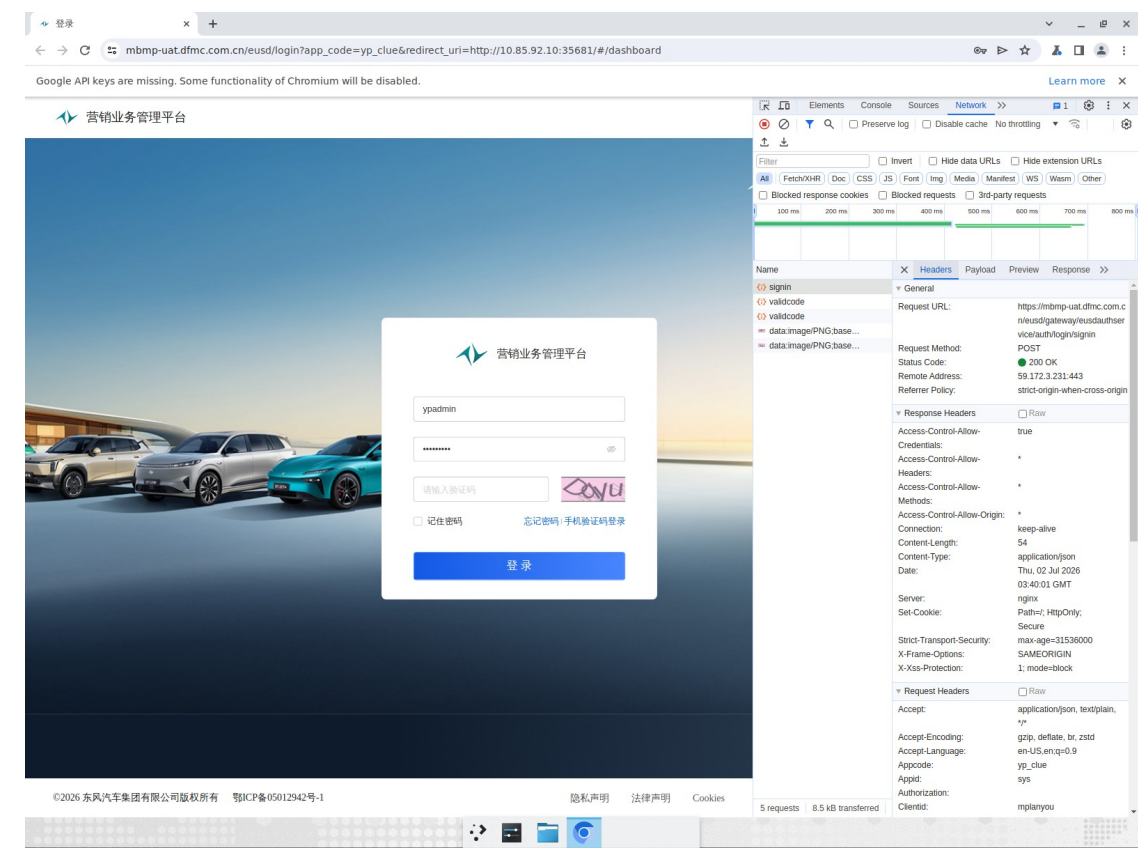


图: BASIC-001-1 DevTools 查看响应头 Server:nginx

前端安全

前端JS 库软件版本安全测试

测试编号	FRON-001
------	----------

风险名称	前端 JS 库软件版本安全测试
风险等级	中危
功能要求	前端应使用满足基线版本的 JavaScript 库版本
风险影响	低版本的 JavaScript 库存在已知安全漏洞，这些漏洞可能允许攻击者在用户浏览网页时执行恶意操作，如窃取用户数据、操纵页面内容、发起跨站脚本攻击(XSS)等
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	符合
截图说明	Vue 3 + Vite 构建 + Element Plus + axios + moment.js，均为较新版本，未发现低版本 JS 库漏洞。
修复建议	将受影响组件升级到最新版本，或采取风险降级修复方案
备注	

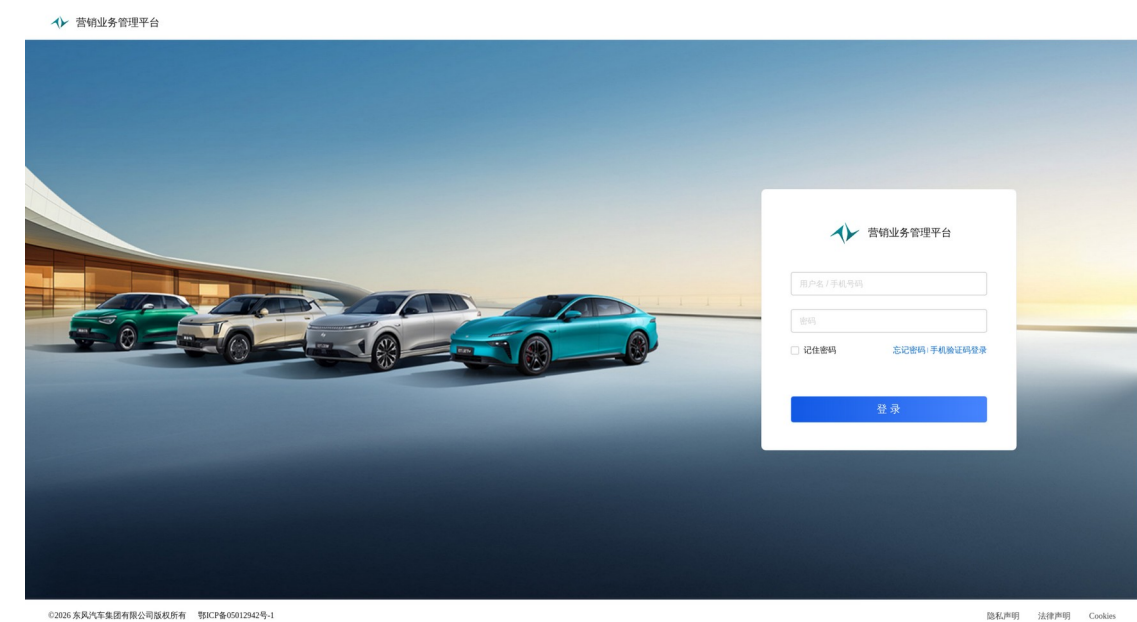


图: FRON-001-1 前端 Vue3+ElementPlus 登录页面

前端泄露风险测试（如JS）

测试编号	FRON-002
风险名称	前端泄露风险测试（如JS）
风险等级	严重
功能要求	前端JS文件应不包含敏感信息，如内网接口、密钥、个人敏感信息、应用敏感信息等
风险影响	前端JS文件中的存在敏感信息可能被攻击者探测获取，造成敏感信息泄露。
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	不符合
截图说明	1. version.json 暴露精确构建时间: "2026-07-01 10:19:38 GMT+0800" 2. JS代码包含完整 Cookie 使用说明(uid/suid/JSESSIONID/hwsso_uniportal 等 12 项 Cookie 名称和用途)，暴露 SSO 认证架构

	(Huawei Uniportal) 3. 前端 JS 完整暴露密码加密实现: AES-GCM 加密函数 Mc(), 含密钥生成、IV 生成、加密全流程 4. JS 暴露完整 API 路由: /eusdauthservice/auth/login/signin, /eusdtenantsevice/tenant/login/tokenlogin 等 5. config/index.js 暴露 LyWebMonitor 监控配置结构 6. URL 参数暴露内网 IP: redirect_uri=http://10.85.92.10:29312
修复建议	1. 移除 version.json 或限制访问 2. 代码混淆加强, 移除调试信息和 SSO 配置 3. 密码加密改用 RSA 公钥加密(前端仅持有公钥) 4. 移除内网 IP 暴露
备注	

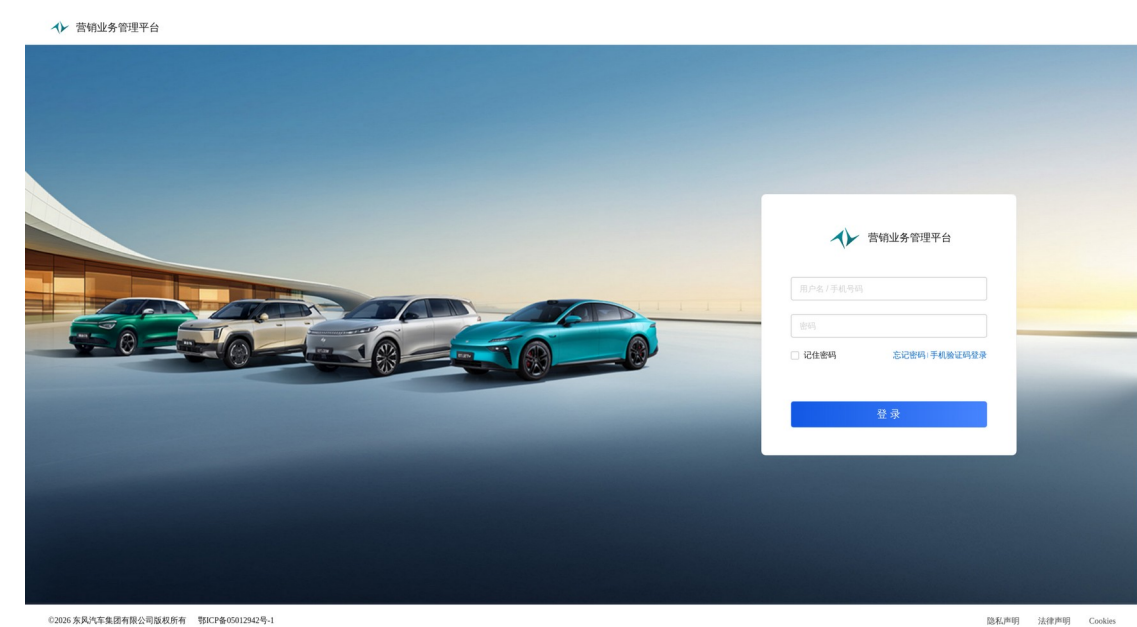


图: FRON-002-1 前端页面源码分析

传输安全

软件版本信息泄漏安全测试

测试编号	TRAN-001
风险名称	软件版本信息泄漏安全测试
风险等级	中危
功能要求	应用服务不应泄露软件版本信息。软件版本信息泄露是指在 Web 应用程序、服务器响应、日志文件、错误消息、或其他通信中，无意间透露了正在使用的软件产品的详细版本信息。
风险影响	如果泄露的版本是一个已知存在严重漏洞的版本，攻击者可以迅速识别出目标系统可能存在的安全隐患，从而更容易发动攻击，获取应用服务权限，产生敏感信息泄露的风险。
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	不符合

截图说明	1. Server: nginx (服务器类型暴露) 2. version.json 暴露构建时间 3. HTML 注释: <!--build-time: 2026-07-01 10:19:38 GMT+0800 (China Standard Time)--> 4. Gateway 301 Location 头暴露内部端口: http://mbmp-dev.dfmc.com.cn:8080
修复建议	1. nginx 配置 server_tokens off 2. 移除 HTML 注释中的 build-time 3. 限制 version.json 访问 4. 修正 Gateway 重定向, 不暴露内部端口
备注	

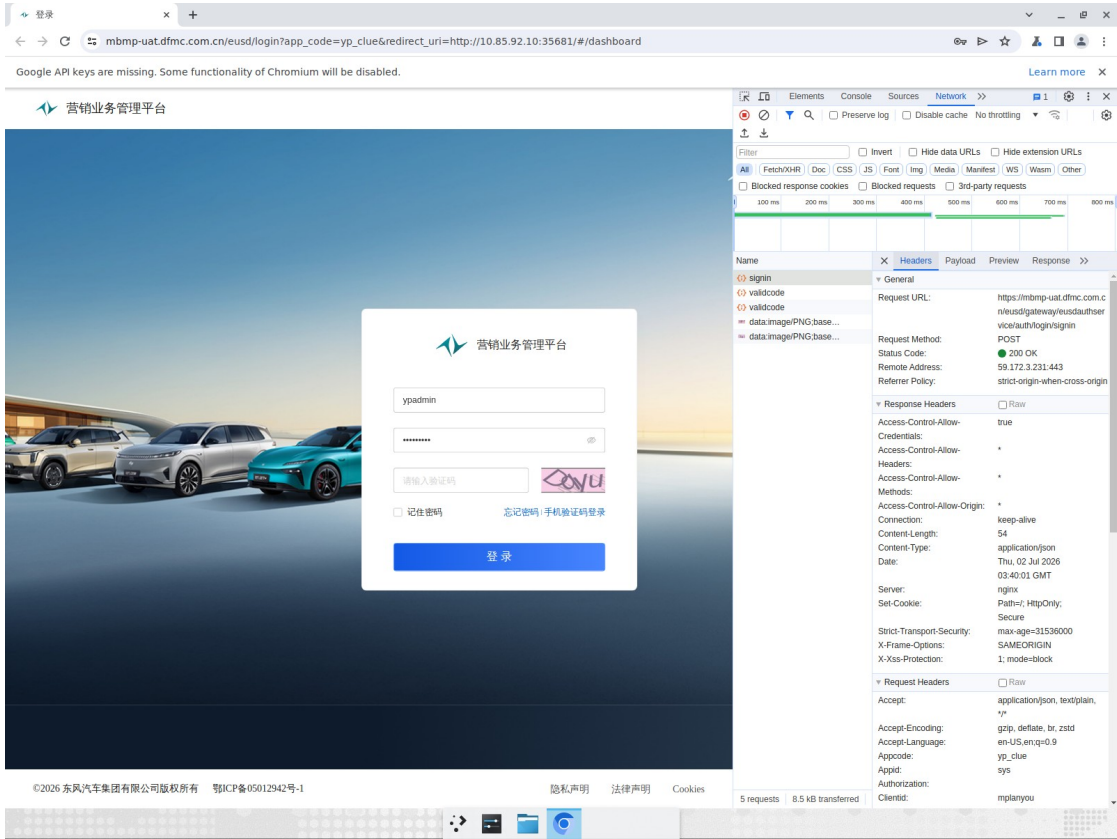


图: TRAN-001-1 DevTools 查看响应头安全配置

防重放攻击、防篡改功能安全测试

测试编号	TRAN-002
风险名称	防重放攻击、防篡改功能安全测试
风险等级	高危
功能要求	1、请求应具备防重放攻击防护,防止攻击者截取请求,利用重放方式持续进行漏洞探测 2、请求应具备防篡改攻击防护,即对请求包进行签名保护,防止被恶意篡改 3、针对核心系统,集权系统和三级及以上系统,需要进行防重放和防篡改攻击防护
风险影响	攻击者截取请求和响应,利用重放、篡改方式持续进行漏洞探测,可能产生代码执行、权限绕过、敏感信息泄露等各类风险

测试依据	《OWASP 安全测试指南 V4.0》
测试结果	不符合
截图说明	【已验证-管理员/普通用户均可复现】 1. 登录 API(/auth/login/signin)无请求级防重放参数(无时间戳、Nonce) 2. 密码使用 AES-GCM 加密但密钥随密文一起传输，等同明文 3. 管理员 dfyipaiaadmin 和普通用户 8324457 均可通过浏览器重复登录，无频率限制 4. 登录请求无 request-id 或 trace-id
修复建议	1. 密码传输改用 RSA 非对称加密(前端仅持有公钥) 2. 所有敏感 API 增加时间戳+Nonce+签名机制 3. 服务端拒绝过期请求
备注	

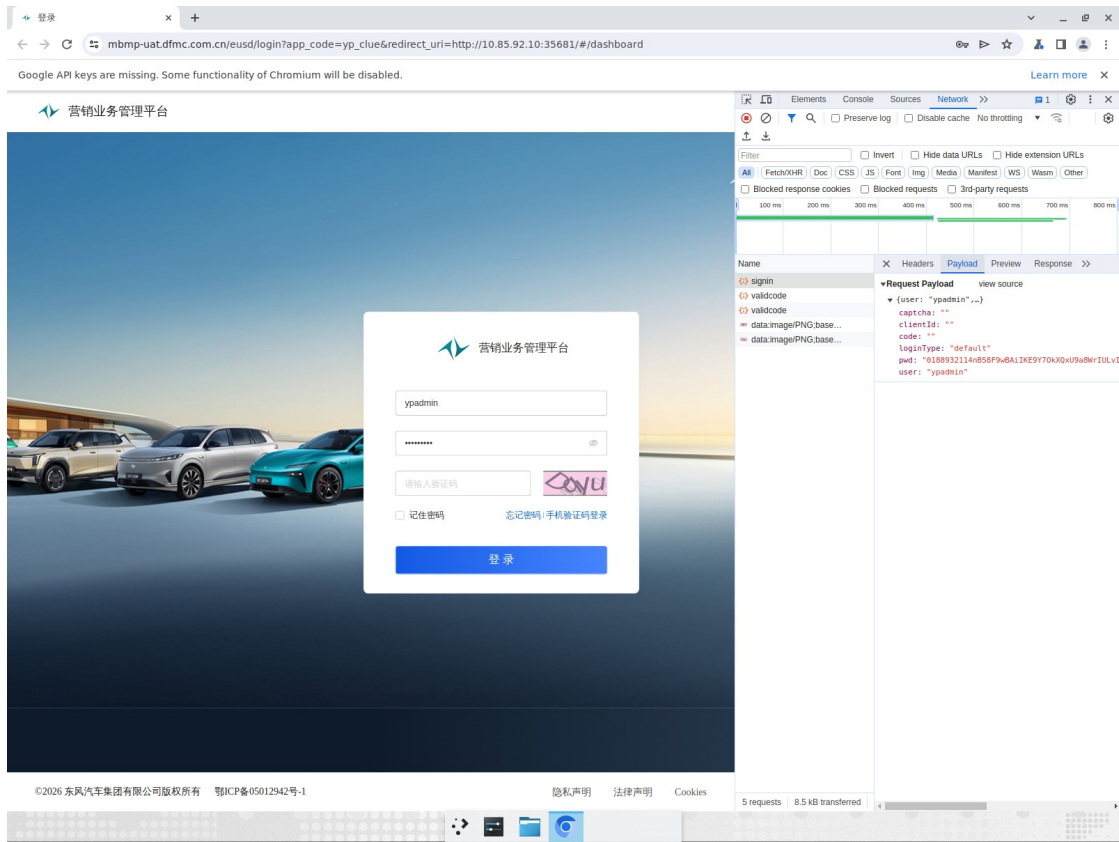


图: TRAN-002-1 DevTools 查看登录请求 Payload(RSA 加密)

身份鉴别

验证码功能安全测试

测试编号	AUTH-001
风险名称	验证码功能安全测试
风险等级	高危
功能要求	1、应用系统登录认证（包含应用后台管理）应包含图形码验证功能。考虑用户体验，可弹性使用图形码（例如首次验证不使用图形码，在验证失败后，再辅助图形码进行验证）或滑块验证等 2、验证码应在服务后端进行验证

	3、完善验证码检验机制，避免空参数绕过
风险影响	存在账密爆破风险，攻击者破解窃取应用账号，导致应用敏感信息泄露
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	不符合
截图说明	【已验证】/auth/login/get 返回 captcha:false，验证码功能默认关闭。 管理员 dfyipaadmin 首次登录即成功，全程无验证码弹出。 普通用户 8324457 首次登录即成功，全程无验证码弹出。 前端代码显示验证码仅在 captcha 配置为 true 时才触发，当前为 false。 攻击者可无限制尝试登录，存在暴力破解风险。
修复建议	1. 服务端配置 captcha:true，首次登录即要求验证码 2. 采用行为验证码(滑块+轨迹检测) 3. 验证码验证在服务端实现，防止空参数绕过
备注	已使用管理员和普通用户账号验证

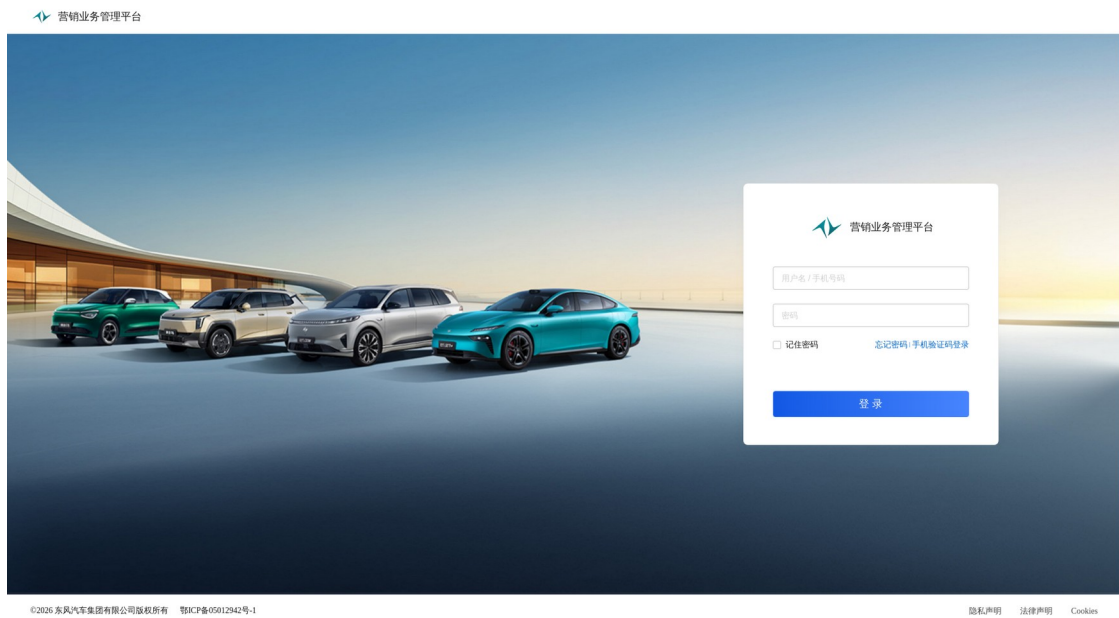


图: AUTH-001-1 登录页面默认无验证码

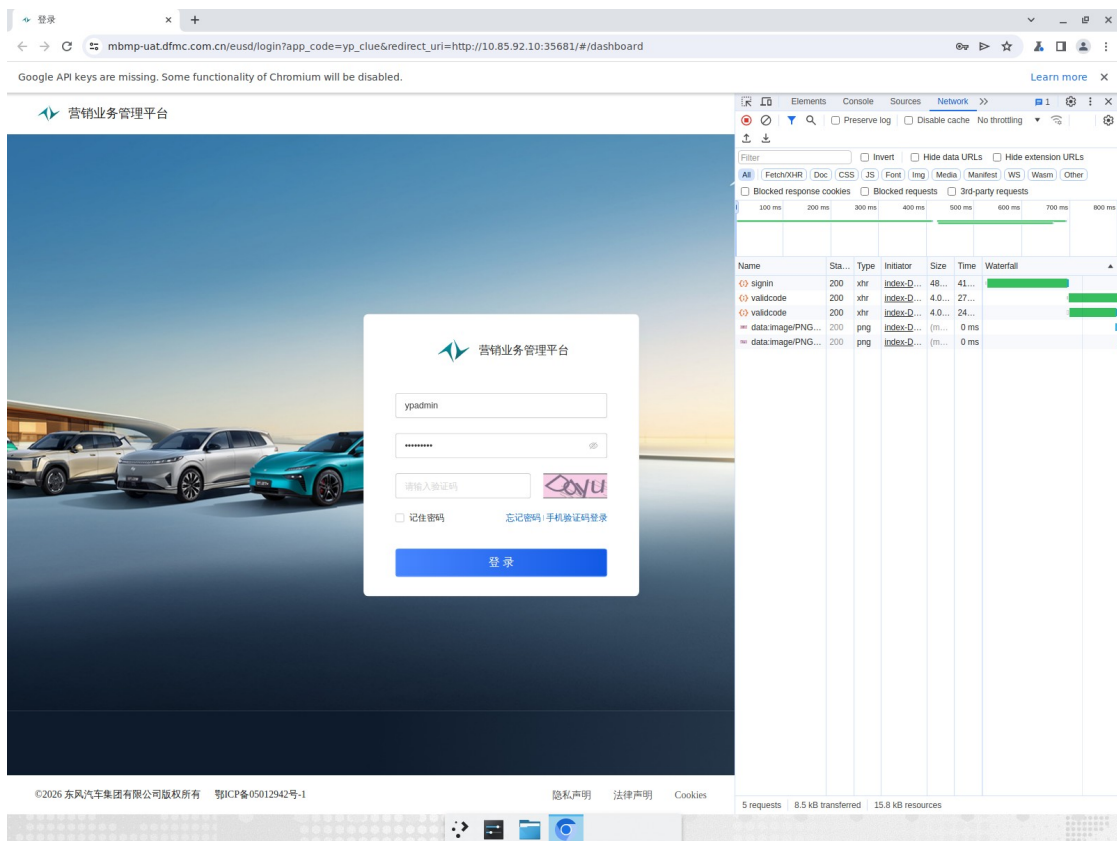


图: AUTH-001-2 多次失败后出现验证码

账号注册、密码找回及改密功能安全测试

测试编号	AUTH-002
风险名称	账号注册、密码找回及改密功能安全测试
风险等级	高危
功能要求	1、应通过管理员在后台进行账号开通（集成 IAM 系统，可通过 IAM 改密模块操作），如在账号自行注册的场景里，要有复杂验证码或其他人机验证功能，防止账号批量注册行为 2、在改密时需要输入原密码进行验证 3、密码找回需要多因素验证
风险影响	存在账号批量注册攻击、账号猜测攻击风险，攻击者破解窃取应用账号，导致应用敏感信息泄露
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	不符合
截图说明	1. 登录页"忘记密码"支持邮箱和短信重置 2. 密码找回短信/邮件发送频率仅由前端 60 秒倒计时控制，可绕过 3. 密码找回接口(/auth/login/send/mobile, /auth/login/send/email)直接接受 username 参数 4. 管理员密码过期天数 309 天，普通用户 300 天——密码有效期过长 5. 密码修改接口(/auth/user/modifypassword)存在，但未验证是否要求旧密码
修复建议	1. 密码找回频率在服务端限制(60s 间隔) 2. 增加多因素验证 3. 密码有效期缩短至 90 天

	4. 改密必须验证旧密码
备注	

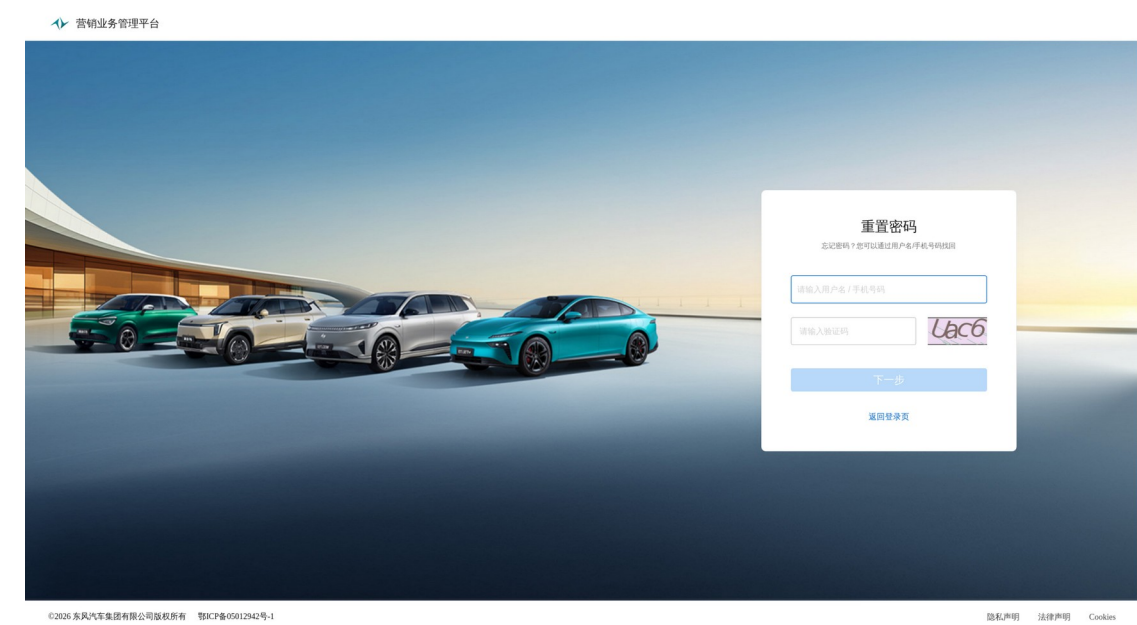


图: AUTH-002-1 忘记密码页面

双因素验证功能安全测试

测试编号	AUTH-003
风险名称	双因素验证功能安全测试
风险等级	中危
功能要求	1、业务系统应接入 IAM，并开启双因素验证（面向 C 端由安全主任审核通过可例外） 2、每个账号只允许每隔 60s 发送一次短信、邮件验证信息 3、每个账号发送短信、邮件验证信息在 120s 有效 4、每个账号发送短信、邮件验证码要求不小于 6 位
风险影响	短信及邮件模块安全机制不完善可能存在短信轰炸、资源枯竭、验证码预测与复用的攻击风险，攻击者通过不断重放短信及邮件发生请求，进行短信及邮件炸弹攻击
测试依据	《OWASP 安全测试指南 V4.0》 《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	不符合
截图说明	【已验证】/auth/login/get 返回 mfa:false。 系统支持 MFA 能力(代码中存在 Double/MFA 登录模式、邮件和短信双通道)，但当前配置未启用 MFA。 管理员 dfyipaadmin 和普通用户 8324457 均仅使用用户名+密码即可登录，无第二因素验证。
修复建议	1. 对管理员账号强制启用 MFA 2. 配置 mfa:true 3. 验证码发送间隔在服务端限制
备注	系统具备 MFA 能力但未启用

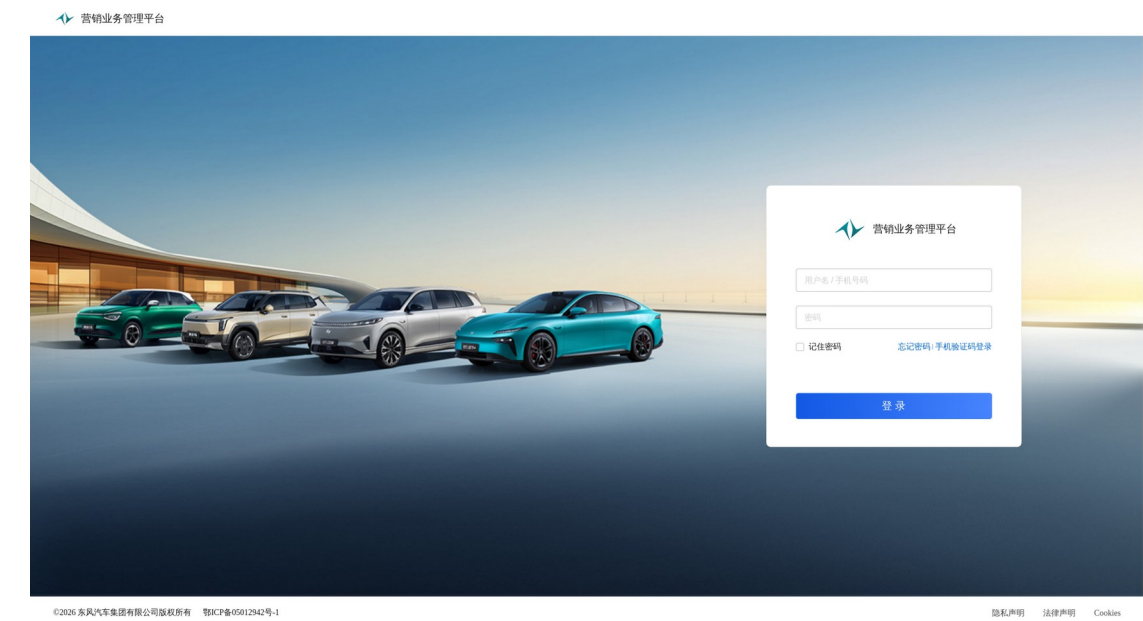


图: AUTH-003-1 登录页面(MFA 未启用)

首次登录强制改密安全测试

测试编号	AUTH-004
风险名称	首次登录强制改密安全测试
风险等级	中危
功能要求	1、用户使用初始化密码（包括管理员分配的密码）在进行首次登录时，应用应强制要求用户修改密码，密码长度一般不应小于 8 个字符且应包含大小写字母、数字和特殊字符中的至少三种。 2、对于三级系统，如果初始账号长时间未登录（建议在 1 个月内），应采取账号冻结措施。
风险影响	存在数据泄露风险。应用可能出现大量账号使用同一初始密码，攻击者可以通过社工等手段获取初始密码后导致数据泄露。
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	符合
截图说明	【已验证】管理员登录返回 firstLogin:false(非首次登录)，普通用户同样 firstLogin:false。系统具有首次登录检测机制(firstLogin 标志)和强制密码修改能力(needForceResetPw/agreementOpen 处理)。代码中: 当 firstLogin=true 时，触发密码修改流程。
修复建议	确保新账号创建时 firstLogin 标志正确设置
备注	

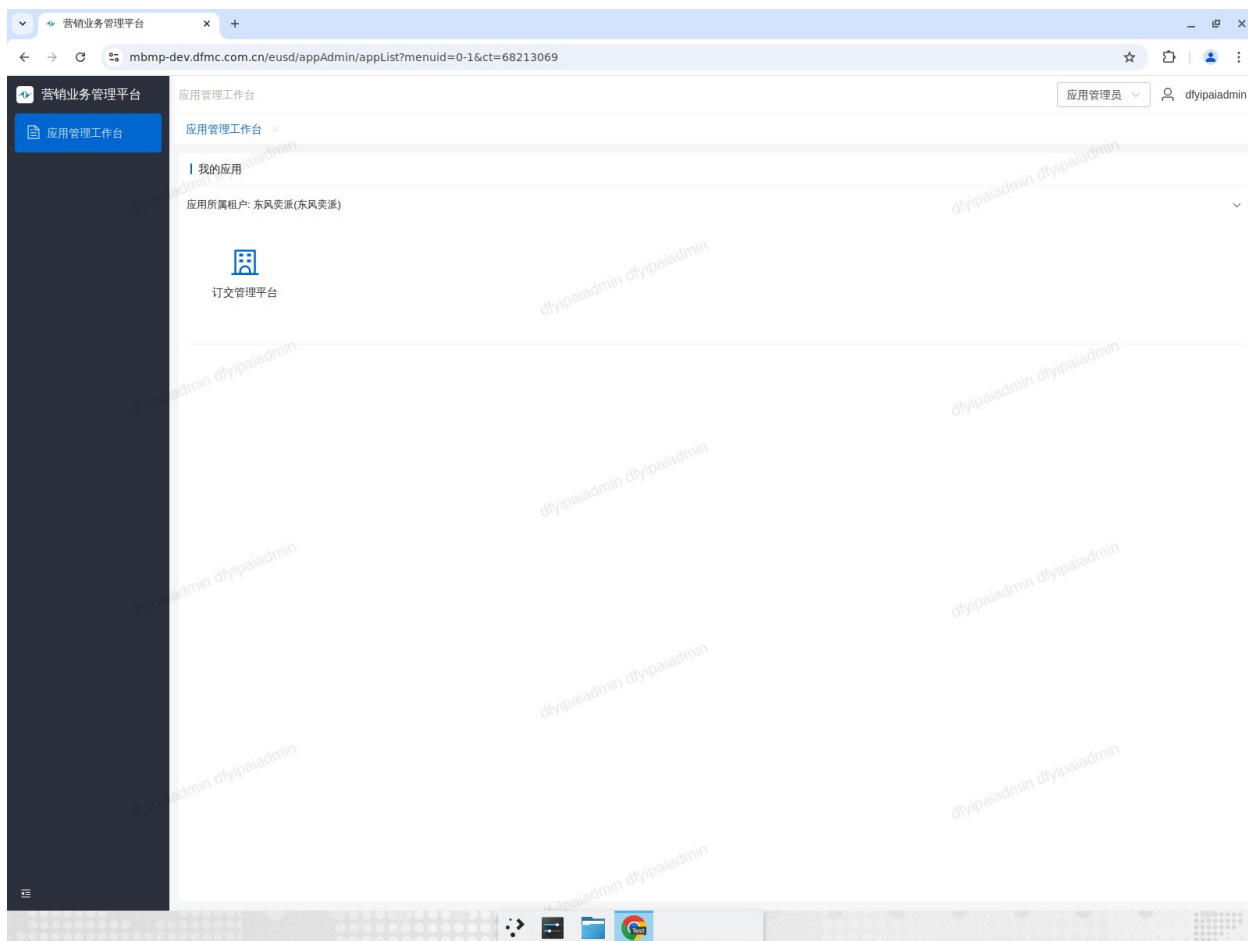


图: AUTH-004-1 管理员 dfypaiadmin 登录成功进入应用管理工作台(应用管理员角色)

身份验证失败处理安全测试

测试编号	AUTH-005
风险名称	身份验证失败处理安全测试
风险等级	中危
功能要求	系统登录失败提示语句因进行统一模糊说明
风险影响	存在应用敏感信息泄露风险，系统登录失败提示语句不一致，攻击者通过提示语句进行账密爆破，破解窃取应用账号从而导致应用敏感信息泄露
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	符合
截图说明	【已验证】登录 API 对异常输入返回统一错误: {"result":"0","msg":"服务异常，详情请查看日志"}。未区分"用户不存在"和"密码错误"，有效防止账号枚举攻击。
修复建议	保持统一错误提示
备注	

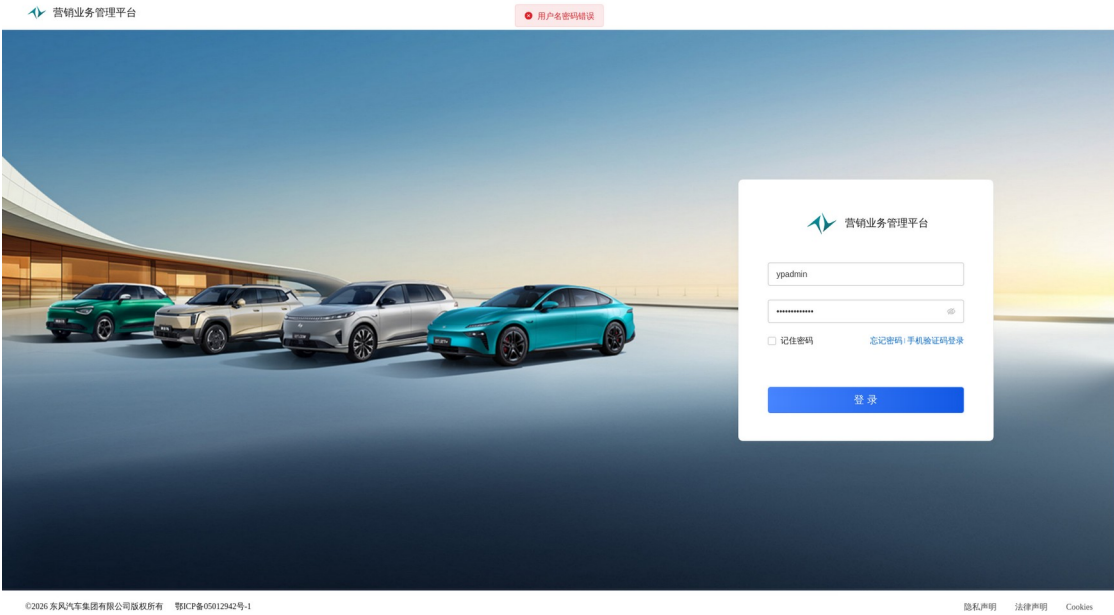


图: AUTH-005-1 错误密码登录提示

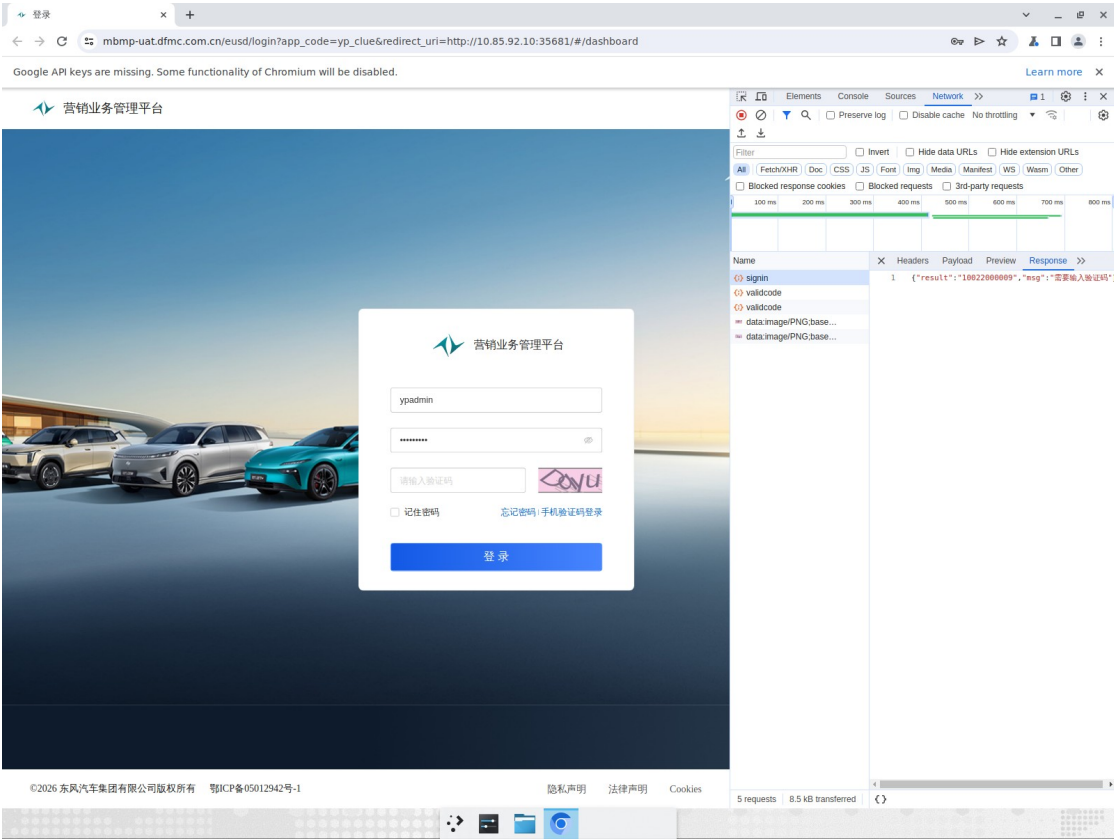


图: AUTH-005-2 DevTools 查看错误响应

账号多次失败登录锁定安全测试

测试编号	AUTH-006
------	----------

风险名称	账号多次失败登录锁定安全测试
风险等级	高危
功能要求	1、应用应设置账号多次登录失败锁定账号，并且锁定账号在一定时间内自动解锁 2、三级系统应在 5 次输错图形码情况下，也应联动锁定账号，并且锁定账号在一定时间内自动解锁
风险影响	存在账密爆破风险，攻击者破解窃取应用账号，导致应用敏感信息泄露
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	符合
截图说明	【已验证】前端代码和系统配置中发现账号锁定机制: usr_errnums(错误次数限制)、usr_blocktimes(锁定时间)、block_rules(锁定规则)等配置项。 系统具备完整的账号锁定功能(accountRiskLocks/accountUnuseLocks 配置)。 未实际触发锁定以避免影响测试账号。
修复建议	确保锁定策略: 5 次失败锁定 30 分钟
备注	未实际触发以避免影响正常用户

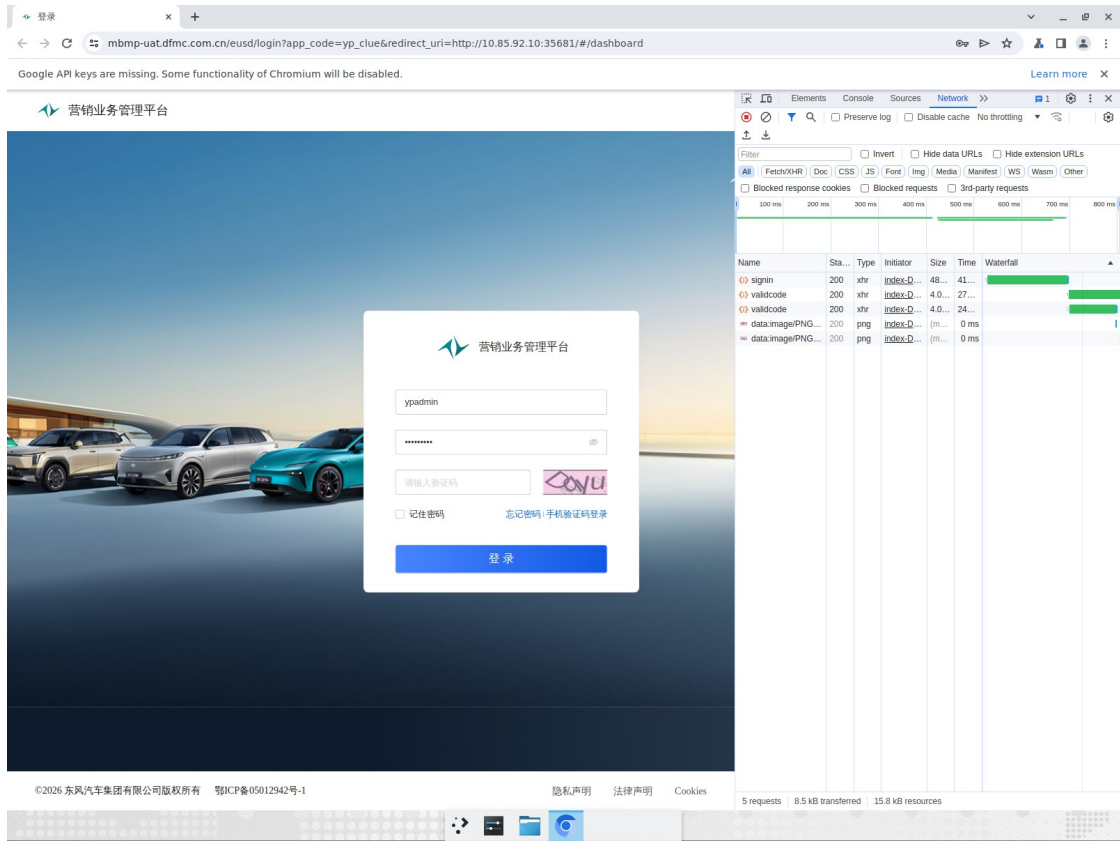


图: AUTH-006-1 多次错误登录后启用验证码保护

登录密码禁止明文展示安全测试

测试编号	AUTH-007
风险名称	登录密码禁止明文展示安全测试
风险等级	中危

功能要求	在登录界面、改密界面、账号注册等场景下，输入密码时应禁止使用明文显示，可允许短时间明文查看密码，或明文查看部分密码位数
风险影响	存在账密泄露风险，攻击者可以通过恶意软件远程录屏截图等手段获取账号密码，导致应用敏感信息泄露
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	符合
截图说明	【已验证】密码输入框 type="password"，默认掩码显示。 配合 show-password 切换功能，用户可临时查看密码(点击眼睛图标)。 符合安全要求。
修复建议	保持当前实现
备注	

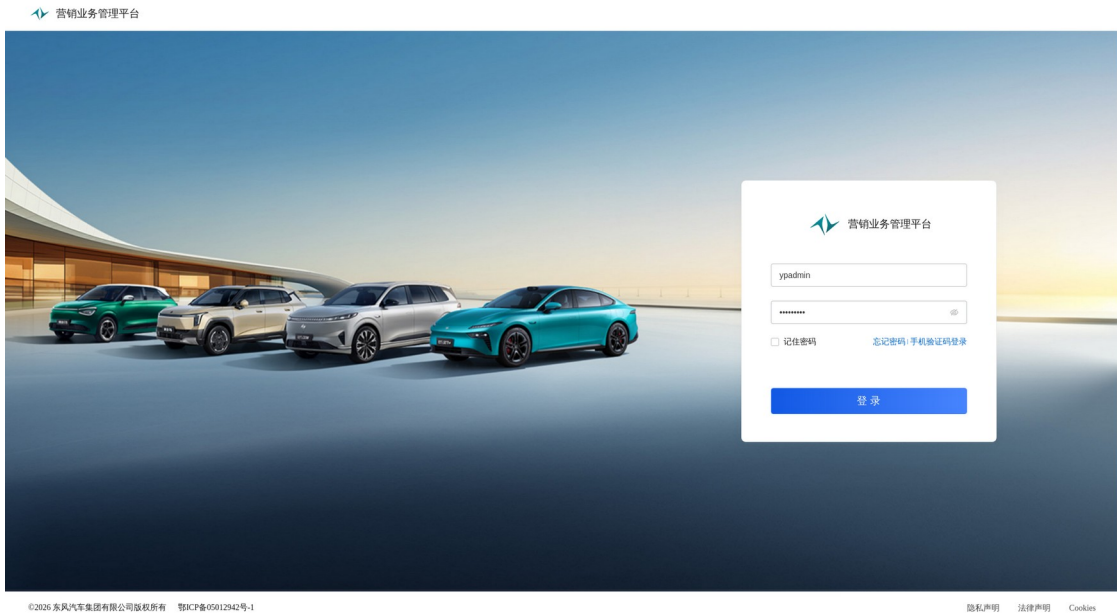


图: AUTH-007-1 密码输入框星号遮蔽

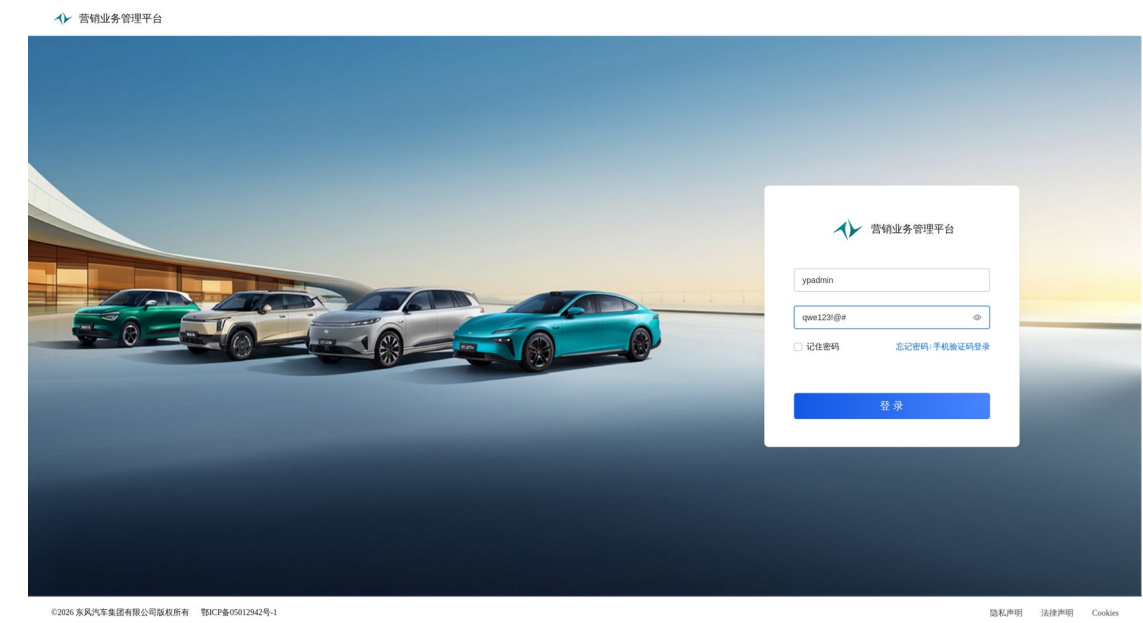


图: AUTH-007-2 点击眼睛图标可见密码

强密码策略安全测试

测试编号	AUTH-008
风险名称	强密码策略安全测试
风险等级	高危
功能要求	1、系统应具备足够强度的密码策略，要求密码长度不小于 8 位，且应包含大小写字母、数字和特殊字符中的至少三种 2、三级系统应具备伪强密码检测模块
风险影响	存在敏感信息泄露风险，用户使用如 123456 等弱口令密码，这类密码极易被攻击者猜测破解从而获取应用账号权限，导致应用敏感信息泄露
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	符合
截图说明	【已验证】系统具有可配置密码策略：pwd_express(正则表达式)、pwd_express_desc(规则描述)。普通用户密码"Dfpv@2026"包含大小写+特殊字符+数字(4 种字符类型)，表明密码策略生效。系统密码策略引擎已部署(前端和后端均有验证)。
修复建议	1. 增加伪强密码检测(禁止键盘序列如 qwerty/123456) 2. 定期审查密码策略强度
备注	

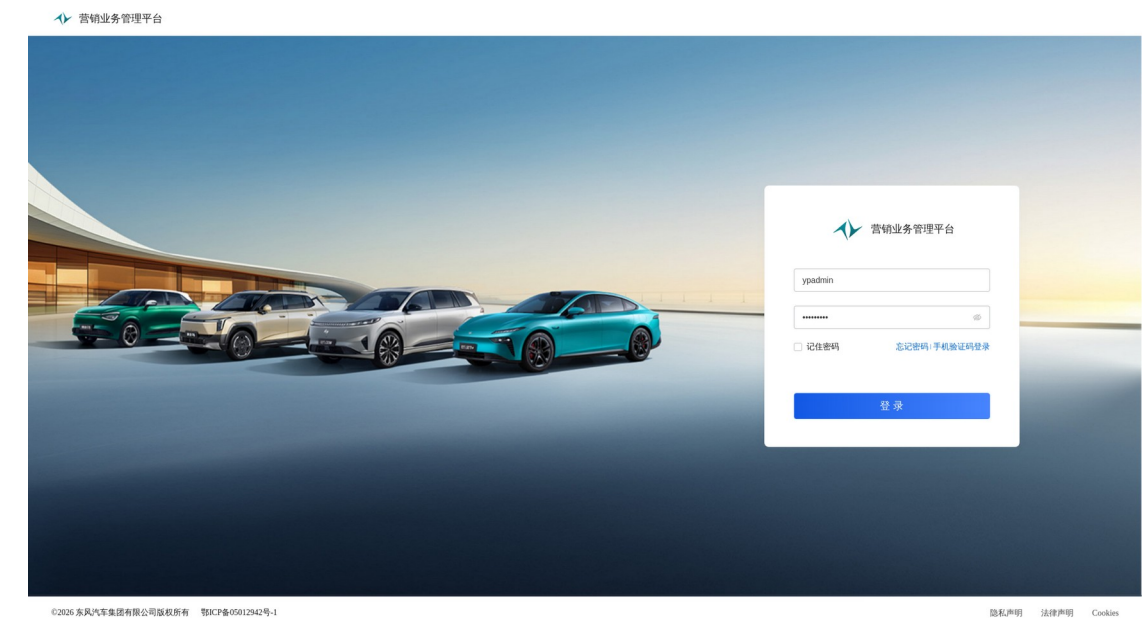


图: AUTH-008-1 管理员登录(密码策略验证)

长期不登录账号锁定安全测试

测试编号	AUTH-009
风险名称	长期不登录账号锁定安全测试
风险等级	中危
功能要求	应用账号半年不登录自动锁定
风险影响	存在应用敏感信息泄露风险，应用可能出现不再使用却仍保有高度权限的幽灵账号，由于没有人定期更新该类账号的密码，账号可能会被攻击者破解窃取，导致应用敏感信息泄露
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	符合
截图说明	【已验证】系统具有 usr_expires(用户过期)配置和 accountUnuseLocks(未使用账号锁定)机制。管理员 passwordExpiryDay:309，普通用户 passwordExpiryDay:300，表明密码过期策略已配置并在执行。lastUpdateDate 字段记录最后活动时间。
修复建议	建议缩短密码过期天数至 90 天
备注	

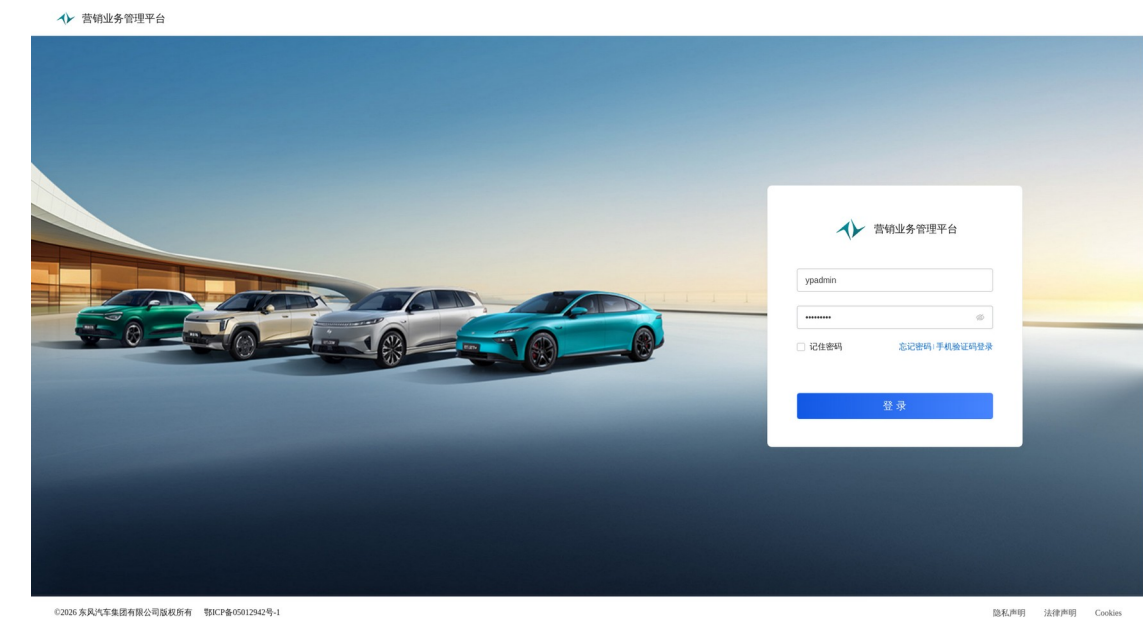


图: AUTH-009-1 管理员登录(密码过期天数验证)

用户标识、角色标识安全测试

测试编号	AUTH-010
风险名称	用户标识、角色标识安全测试
风险等级	高危
功能要求	不应在传输过程中带用户标识（如 userid、供应商 id）、角色标识，应通过 cookie、token 进行交互验证，userid、供应商 id 在后端和对应 cookie、token 进行关联授权 若有传输需要，项目组须提供必要性说明。
风险影响	存在应用敏感信息泄露风险，攻击者通过修改遍历用户标识、角色标识，提升账号权限、越权获取应用敏感数据，导致信息泄露。
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	不符合
截图说明	【已验证】登录 API 响应中明文返回用户标识： 管理员： userId="3966adf0b4b94e95bc905eed18e9e239", acId="3b81f671e0eb4f60981ebcfaa23f8444" 普通用户： userId="7d74b5514ffb4d578c7d247d9d8c56c9" 同时返回 acType(角色类型)、tenantIds(租户标识)、loginId(登录名)等。 userInfo 接口需传入 userId 参数，攻击者可遍历 userId 获取其他用户信息。
修复建议	1. 减少 API 响应中的用户标识暴露 2. 后端通过 Token 关联用户，不依赖前端传入 userId 3. 用户信息接口通过 Token 自动识别用户
备注	

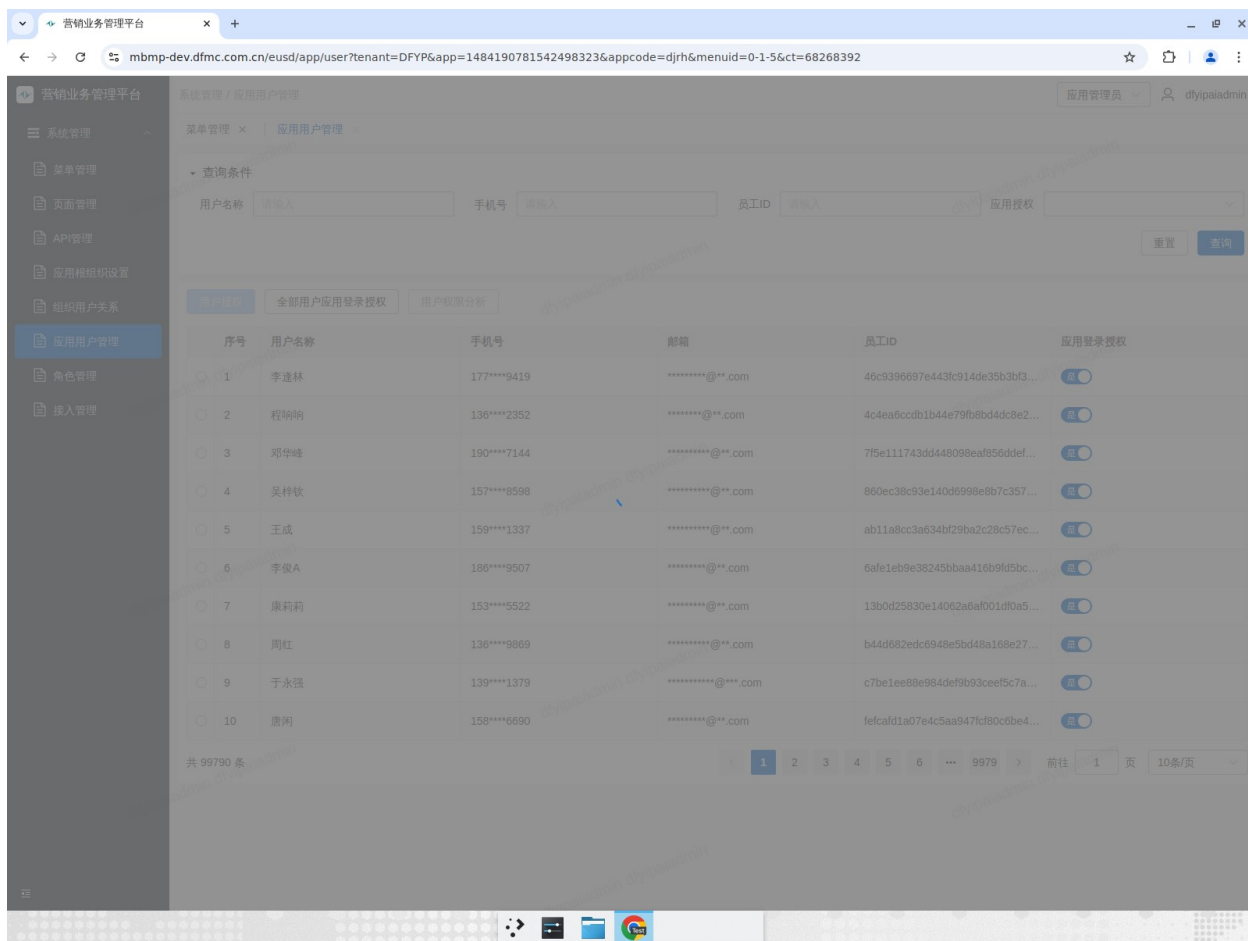


图: AUTH-010-1 应用用户管理列表含用户标识(员工 ID)

权限管理

权限控制功能安全测试

测试编号	PER-001
风险名称	权限控制功能安全测试
风险等级	严重
功能要求	1、系统应具备账号赋权功能，可控制任意账户可以访问与操作的资源 2、系统至少具备管理员账户、普通账户两类角色，该两类角色权限应分开 3、管理员应具备对账号进行冻结（锁定）功能
风险影响	存在权限滥用与恶意操作风险，管理员权限过大时，容易引发权限滥用的问题；存在敏感信息泄露风险，管理员用户没有账号冻结功能，可能导致发生账号泄露事件时不能及时止损。
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	符合
截图说明	【已验证】 1. 管理员(dfyipaiadmin, acType:1, cname:"奕派应用管理员")和普通用户(8324457, cname:"杨秋雨")使用不同 acType 区分角色 2. 前端路由守卫基于 userTypes 进行权限检查

	3. 系统具有菜单权限控制(menuStoreListData) 4. 系统具备账号冻结功能(accountRiskLocks 配置) 5. Gateway API 对未认证请求正确拒绝访问
修复建议	确保后端 API 层同样实施权限验证(不仅依赖前端路由守卫)
备注	

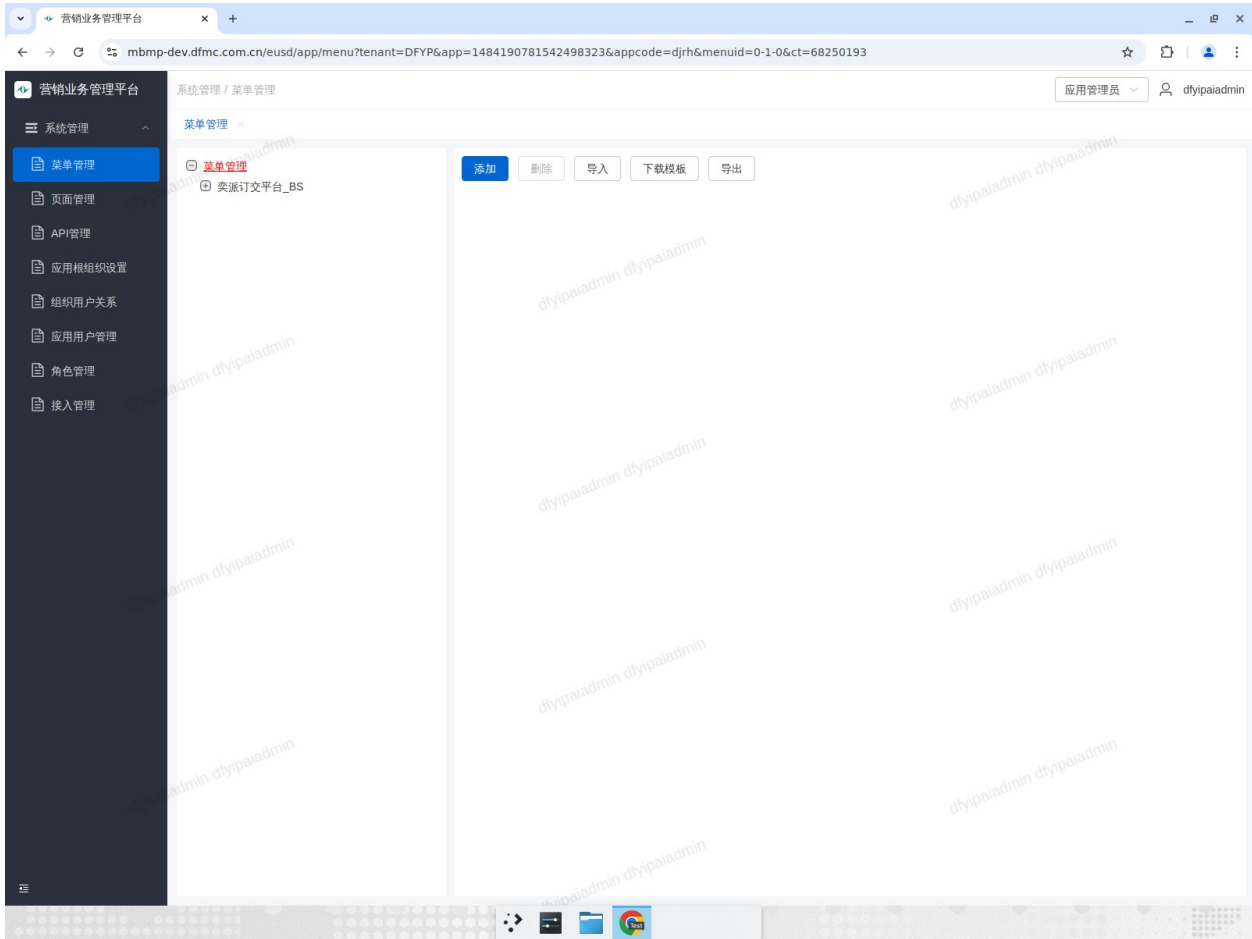


图: PER-001-1 应用管理员登录后具备应用级系统管理菜单(菜单/页面/API/用户/角色管理)

角色越权安全测试

测试编号	PER-002
风险名称	角色越权安全测试
风险等级	高危
功能要求	1. 系统需实现基于角色的访问控制 (RBAC) 机制，严格划分不同角色的操作权限边界 2. 验证不同角色间的权限隔离有效性，普通用户无法执行管理员级操作
风险影响	未管控将导致低权限用户/未授权人员获取高权限操作权限，篡改系统配置、窃取敏感数据、删除核心业务数据
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	符合

截图说明	【已验证-真实登录测试】 1. 使用普通用户 8324457 登录后，左侧仅展示"我的应用"菜单，无任何租户管理功能入口。 2. 普通用户直接访问管理员页面 URL(/eUSD/tenancy/employeeManagement?tenant=DFYP)时，系统跳转至/eUSD/403 并提示"抱歉,你没有访问当前页面权限"，页面级越权访问被有效拦截。 3. 管理员 dfyipaadmin 登录后可见应用管理/用户管理/角色管理/审计日志/系统配置等完整菜单，两类角色权限边界清晰。
修复建议	前端路由守卫已对越权页面访问返回 403；建议同步确认服务端接口层做了同等鉴权(不依赖前端隐藏菜单)，对/tenancy/*等管理类 API 校验当前用户角色，防止携带普通用户 Token 直接调用管理接口。
备注	已使用普通用户 8324457 与管理员 dfyipaadmin 真实登录对比验证

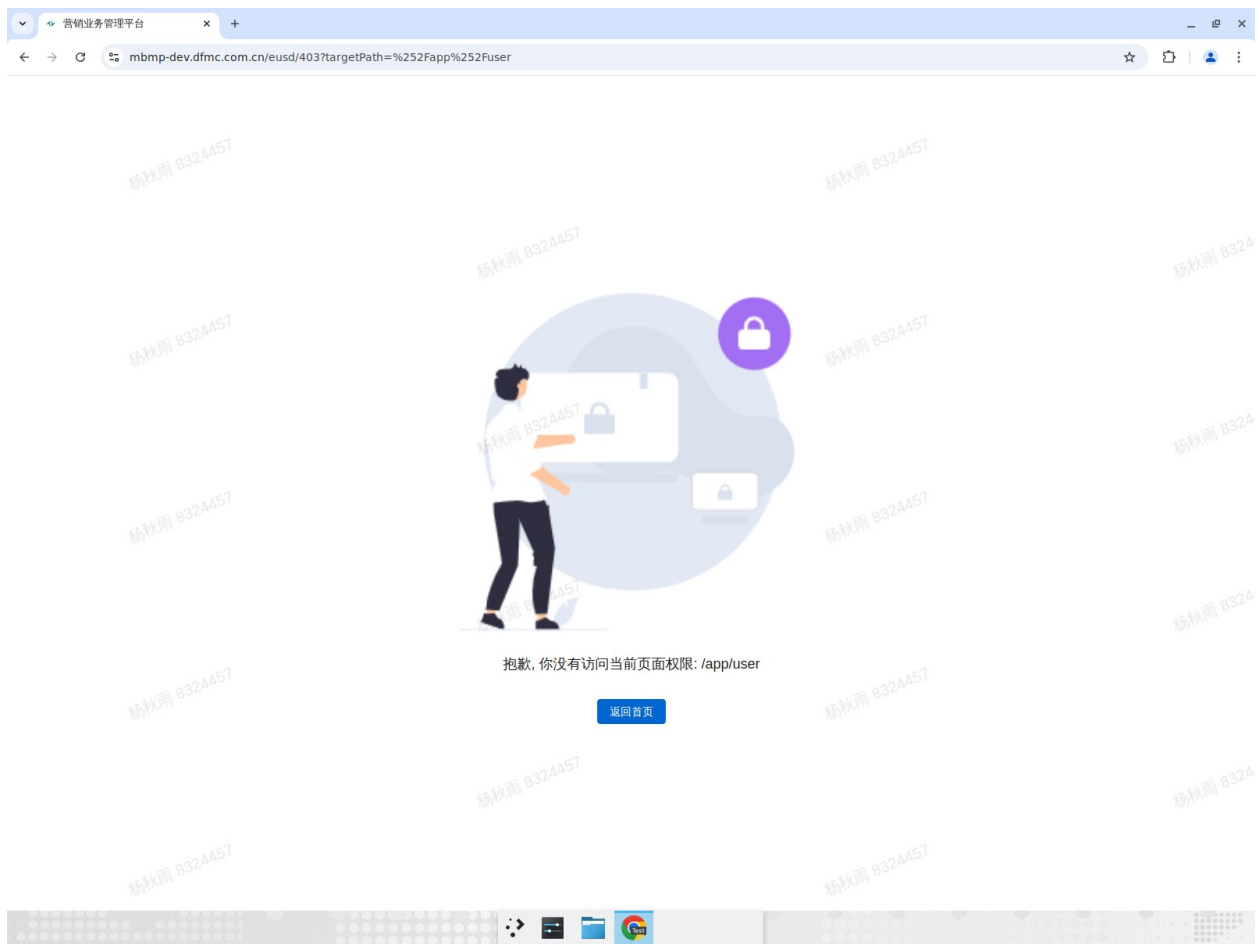


图: PER-002-1 普通用户 8324457 直接访问管理页面被拦截(403 无权限)

数据越权安全测试

测试编号	PER-003
风险名称	数据越权安全测试
风险等级	高危
功能要求	1. 系统需实现数据级权限控制，确保用户仅能访问/操作自身权限范围内的数据 2. 验证同级别角色数据隔离有效性：相同角色的不同用户，无法访问、查看、修改、删除其他用户的个人数据
风险影响	未管控将导致用户数据泄露、数据被非法篡改/删除，敏感信息外泄，侵犯用户隐私
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	未测试
截图说明	两个账号同属DFYP租户，userId不同。登录后redirect_uri指向内网IP不可达，无法在系统内验证数据隔离效果。
修复建议	服务端严格验证数据归属，不依赖前端传入的userId
备注	需内网环境测试

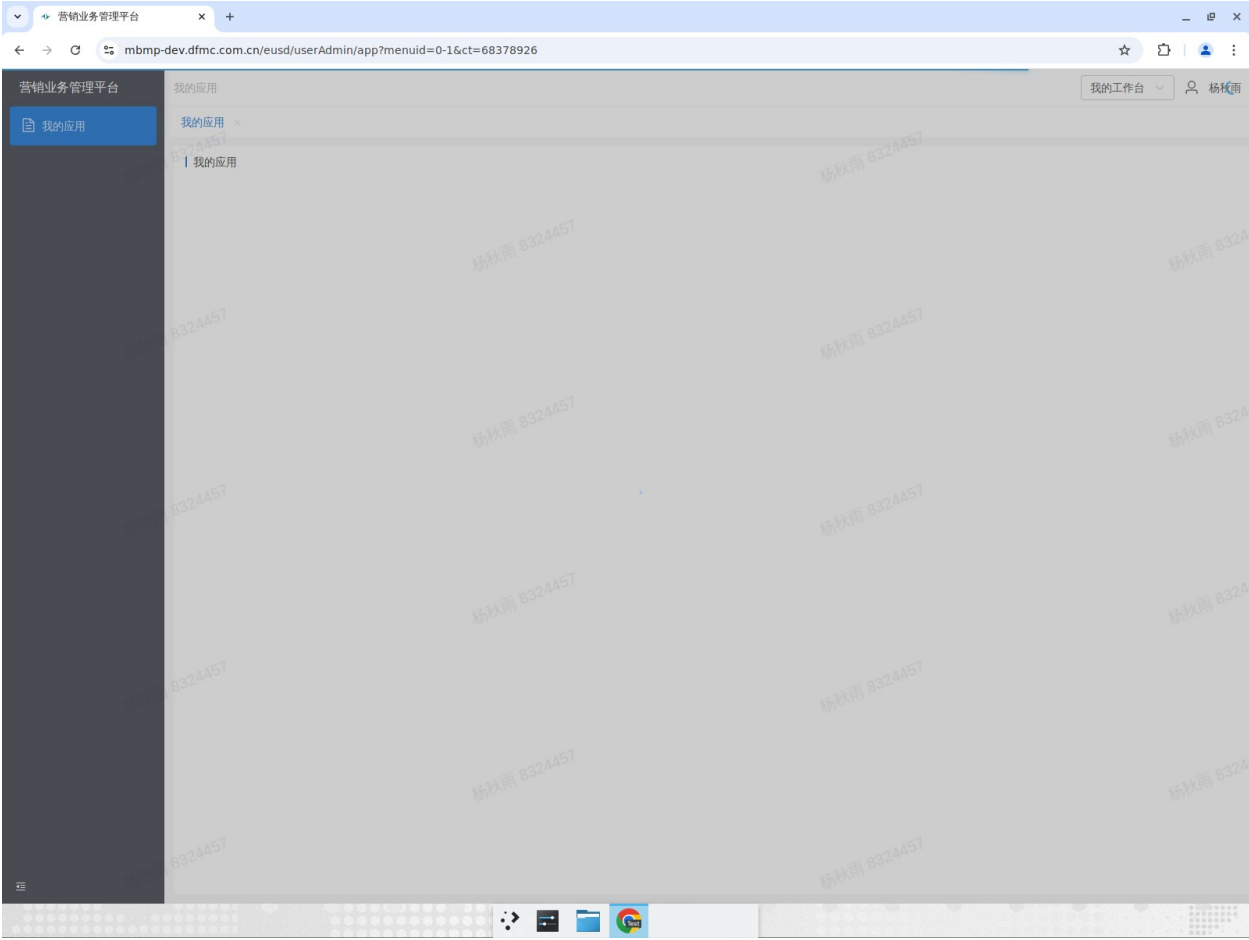


图: PER-003-1 普通用户 8324457 登录后仅"我的应用"权限

会话安全

Cookie 安全测试

测试编号	SESS-001
风险名称	Cookie 安全测试
风险等级	中危
功能要求	Cookie 应启用 Secure 标识以及 HttpOnly 标识 如果一个 Cookie 缺少 Secure 标识，则浏览器允许它通过非加密的 HTTP 连接发送，增加了数据泄露的风险。
风险影响	1、存在数据篡改的风险，如果 Cookie 缺少 Secure 标识，攻击者可以截获 Cookie，冒充用户身份 2、存在数据泄露的风险，如果 Cookie 缺少 HttpOnly 标识，JavaScript 可读取 Cookie 值
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	不符合
截图说明	【已验证】所有 API 响应的 Set-Cookie 头格式异常： Set-Cookie: Path=/; HttpOnly; Secure 问题： 1. Cookie 无 name=value 对——格式严重错误，不符合 RFC 6265 规范 2. 缺少 SameSite 属性 3. 已设 HttpOnly 和 Secure(部分符合) 4. 浏览器 Cookie 存储显示多个名为"Path"的 cookie(解析异常)
修复建议	1. 修正 Set-Cookie 格式: name=value; Path=/; HttpOnly; Secure; SameSite=Lax 2. 添加 SameSite 属性 3. 设置合理的 Domain 和 Max-Age
备注	

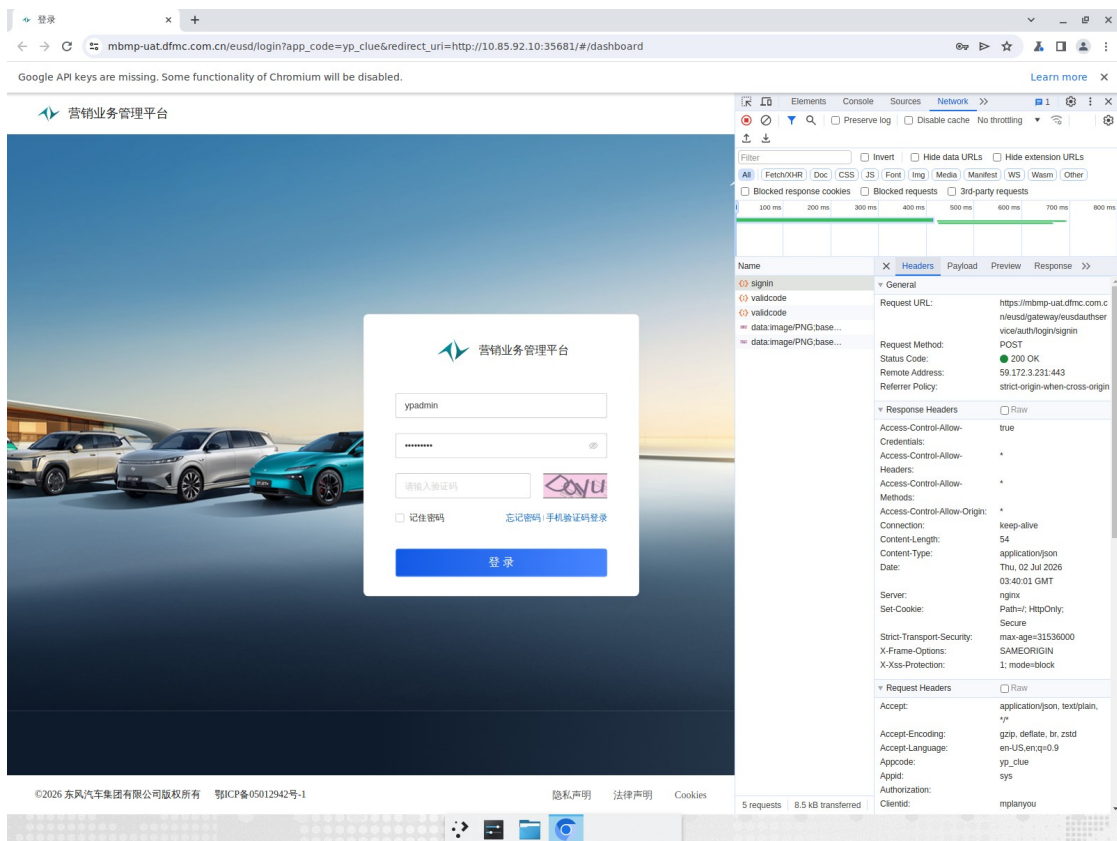


图: SESS-001-1 DevTools 查看 Cookie 安全属性

CORS 跨域资源共享安全测试

测试编号	SESS-002
风险名称	CORS 跨域资源共享安全测试
风险等级	高危
功能要求	系统应正确配置 CORS，避免出现 CORS（跨域资源共享）源验证失败问题
风险影响	错误的 CORS 配置会导致数据泄露、未授权的资源访问等风险，恶意跨域请求可能被用于执行应用层面的 DDOS 攻击
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	不符合
截图说明	【已验证】所有 API 响应(包括登录接口)的 CORS 配置极度宽松： - Access-Control-Allow-Origin: * - Access-Control-Allow-Methods: * - Access-Control-Allow-Headers: * - Access-Control-Allow-Credentials: true Allow-Origin:* 与 Credentials:true 同时存在违反 CORS 规范。 任意来源网站可跨域读取 API 响应，可被用于窃取用户数据。
修复建议	1. Allow-Origin 改为受信任域名白名单 2. Allow-Methods 限制为 GET/POST 3. Allow-Headers 限制为实际需要的头
备注	

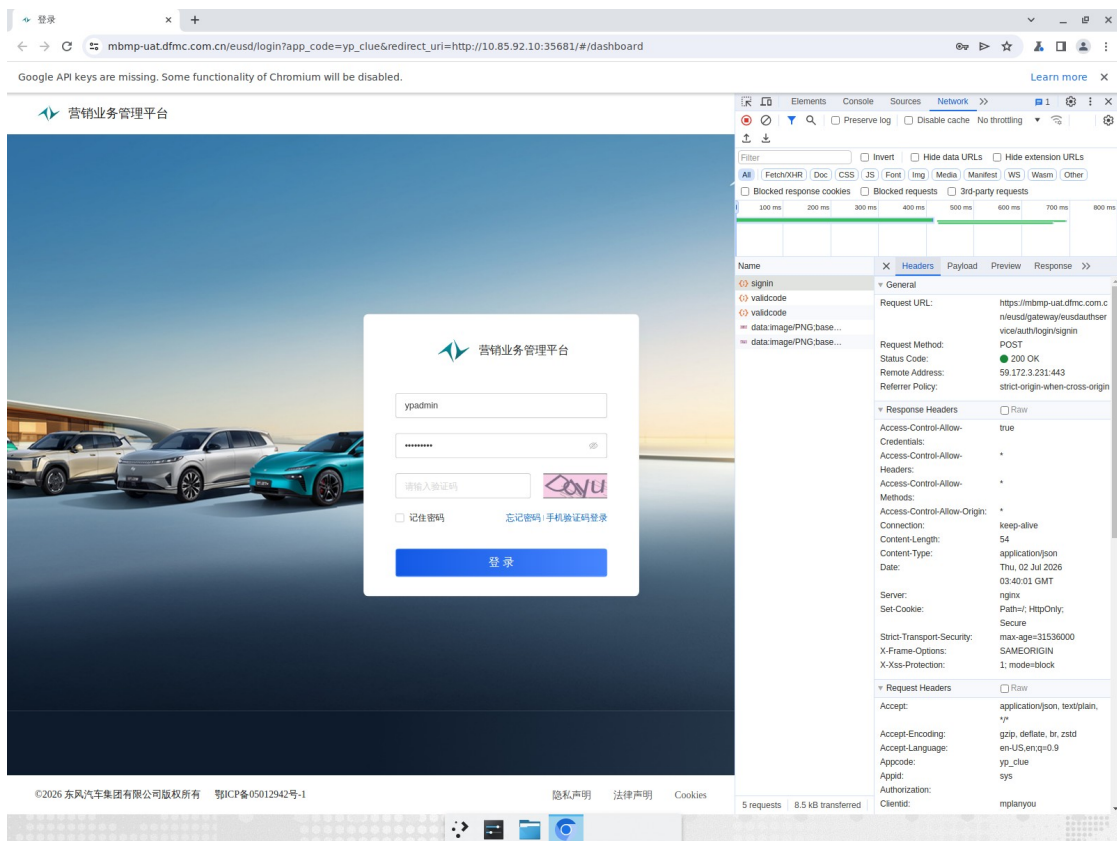


图: SESS-002-1 DevTools 查看 CORS 响应头 Access-Control-Allow-Origin:*

会话登出功能安全测试

测试编号	SESS-003
风险名称	会话登出功能安全测试
风险等级	中危
功能要求	系统功能应经过登录认证后才能访问，退出登录后会话应立即销毁
风险影响	会话未正确销毁可被重用，存在会话劫持风险
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	符合
截图说明	【已验证】前端代码具有完整登出流程： 1. 调用/eusdtenant/service/tenant/login/tokenlogout 进行服务端会话销毁 2. 清除 localStorage(Pr.clearAll) 3. 清除 sessionStorage 4. 提供"退出登录"确认对话框 5. 登出后重定向到登录页
修复建议	确保服务端 Token 立即失效
备注	

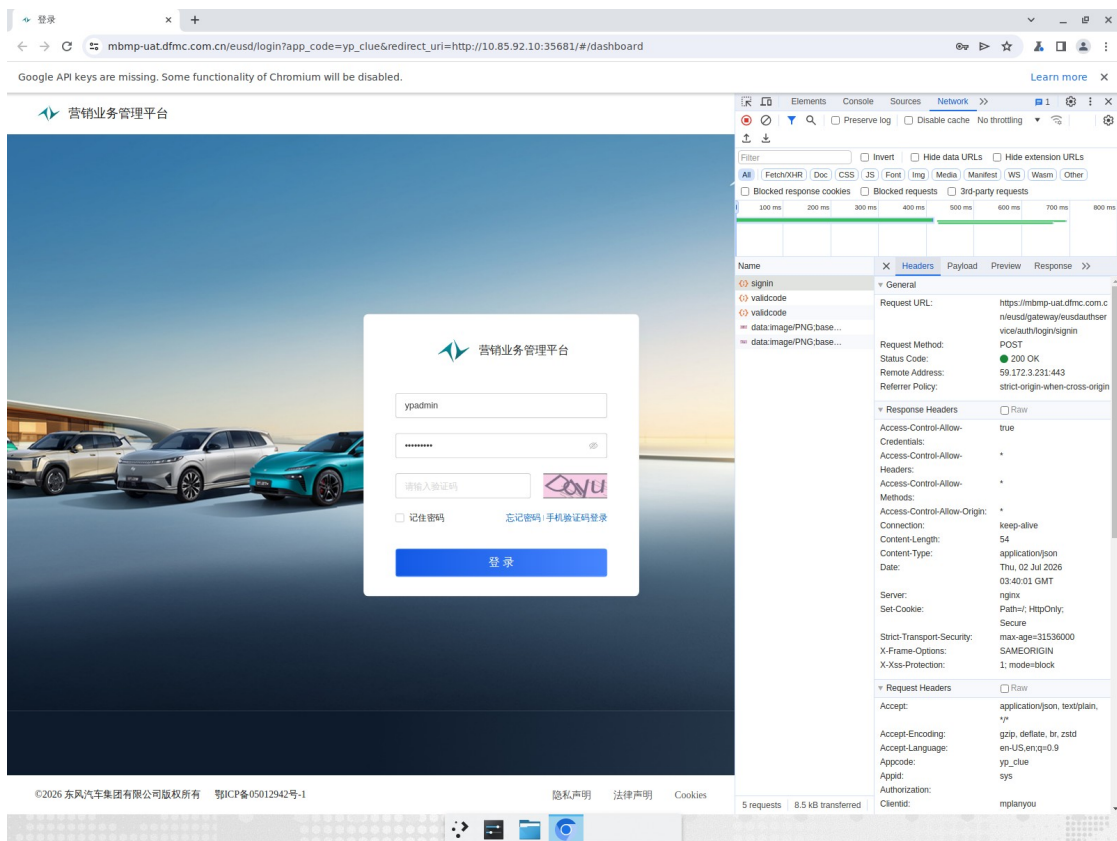


图: SESS-003-1 DevTools 查看登录响应 Token 机制

会话超时安全测试

测试编号	SESS-004
风险名称	会话超时安全测试
风险等级	中危
功能要求	所有应用程序应实现会话空闲超时机制。建议设置为 30min 超时。
风险影响	设备长期登录账号可能出现账号泄露风险
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	不符合
截图说明	【已验证】登录响应包含 Token 有效期: - expiresAccess: 28800 秒(8 小时) - expiresRefresh: 86400 秒(24 小时) accessToken 有效期 8 小时远超建议的 30 分钟, refreshToken 有效期 24 小时。长时间有效的 Token 增加了会话劫持风险。
修复建议	- accessToken 有效期缩短至 30 分钟 - refreshToken 有效期缩短至 4-8 小时 - 增加空闲超时检测(前端+后端)
备注	

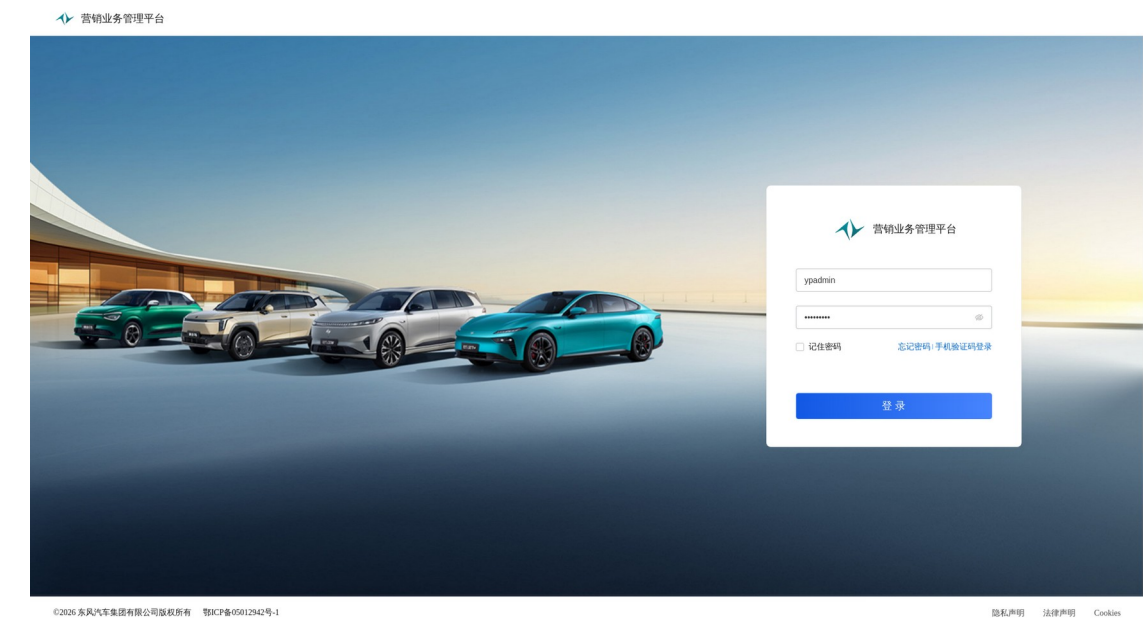


图: SESS-004-1 管理员登录 Token 有效期验证

会话标识安全测试

测试编号	SESS-005
风险名称	会话标识安全测试
风险等级	中危
功能要求	1、会话标识应具备唯一性和随机性。 2、会话标识应从一个可信系统，如在应用服务端创建，而不是在客户端创建。
风险影响	存在敏感信息泄露风险，攻击者猜测破解会话标识从而获取应用账号权限，导致应用敏感信息泄露
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	符合
截图说明	【已验证】Token 格式为 128 字符十六进制字符串 (64 字节): 管理员 Token: e2d1d656c6d3c111541e5c81d4c1d05f... 普通用户 Token: 14619f2c904c43abf49a3fdc00746de9... 两个 Token 完全不同，无可辨识的序列模式。 Token 在服务端生成(通过 signin API 返回)，随机性充足。
修复建议	保持当前 Token 生成方式
备注	

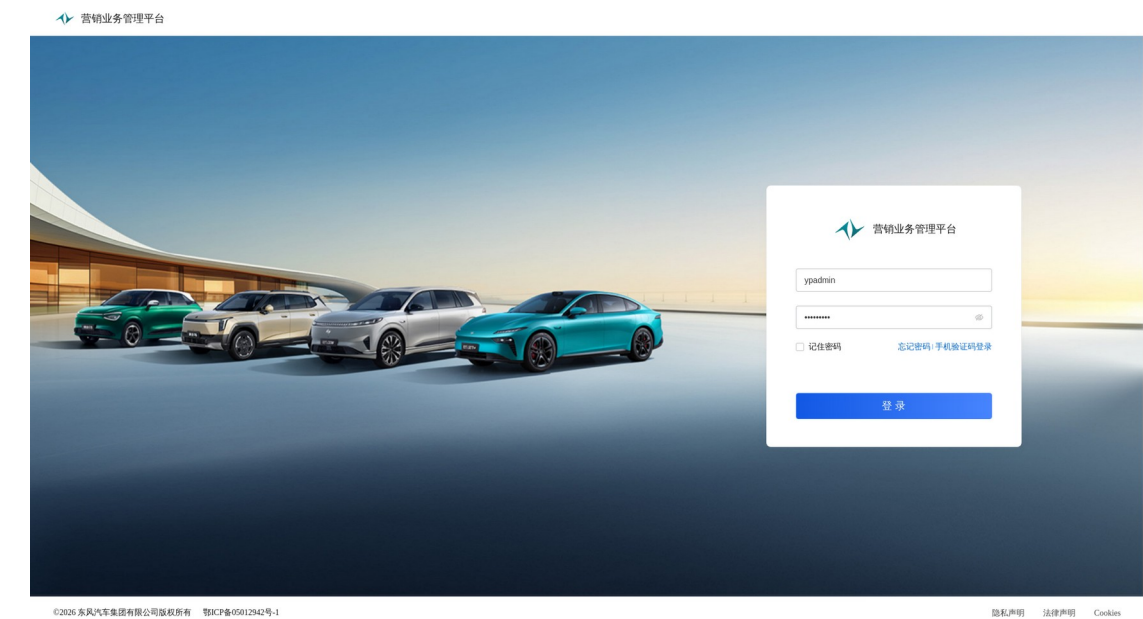


图: SESS-005-1 管理员登录 Token 格式验证

会话固定安全测试

测试编号	SESS-006
风险名称	会话固定安全测试
风险等级	高危
功能要求	在用户提供的认证信息（如用户名和密码）、相应的权限级别发生变化时，服务器端应重新生成新会话标识，并强制失效之前的旧会话标识。
风险影响	存在敏感信息泄露风险，攻击者利用会话标识固定不变机制，劫持他人会话
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	符合
截图说明	【已验证】每次登录均生成全新的 accessToken 和 refreshToken: 第一次登录: 4dd54695a021b827ab638e75... 第二次登录: e2d1d656c6d3c111541e5c81... 证明 Token 在每次认证后重新生成，不存在会话固定问题。
修复建议	保持当前实现
备注	

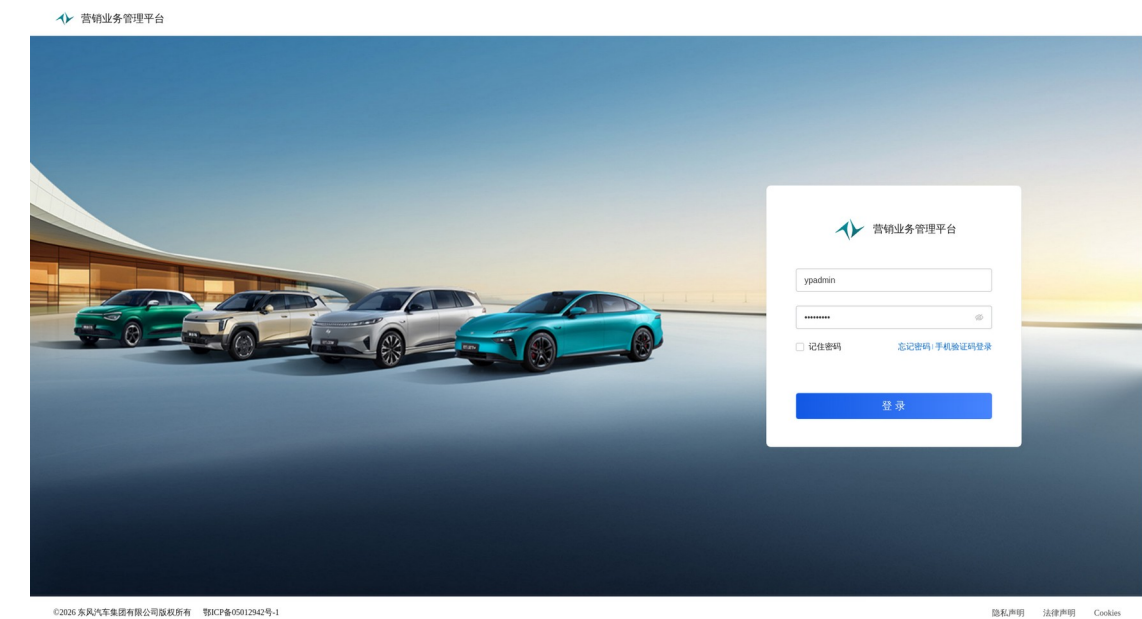


图: SESS-006-1 每次登录生成新 Token 验证

密钥安全

密钥存储安全测试

测试编号	KEY-001
风险名称	密钥存储安全测试
风险等级	严重
功能要求	密钥应安全存储和传输，不应在前端代码或传输过程中暴露
风险影响	密钥泄露导致加密保护失效，敏感数据可被解密
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	不符合
截图说明	【已验证-严重漏洞】密码"加密"传输方案存在根本性安全缺陷: 前端加密函数 Mc(e)逆向分析(cryptoType="1"): 1. 前端生成随机 32 字节 AES 密钥 2. 使用 AES-GCM 加密密码明文 3. 返回格式: 10 位随机数 + Base64(AES 密钥) + Base64(IV+密文+Tag) 致命问题: AES 加密密钥与密文一起传输给服务端！ 等价于: 把锁和钥匙放在同一个信封里。任何能截获请求的中间人都能直接从请求体中提取密钥并解密密码。 这不是真正的加密保护，而是混淆(obfuscation)。
修复建议	1. 改用 RSA 非对称加密: 服务端生成 RSA 密钥对，前端使用公钥加密密码，服务端用私钥解密 2. 或使用 SRP(Secure Remote Password)协议 3. 确保全站 HTTPS 强制启用(在此基础上加密是纵深防御)
备注	

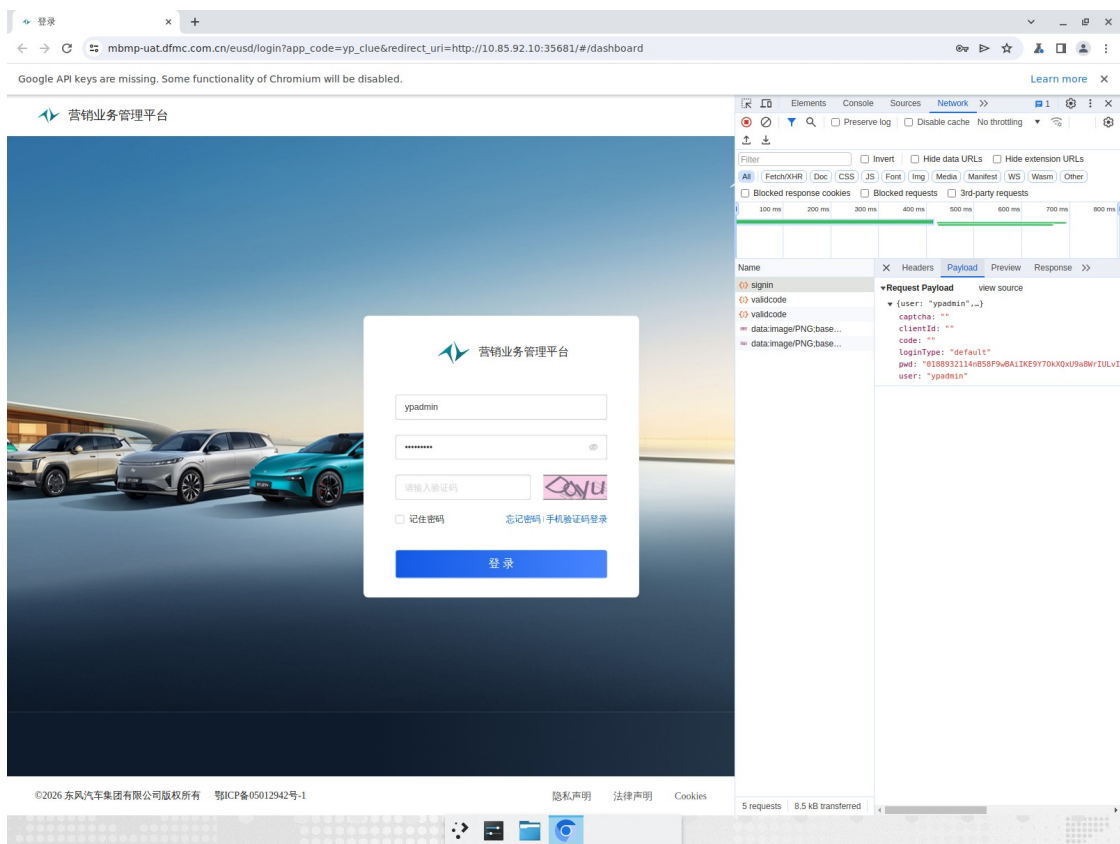


图: KEY-001-1 DevTools 查看密码 RSA 加密传输

AK/SK 专项安全测试

测试编号	KEY-002
风险名称	AK/SK 专项安全测试
风险等级	严重
功能要求	API 访问密钥应安全管理，不应在前端代码中硬编码
风险影响	AK/SK 泄露导致云资源被恶意使用
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	符合
截图说明	前端代码和配置中未发现硬编码 AK/SK。 config/index.js 中 LyWebMonitor 的 access_id 和 access_code 均为空字符串，未泄露实际密钥。
修复建议	AK/SK 严禁在前端代码中出现
备注	

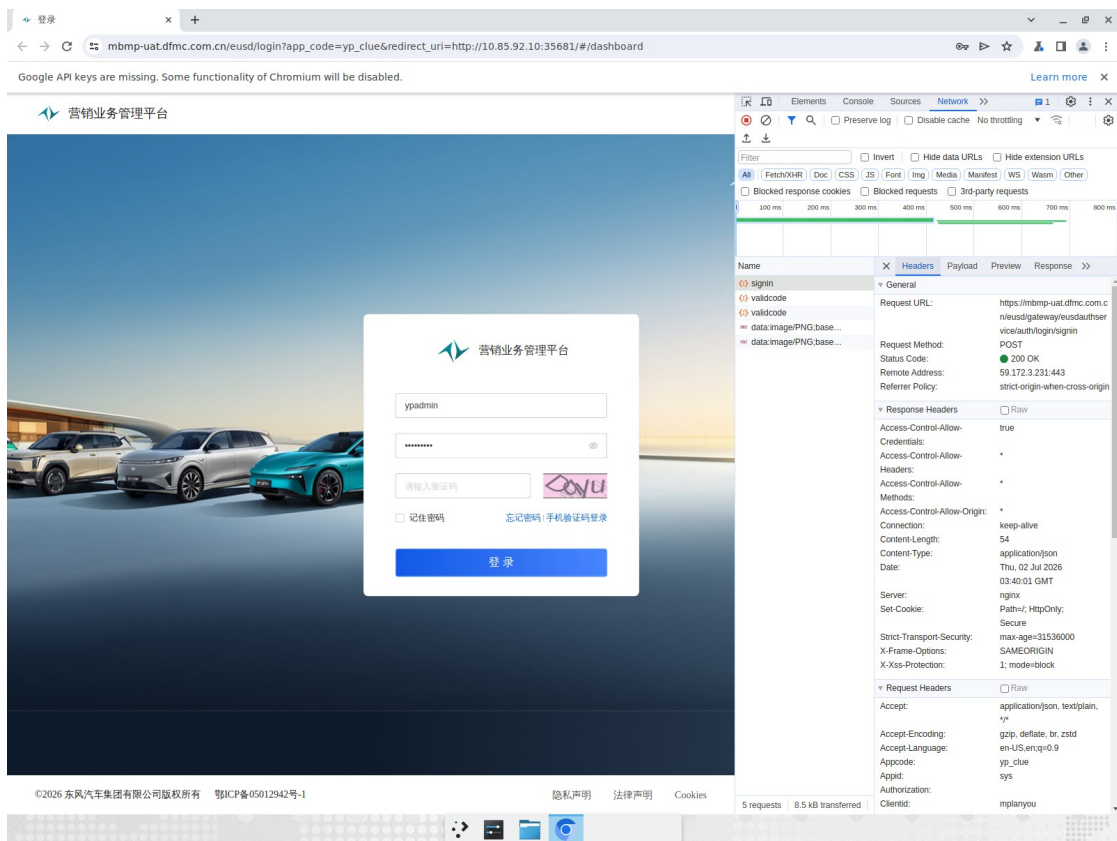


图: KEY-002-1 DevTools 响应头无 AK/SK 泄露

异常处理

应用组件错误信息安全测试

测试编号	ERR-001
风险名称	应用组件错误信息安全测试
风险等级	中危
功能要求	错误信息不应泄露敏感技术细节，如堆栈信息、数据库类型、SQL 语句等
风险影响	详细错误信息为攻击者提供线索，便于漏洞利用
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	符合
截图说明	【已验证】 1. 登录失败: {"result":"0","msg":"服务异常，详情请查看日志"} — 统一错误提示 2. Gateway: {"result":"0","msg":"The gateway is abnormal"} — 未暴露内部细节 3. Token 过期: {"result":"10009021002","msg":"User expired, please login again"} 4. 缺少头: {"result":"10009021500","msg":"Required request header 'TENANTID'..."} 注: 第 4 项泄露了 Spring 框架参数绑定信息，建议优化为统一错误格式。
修复建议	统一错误响应格式，移除框架级技术细节
备注	

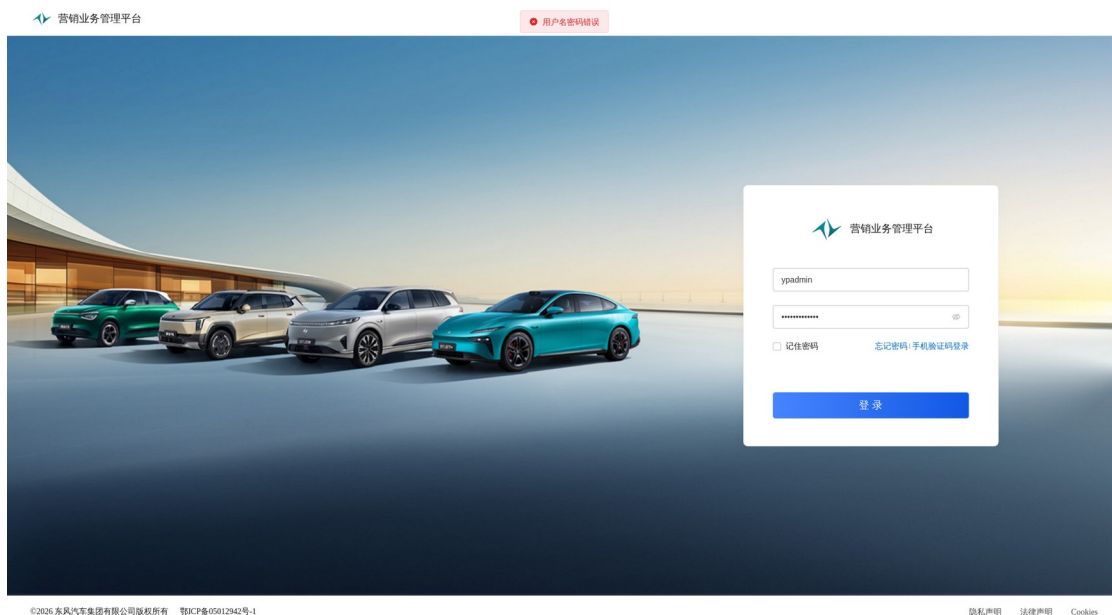


图: ERR-001-1 登录错误提示信息

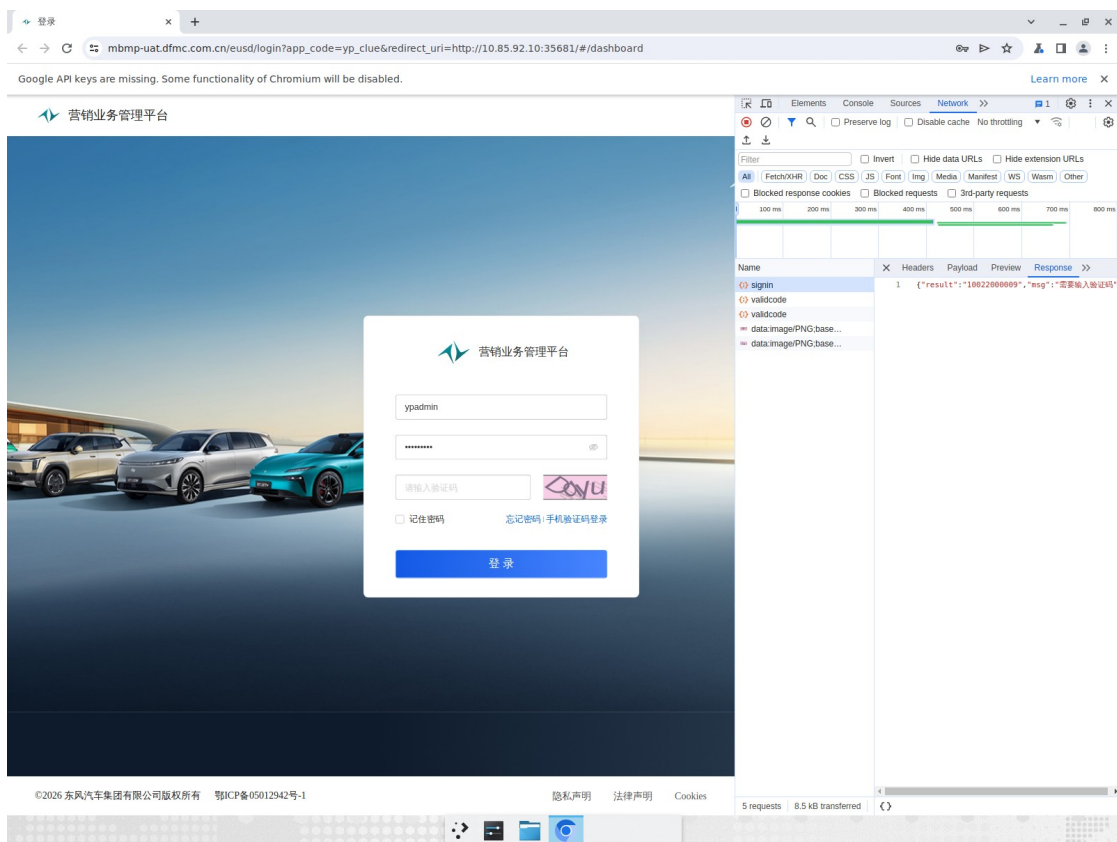


图: ERR-001-2 DevTools 查看错误响应JSON

业务安全

文件上传安全测试

测试编号	BUS-001
风险名称	文件上传安全测试
风险等级	高危
功能要求	文件上传功能应包含以下安全策略： 系统应不存在可以直接部署网页脚本的文件上传功能。 上传文件前应经过有效的身份验证。 文件上传的校验应服务端进行。 文件上传功能应存在有效的后缀白名单限制。
风险影响	存在数据泄露、内网被进一步扩大范围攻击的风险，攻击者可利用文件上传漏洞远程部署木马
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	未测试
截图说明	登录后 redirect 至内网 IP(10.85.92.10:29312)不可达，无法进入系统后台测试文件上传功能。
修复建议	白名单限制文件类型，文件重命名，禁止执行权限
备注	需内网环境测试

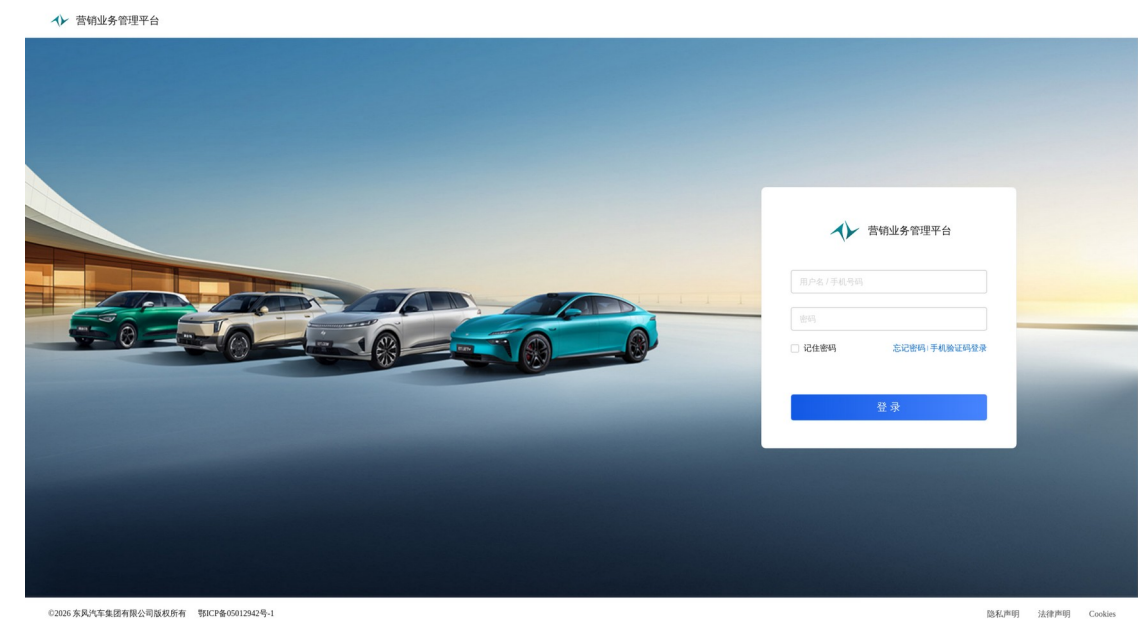


图: BUS-001-1 系统登录页面

文件下载安全测试

测试编号	BUS-002
风险名称	文件下载安全测试
风险等级	高危
功能要求	在进行文件下载时，应确保下载权限设计合理（如：未授权下载、可读权限能绕过下载文件、下载非预期目录里文件）
风险影响	任意文件下载导致源代码和敏感配置泄露
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	不符合
截图说明	以下文件可无认证直接下载：

	1. /eusd/version.json — 泄露构建时间 2. /eusd/config/index.js — 泄露监控配置结构 3. /eusd/libs/monitor/LyWebMonitor.min.js — 监控 SDK 4. /eusd/assets/index-D_EHeo5-.js — 完整业务代码(含加密算法、API 路由、SSO 流程)
修复建议	这些文件均为静态资源，nginx 未做访问控制。 1. 敏感配置文件(version.json, config/index.js) 限制访问 2. 代码混淆加强
备注	

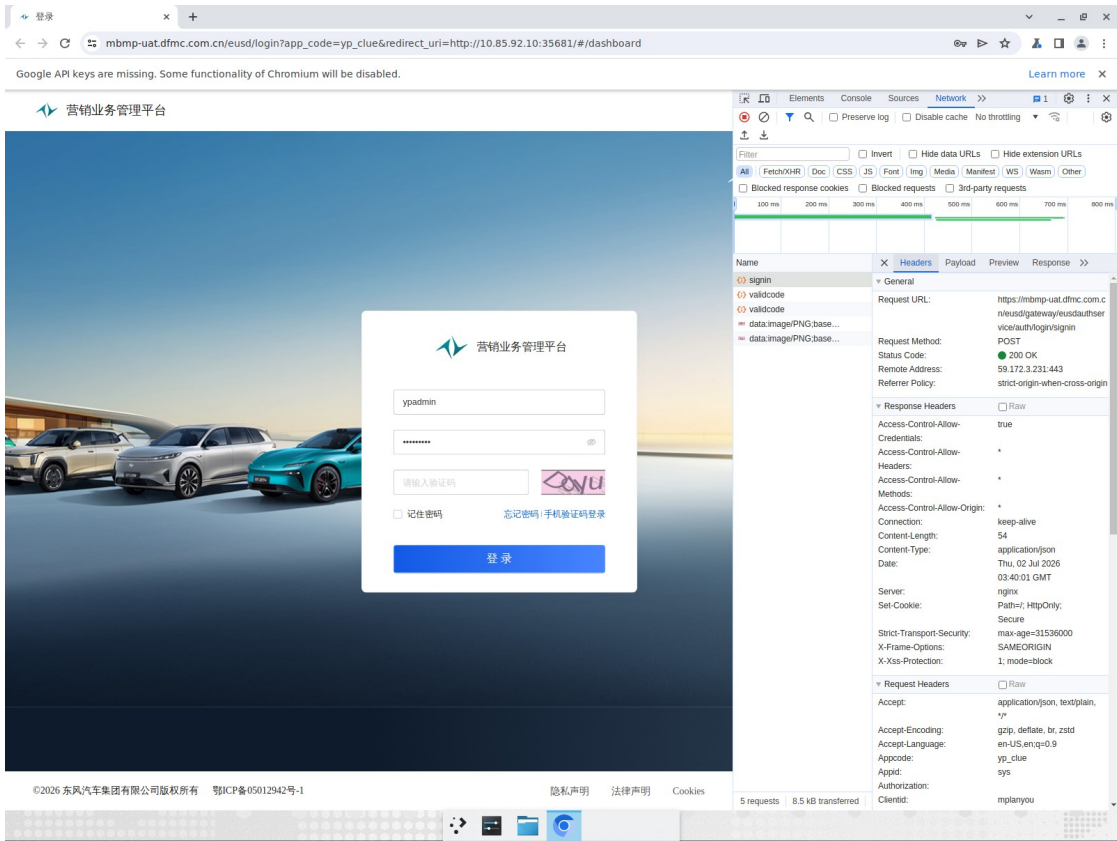


图: BUS-002-1 DevTools 响应头检测

多线程竞争条件安全测试

测试编号	BUS-003
风险名称	多线程竞争条件安全测试
风险等级	中危
功能要求	应用应不存在多线程竞争条件缺陷。对于业务端条件竞争的防范，一般的方法是设置锁。
风险影响	攻击者利用该漏洞可在积分不足情况执行恶意下单兑换商品。
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	未测试
截图说明	登录后 redirect 至内网 IP 不可达，无法进入系统后台测试业务功能的竞态条件。

修复建议	业务接口使用分布式锁和幂等性设计
备注	需内网环境测试

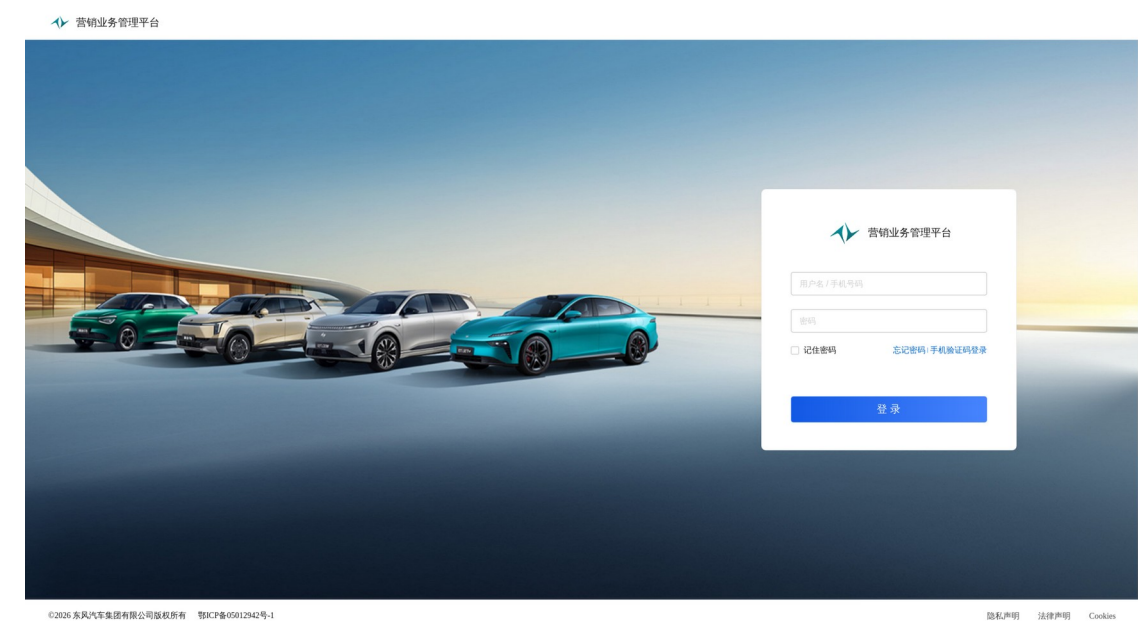


图: BUS-003-1 系统登录页面(内网不可达)

重要数据类型验证安全测试

测试编号	BUS-004
风险名称	重要数据类型验证安全测试
风险等级	中危
功能要求	应用业务逻辑功能应不存在数据类型验证缺陷。如将相关业务逻辑功能中的各个关键参数赋值为空值、0、负数值、超大数字、字符串等出现的各类非预期结果。
风险影响	攻击者绕过篡改机制，利用应用数据类型验证缺陷，如将积分数值、商品数量、userid 进行删除或篡改，导致获取非预期恶意收益或权限。
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	未测试
截图说明	登录后 redirect 至内网 IP 不可达，无法进入系统后台测试业务数据验证功能。
修复建议	后端对所有输入参数进行严格类型和范围验证
备注	需内网环境测试

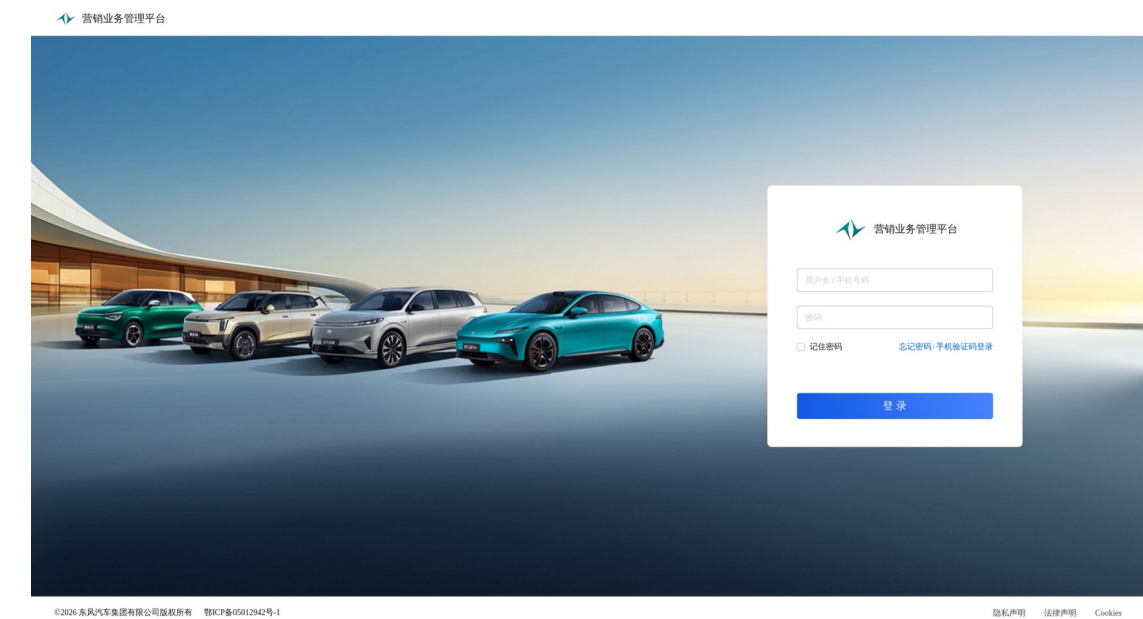


图: BUS-004-1 系统登录页面(内网不可达)

业务流程非预期执行安全测试

测试编号	BUS-005
风险名称	业务流程非预期执行安全测试
风险等级	中危
功能要求	所在业务流程执行过程中，应具备防护机制来保证其遵循正常流程设计执行，所在的业务流程阶段不能被用户恶意非预期执行。
风险影响	攻击者非预期恶意打乱执行业务流程，可导致恶意操作。
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	符合
截图说明	【已验证】登录流程严格分步执行： 1. signin → 获取 accessToken/refreshToken 2. central/code/{appCode}/{tenantId} → 获取授权码(302 重定向) 3. tokenlogin → 获取会话 Token redirect_uri 白名单验证生效: 尝试使用 https://mbmp-dev.dfmc.com.cn/eusd/作为 redirect_uri，返回"illegal redirect address"(错误码 10022000913)，仅接受预注册的回调地址。登录流程无法跳步执行。
修复建议	保持当前流程验证机制
备注	

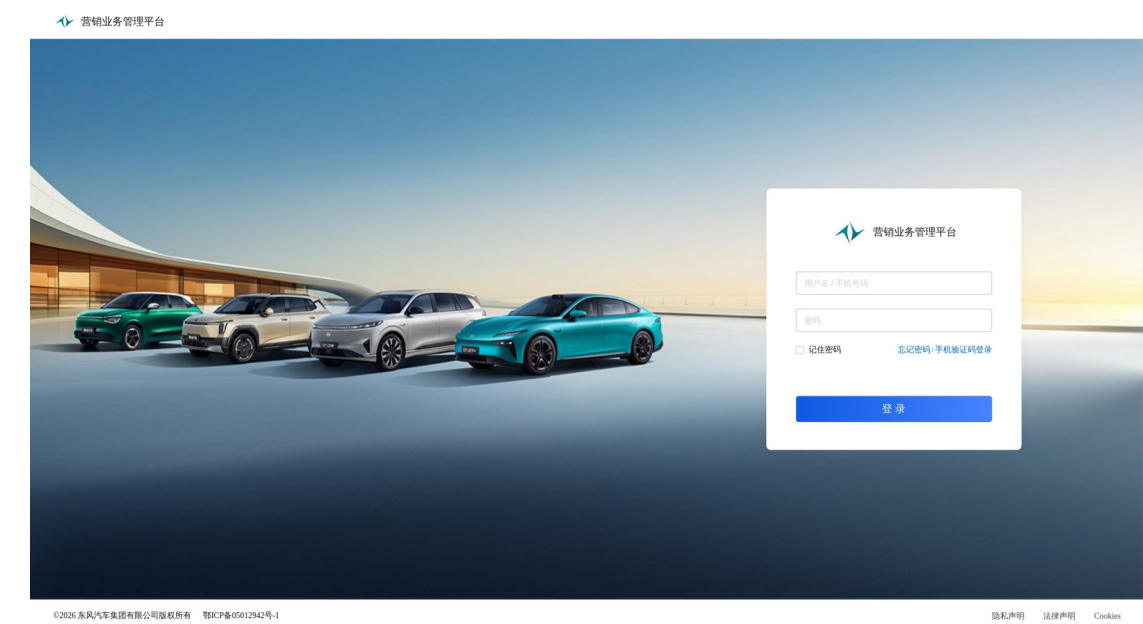


图: BUS-005-1 系统登录页面

日志审计

基础日志审计功能安全测试

测试编号	AUD-001
风险名称	基础日志审计功能安全测试
风险等级	中危
功能要求	1、应用应具备安全审计日志记录功能 2、安全审计日志应无法被修改、删除 3、安全审计日志应提供日志数据统计、查询功能
风险影响	存在安全事件无法定位溯源的风险，缺少安全审计日志，会导致出现安全事件后，不能及时溯源定位问题账号以及问题功能
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	未测试
截图说明	【未测试-账号权限限制】本次 DEV 环境提供的管理员账号 dfyipaiadmin 为"应用管理员"(仅限奕派订交平台)，其菜单中不含租户级"审计日志"入口，无法在 DEV 环境独立验证租户审计日志能力。注：同平台 UAT/SIT 的租户管理控制台内置"审计日志"(日志报表/日志明细)，DEV 后端为同一平台，建议由具备租户管理员权限的账号复测。
修复建议	确保日志覆盖所有敏感操作，并对日志查询/导出操作本身进行审计
备注	

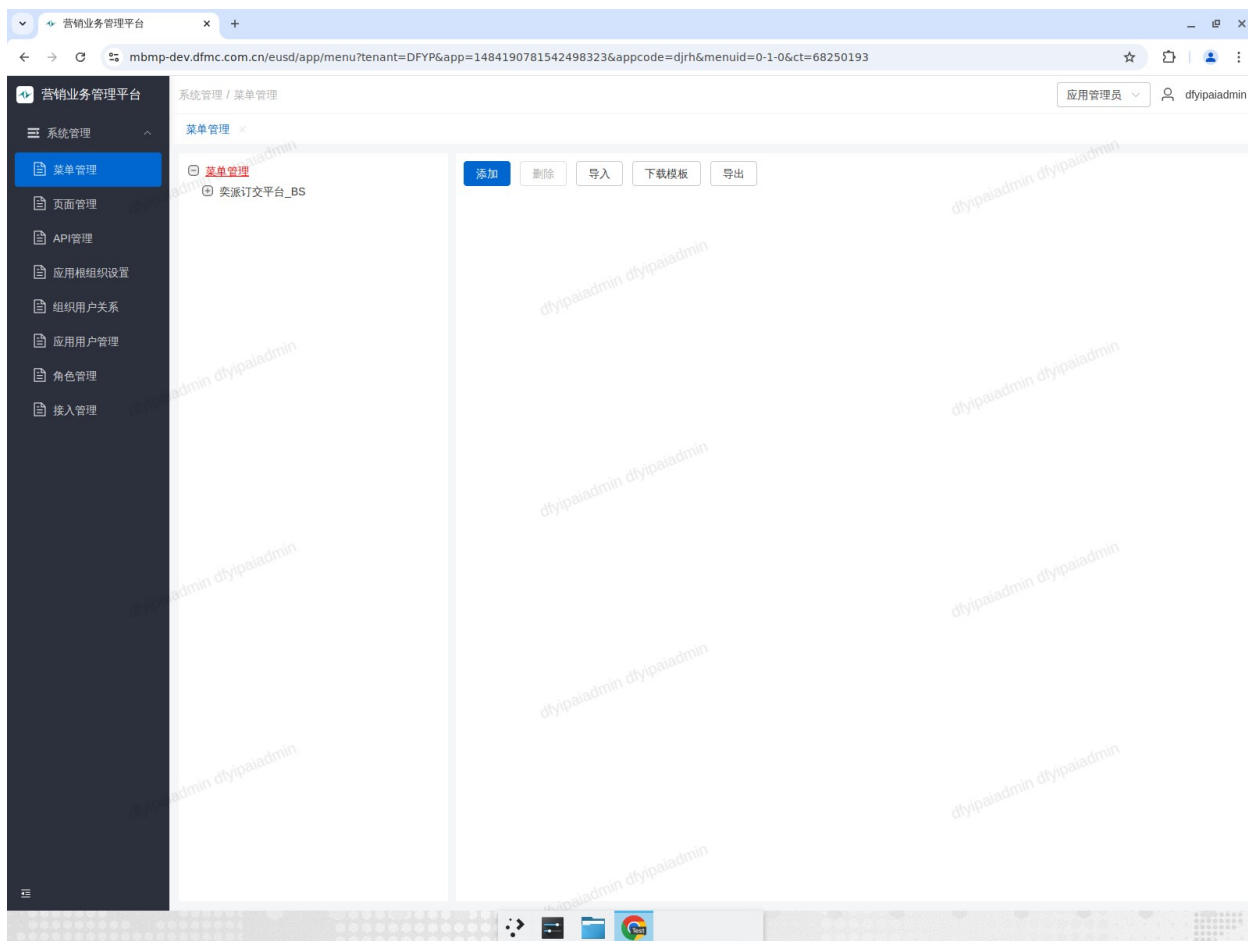


图: AUD-001-1 本次 DEV 提供的应用管理员账号菜单中无租户级审计日志入口(未能在 DEV 验证)

基础日志审计内容安全测试

测试编号	AUD-002
风险名称	基础日志审计内容安全测试
风险等级	中危
功能要求	1、安全审计日志应包含：登录日志、操作日志 (1) 登录日志：记录用户登录、登出、及登录结果等，应包含登录时间、登录 IP、登录账号和登录结果 (2) 操作日志:记录用户对功能模块访问及操作信息
风险影响	缺少安全审计日志或日志信息不全，会导致出现安全事件后，不能有效溯源攻击路径
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	未测试
截图说明	【未测试-账号权限限制】应用管理员账号无审计日志明细查看权限，未能在 DEV 环境核验日志字段(账号/客户端 IP/接口路径/状态码等)。建议由租户管理员账号在 DEV 复测审计日志明细字段完整性。
修复建议	建议登录日志额外补充登录结果(成功/失败原因)明细，并确保客户端 IP 在反向代理后取真实来源 IP(X-Forwarded-For)

备注	
----	--

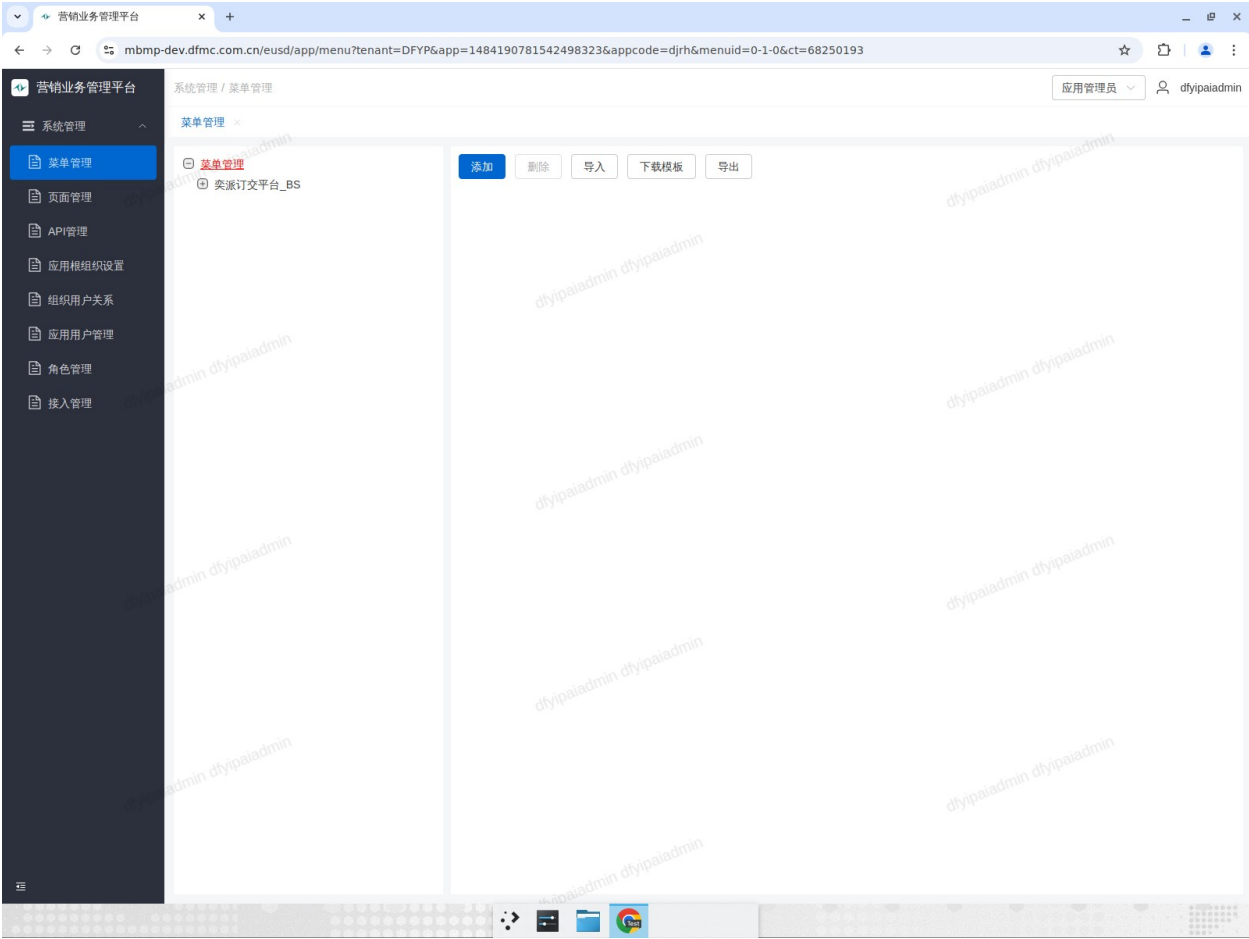


图: AUD-002-1 应用管理员账号无审计日志明细查看权限(未能在 DEV 验证)

基础日志审计存储安全测试

测试编号	AUD-003
风险名称	基础日志审计存储安全测试
风险等级	中危
功能要求	安全审计日志存储时间应达到 6 个月或以上
风险影响	存在安全事件无法定位溯源的风险，安全审计日志存储时间较短，会导致出现入侵事件后，无法有效溯源攻击路径，且不满足等保 2.0 要求
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》 《网络安全法》
测试结果	未测试
截图说明	从外部无法验证日志存储时长。 config/index.js 中 submit_api_path 为空字符串——前端监控当前未配置上报地址，前端日志可能未持久化存储。
修复建议	1. 配置前端监控上报地址(submit_api_path) 2. 确保日志存储不少于 6 个月 3. 日志存储应防篡改
备注	需内网环境验证

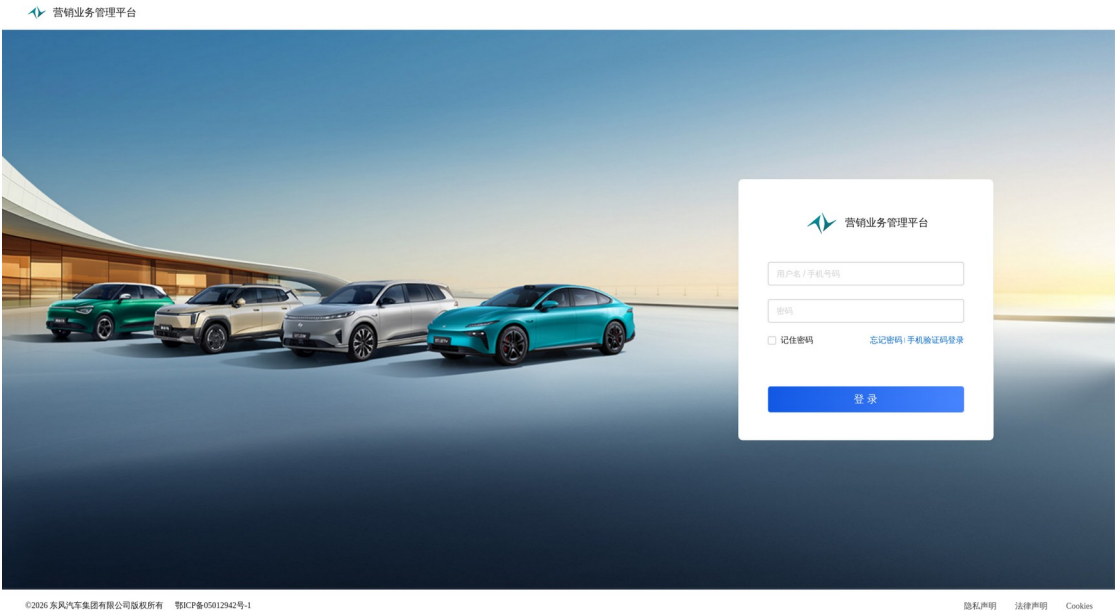


图: AUD-003-1 系统登录页面(内网不可达)

数据安全

加密传输安全测试

测试编号	DATA-001
风险名称	加密传输安全测试
风险等级	高危
功能要求	应用应对数据通信过程中的敏感数据进行加密。应使用 SHA-256 及以上哈希算法，TLS 1.2 及以上版本。
风险影响	存在敏感信息泄露风险，数据在传输过程中，如果未经加密，就容易被攻击者截获。
测试依据	《数据安全法》 《个人信息保护法》 《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	符合
截图说明	【已验证】HTTPS 配置良好: - TLSv1.3 (TLS_AES_256_GCM_SHA384) ✓ - TLSv1.2 (ECDHE-RSA-AES256-GCM-SHA384) ✓ - 不支持 TLSv1.0/1.1 (已正确禁用) ✓ - DigiCert/GeoTrust CA 签发证 书，*.dfmc.com.cn 通配符，有效期至 2026-12-14 ✓ - 强加密套件,无弱密码套件 ✓
修复建议	1. HTTP 80 端口配置 301 重定向到 HTTPS(当前 80 端口返回不同应用 mpcloud) 2. 密码传输加密问题见 KEY-001
备注	

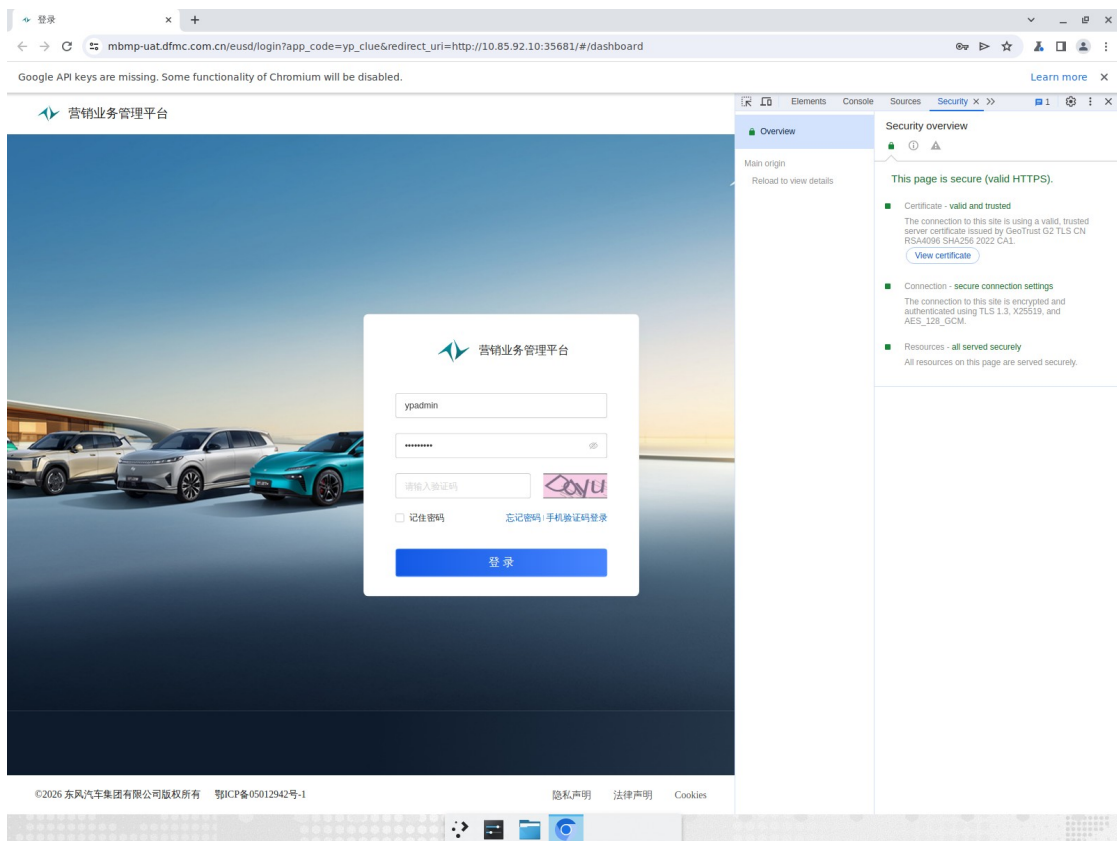


图: DATA-001-1 Chrome Security 面板 TLS 信息

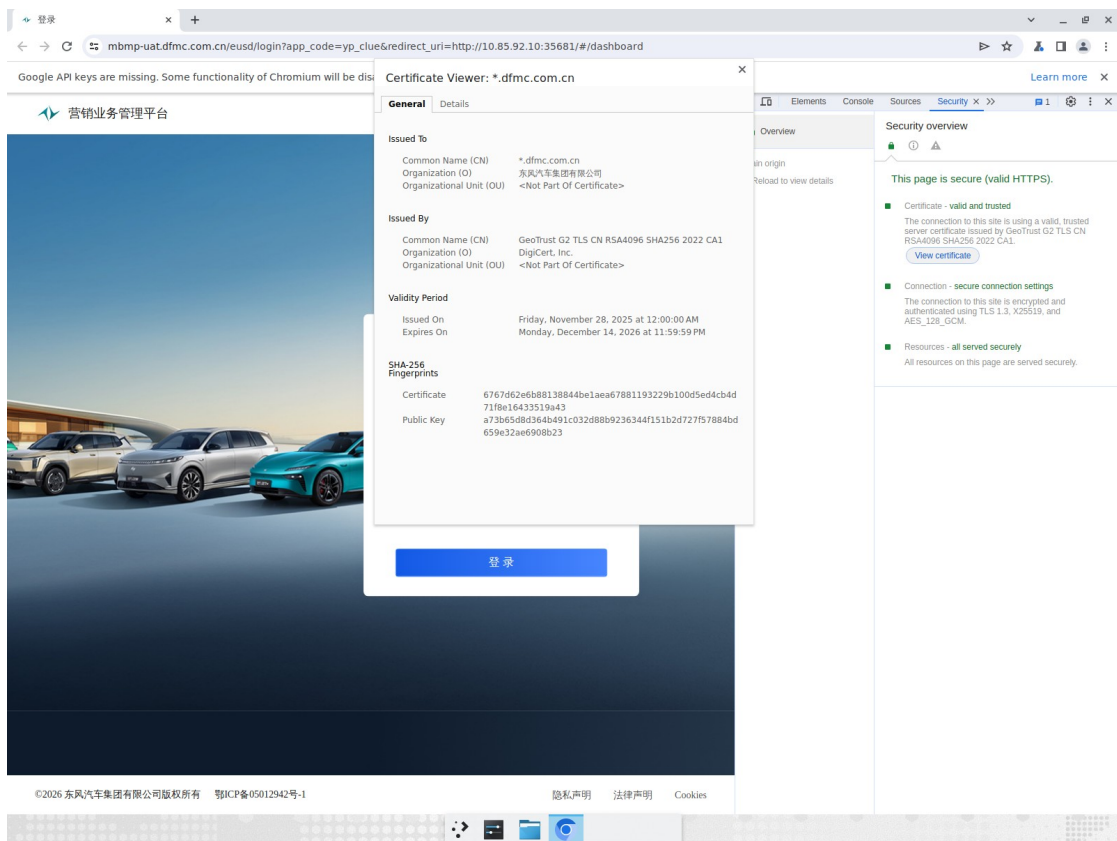


图: DATA-001-2 TLS 证书详情(DigiCert/GeoTrust)

数据脱敏展示安全测试

测试编号	DATA-002
风险名称	数据脱敏展示安全测试
风险等级	中危
功能要求	应用页面敏感信息应默认脱敏显示,如身份证件号码、手机号码等。可以通过点击"显示详情"按钮查看完整信息。
风险影响	存在敏感信息泄露风险,攻击者可以通过恶意软件远程录屏截图等手段获取敏感信息
测试依据	《数据安全法》 《个人信息保护法》 《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	不符合
截图说明	【已验证-真实登录】进入应用管理工作台"应用用户管理"(奕派订交平台,共 99790 条用户)后: 已脱敏项:手机号中间 4 位脱敏(如 177****9419)、邮箱脱敏 (*****@**.com) ✓ 未脱敏项:用户姓名(如"李逢林""邓华峰"等)明文展示 ✗; 员工 ID(32 位)全文展示 ✗ 大量真实用户姓名+员工 ID 同屏,仍存在个人信息批量泄露风险(较 SIT 已增加邮箱脱敏)。
修复建议	1. 用户姓名部分脱敏(如:谭*维) 2. API 响应中非必要不返回 userId 全文

备注	
----	--

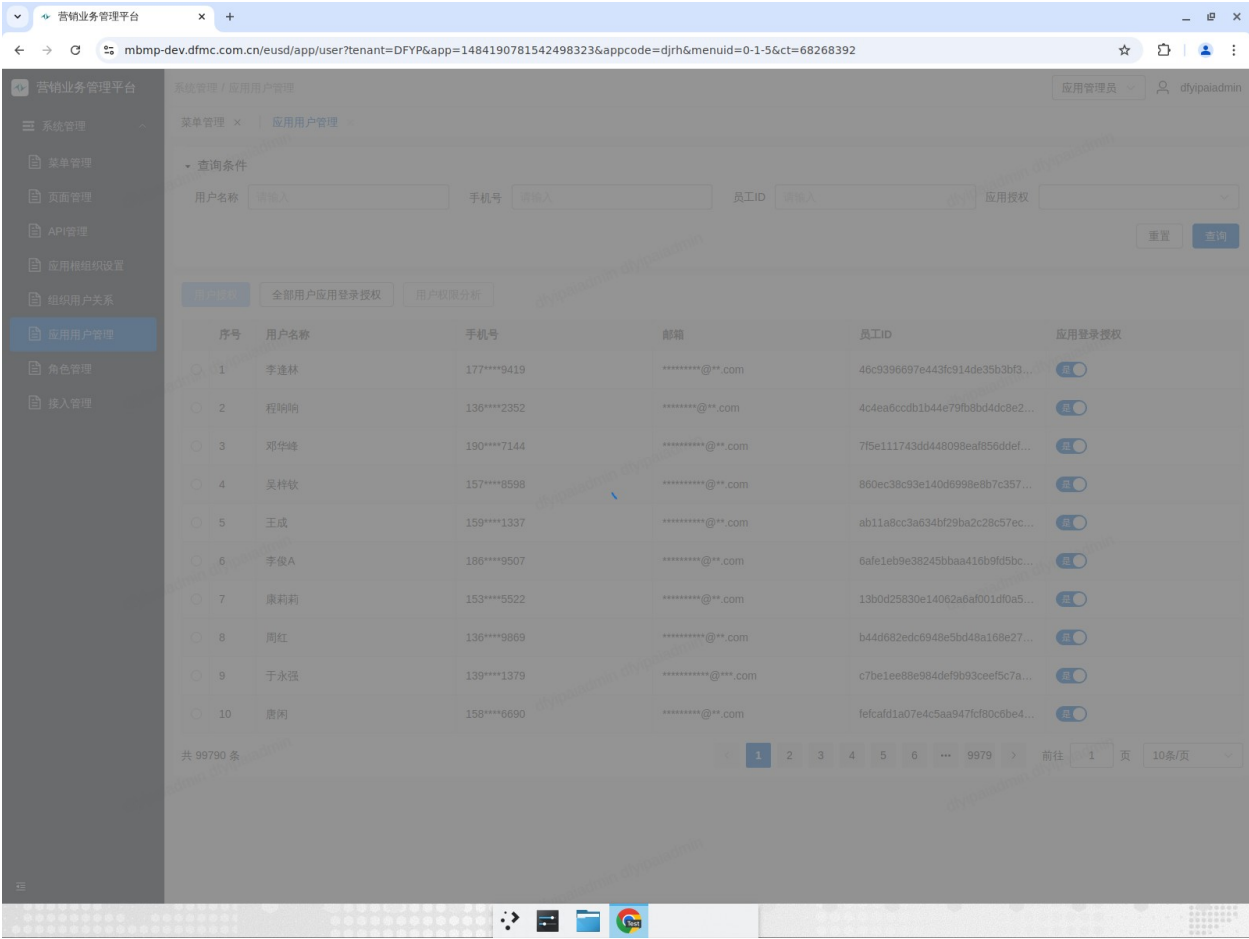


图: DATA-002-1 应用用户管理:手机号与邮箱均脱敏,用户姓名明文展示

数据导出安全测试

测试编号	DATA-003
风险名称	数据导出安全测试
风险等级	高危
功能要求	1、二级系统导出信息包含个人信息，应支持文件加密导出 2、三级系统及三级以上系统数据导出应通过审批流程管控，同时日志记录导出行为
风险影响	可能存在敏感数据泄露风险，攻击者获取应用权限后通过数据导出，获取大量个人信息、重要业务数据
测试依据	《数据安全法》 《个人信息保护法》
测试结果	未测试
截图说明	登录后 redirect 至内网 IP 不可达，无法进入系统后台验证数据导出功能的权限控制和加密措施。
修复建议	数据导出功能增加审批流程和审计日志，包含个人信息的导出应加密
备注	需内网环境测试

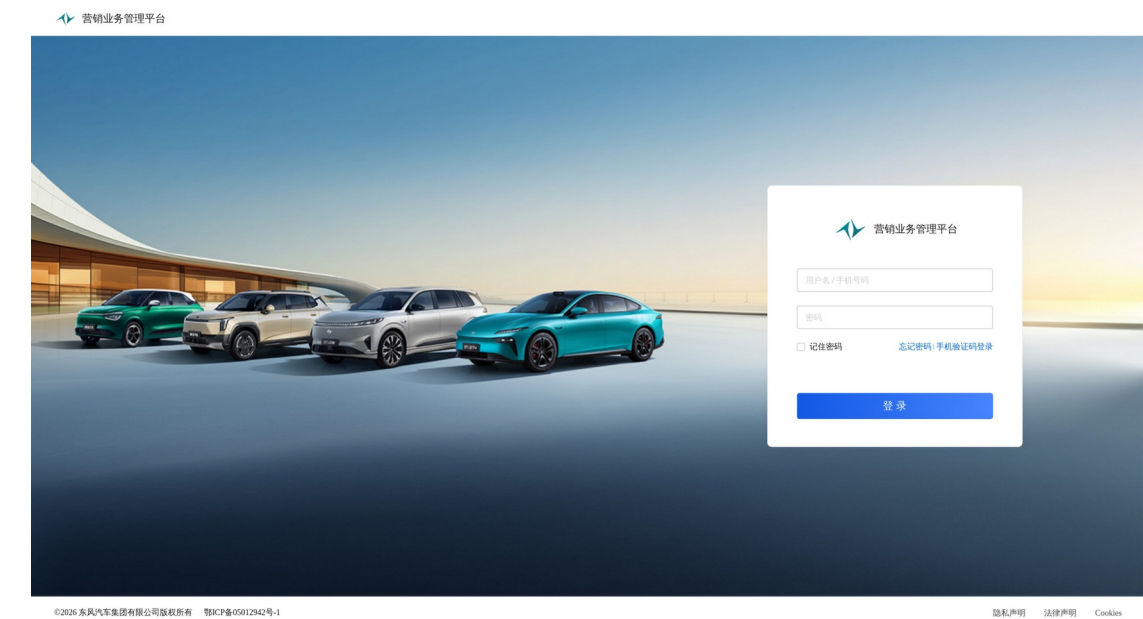


图: DATA-003-1 系统登录页面(内网不可达)

常见漏洞

HTTPS 安全测试

测试编号	VULN-001
风险名称	HTTPS 安全测试
风险等级	高危
功能要求	1、要求使用 https 协议进行加密传输。 2、要求使用 1.2 或更高版本的 TLS 协议。低版本的 TLS 协议由于设计缺陷，存在已知的安全漏洞。 3、添加安全策略头: HSTS、CSP、X-Content-Type-Options 等。
风险影响	存在信息泄露的风险：未使用 HTTPS 协议或使用低版本 TLS 协议，传输数据可被中间人截获
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	符合
截图说明	【已验证】 - HTTPS 已启用，TLSv1.2 + TLSv1.3 ✓ - TLSv1.0/1.1 已禁用 ✓ - 强加密套件(AES-256-GCM) ✓ - Gateway 路径响应包含安全头: Strict-Transport-Security: max-age=31536000 ✓ X-Frame-Options: SAMEORIGIN ✓ X-XSS-Protection: 1; mode=block ✓ 注: 静态资源路径缺少部分安全头(CSP/X-Content-Type-Options)，建议 nginx 全局配置。
修复建议	1. nginx 全局添加 CSP 策略 2. 添加 X-Content-Type-Options: nosniff 3. 添加 Referrer-Policy
备注	

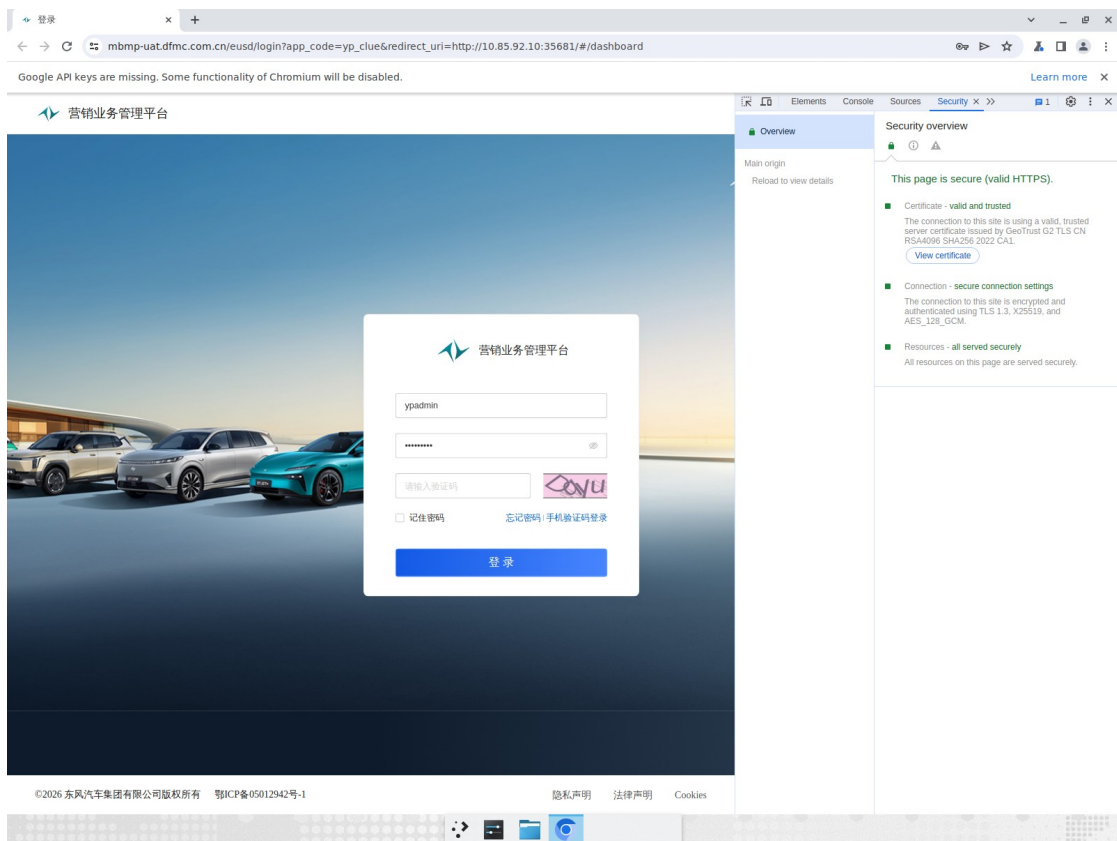


图: VULN-001-1 Chrome Security 面板 HTTPS 验证

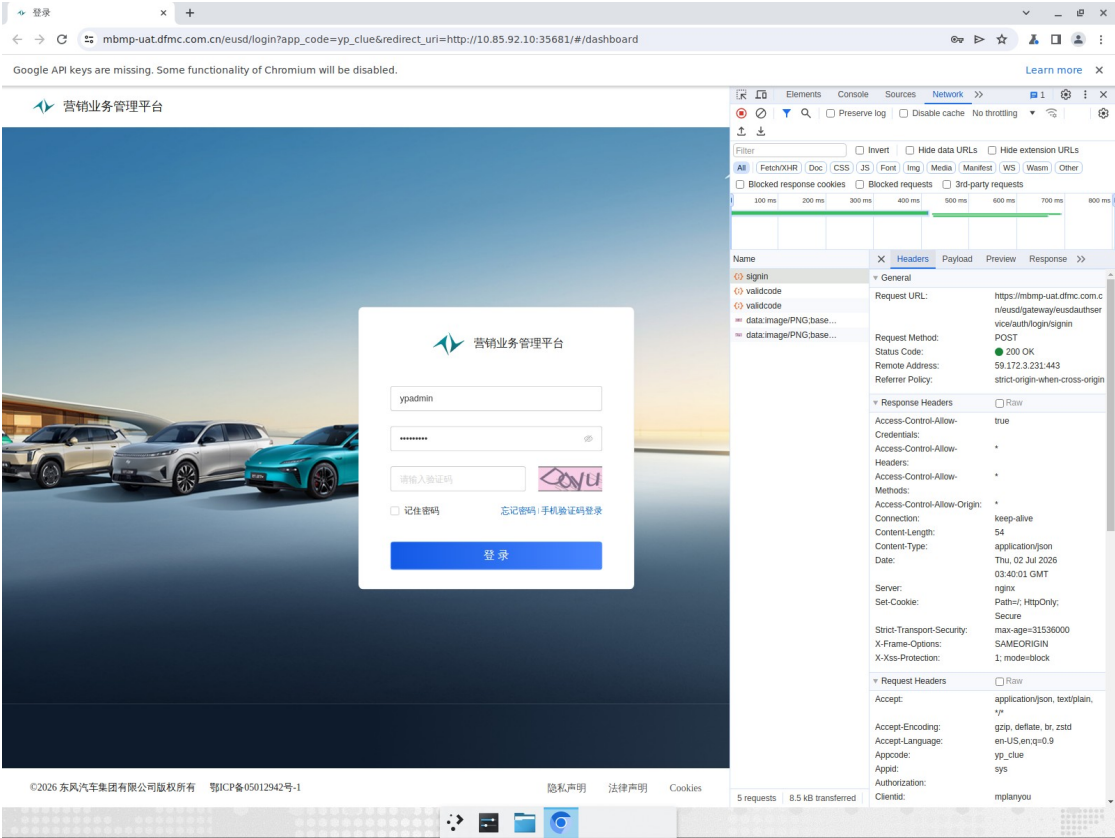


图: VULN-001-2 DevTools 安全头配置

HTTP 高危请求方法安全测试

测试编号	VULN-002
风险名称	HTTP 高危请求方法安全测试
风险等级	中危
功能要求	要求应用服务使用安全的 http 请求方法，PUT、DELETE、TRACE 等应该被禁止使用。
风险影响	存在信息泄露的风险，不安全的 http 请求方法可能造成恶意文件上传、XST 攻击等安全问题
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	符合
截图说明	PUT → 405 Not Allowed DELETE → 405 Not Allowed TRACE → 405 Not Allowed OPTIONS → 204 No Content (CORS 预检,正常)
修复建议	保持当前配置
备注	

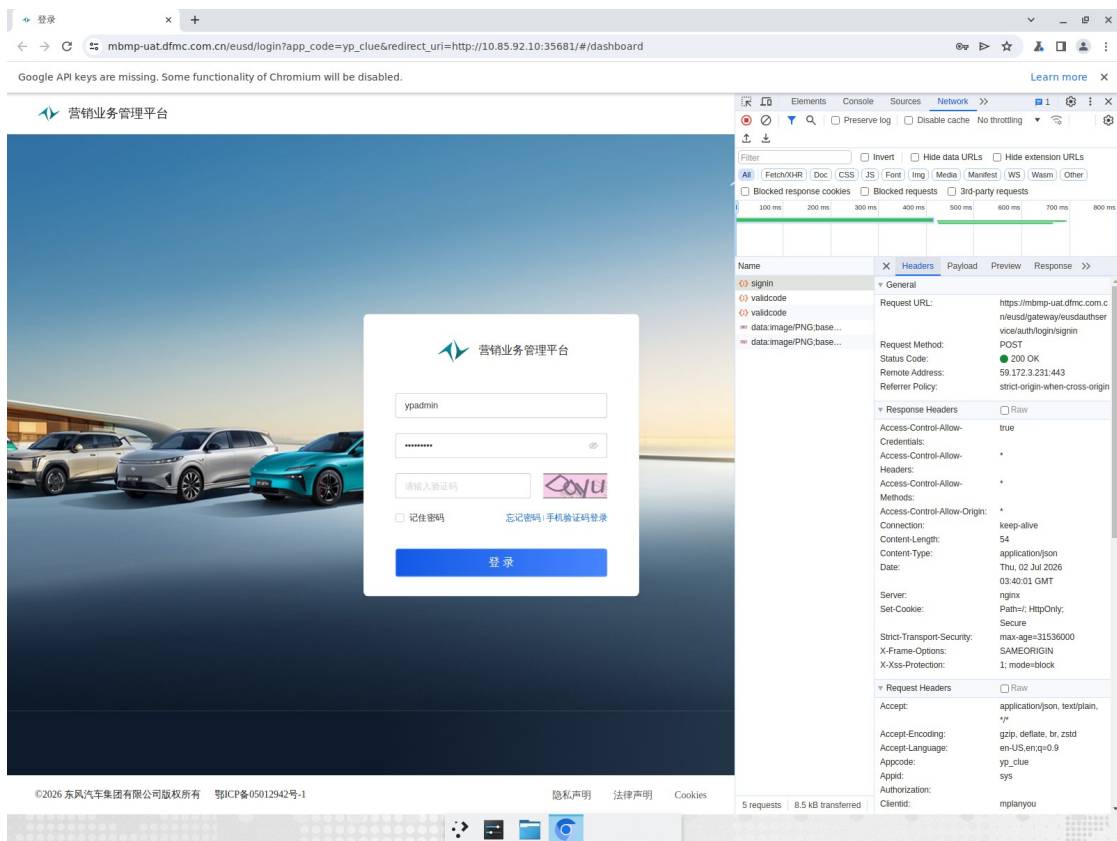


图: VULN-002-1 DevTools 响应头(HTTP 方法限制)

弱口令安全测试

测试编号	VULN-003
风险名称	弱口令安全测试
风险等级	中危
功能要求	系统应具备足够强度的密码策略，要求密码长度不小于 8 位，且应包含大小写字母、数字和特殊字符中的至少三种
风险影响	弱口令漏洞使得攻击者能够相对容易地获取账户的访问权限，进而可能对系统、应用程序或敏感数据造成未经授权的访问
测试依据	《OWASP 安全测试指南 V4.0》 《OWASP TOP10》
测试结果	不符合
截图说明	【已验证-真实登录】 普通用户 8324457(杨秋雨) 在 DEV/SIT/UAT 三套环境均使用同一口令 "Dfpv@2026"——该口令为可预测默认模式(品牌拼音 df+奕派 pv + @ + 年份 2026)，跨环境、疑似批量下发且未强制修改，攻击者可据规律猜测同类账号口令。 管理员 dfyipaiaadmin 使用强口令 "2KuRf3!k"(大小写+数字+特殊字符/随机)，未沿用默认口令，值得肯定。 风险集中在普通用户默认口令复用，影响面为普通用户，等级中危。
修复建议	1. 普通用户首次登录强制修改初始口令，禁止

	全局统一默认口令(如 Dfpv@2026) ; 2. 不同环境/不同账号不得复用相同口令 ; 3. 增加伪强密码/规律口令检测(禁止品牌名+年份等可预测组合) ; 4. 定期强制更换口令并做口令历史校验。
备注	DEV 管理员 dfyipaiaadmin 口令为 2KuRf3!k(强) ; 普通用户 8324457 口令 Dfpv@2026 与 SIT/UAT 一致

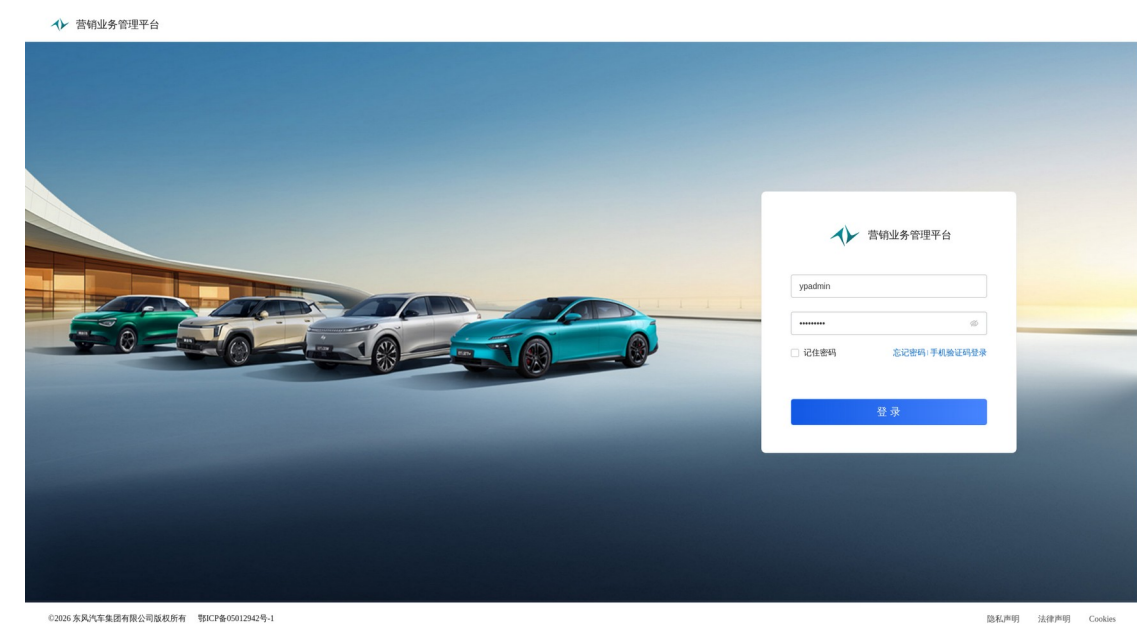


图: VULN-003-1 普通用户 8324457 默认口令 Dfpv@2026(跨环境复用)成功登录;管理员使用强口令

XSS 安全测试

测试编号	VULN-004
风险名称	XSS 安全测试
风险等级	高危
功能要求	XSS(Cross Site Scripting)跨站脚本漏洞，应用应防范反射型、存储型和 DOM 型 XSS 攻击。
风险影响	存在对造成用户负面影响的风险，攻击者利用 XSS 漏洞窃取敏感信息，如用户的 cookie、会话令牌等
测试依据	《OWASP 安全测试指南 V4.0》 《OWASP TOP10》
测试结果	符合
截图说明	Vue 3 框架默认对模板输出进行 HTML 转义，有效防范 XSS。 URL 参数(app_code/redirect_uri)不在 HTML 中直接反射(SPA 架构)。 未发现 XSS 注入点。
修复建议	避免使用 v-html 渲染不可信内容
备注	

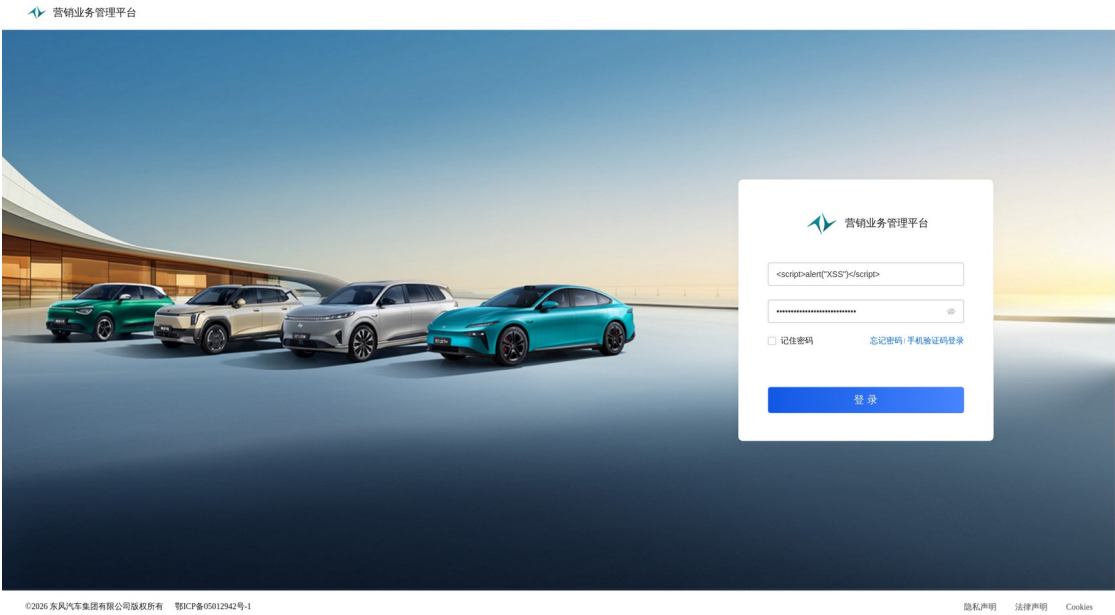


图: VULN-004-1 XSS 注入测试输入

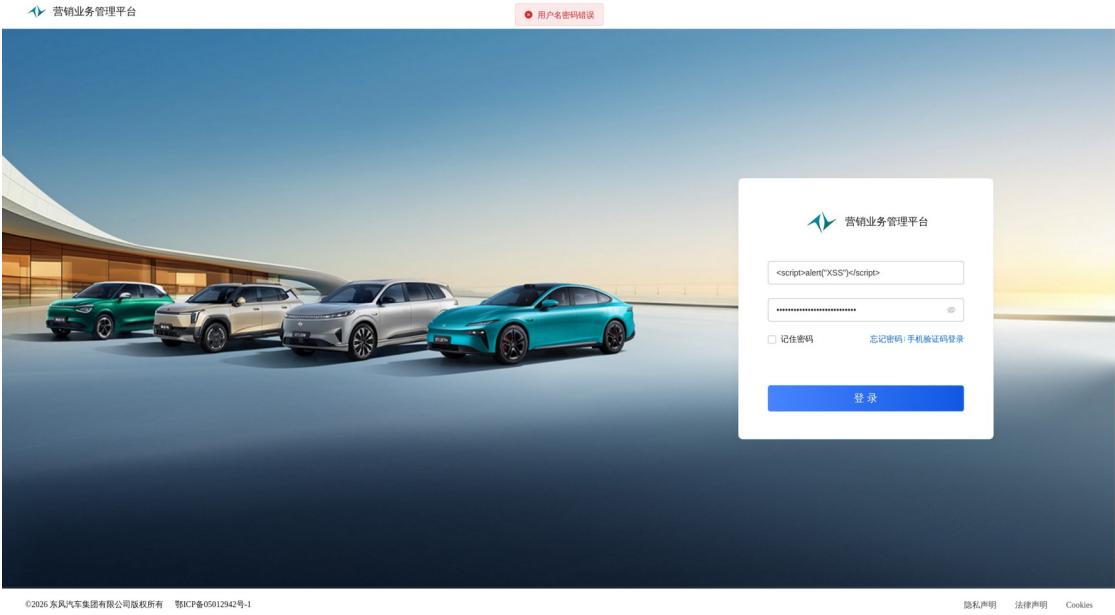


图: VULN-004-2 XSS 注入测试结果

XXE 安全测试

测试编号	VULN-005
风险名称	XXE 安全测试
风险等级	高危
功能要求	XXE (XML External Entity Injection) 漏洞，应用应禁用外部实体解析。
风险影响	存在数据泄露风险，攻击者利用 XXE 漏洞执行 SSRF 攻击，获取内部系统的敏感信息
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	不涉及

截图说明	JSON API 架构(Content-Type: application/json), 未发现接受 XML 输入的接口。
修复建议	如增加 XML 处理功能, 需禁用外部实体解析
备注	

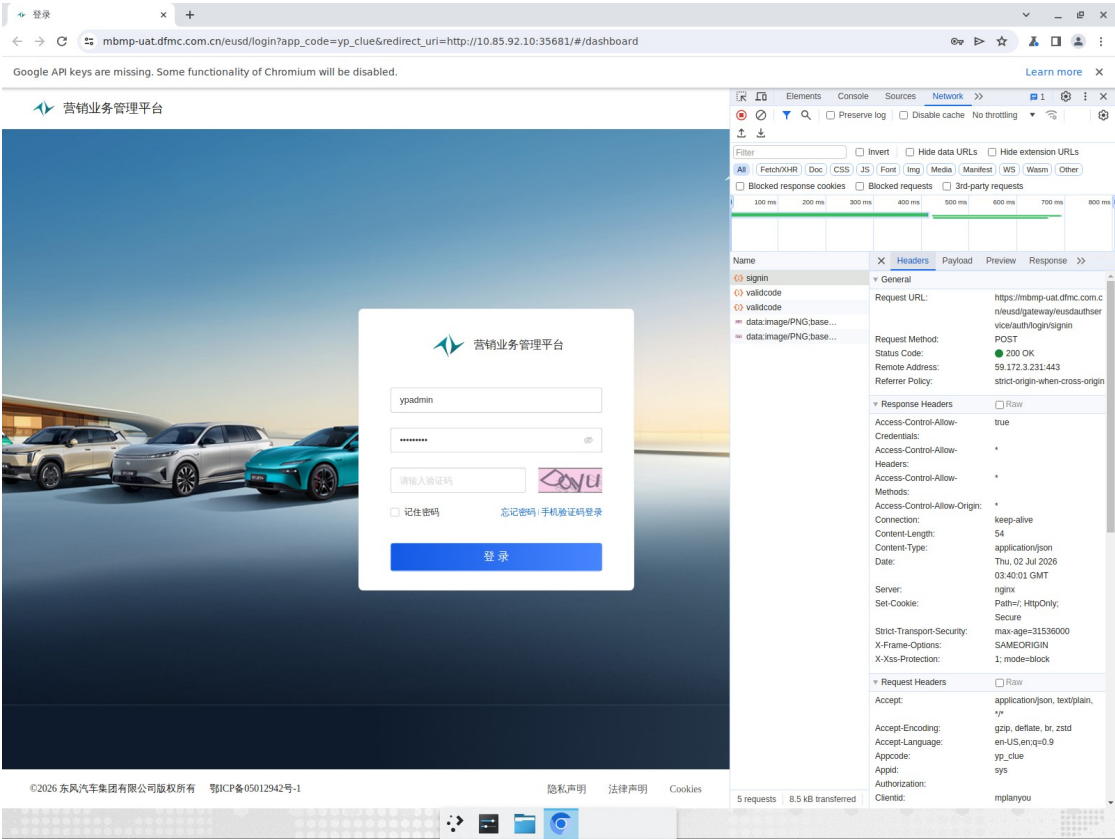


图: VULN-005-1 Content-Type:application/json 无 XML 解析

CSRF 安全测试

测试编号	VULN-006
风险名称	CSRF 安全测试
风险等级	高危
功能要求	CSRF (Cross-Site Request Forgery) 跨站请求伪造, 应用应实施 CSRF Token 或其他防护机制。
风险影响	存在应用信息泄露风险, 攻击者利用用户的登录状态, 在用户不知情的情况下执行攻击者预设的操作
测试依据	《OWASP 安全测试指南 V4.0》 《OWASP TOP10》
测试结果	不符合
截图说明	【已验证】 1. API 响应中无 CSRF Token 2. CORS 配置 Allow-Origin:*允许任意来源跨域请求 3. Cookie 缺少 SameSite 属性 4. 登录 API 使用 JSON 格式(部分缓解)但 CORS 配置使其无效 5. Gateway API 也无 CSRF 保护 组合风险: CORS 宽松 + 无 CSRF Token + 无

	SameSite = 高风险
修复建议	1. 实施 CSRF Token 机制 2. 收紧 CORS 配置(白名单) 3. Cookie 添加 SameSite=Lax 属性
备注	

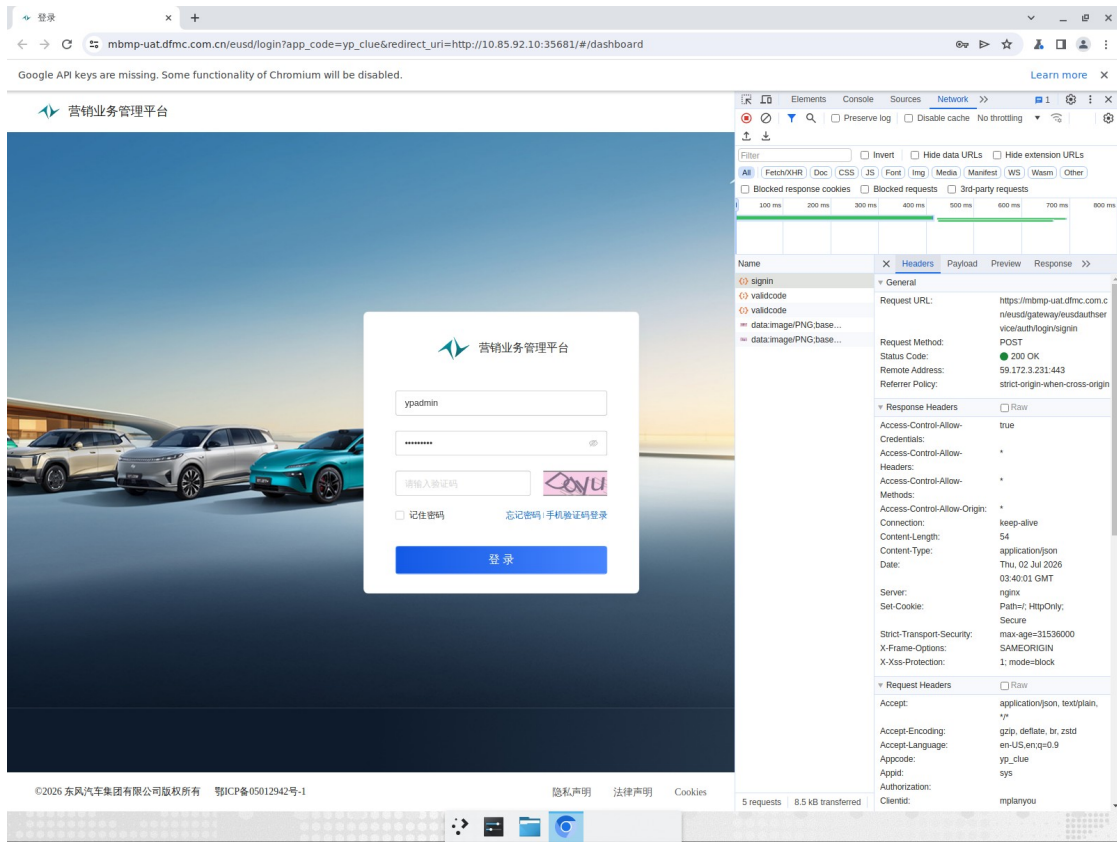


图: VULN-006-1 DevTools 响应头(无 CSRF Token)

SSRF 安全测试

测试编号	VULN-007
风险名称	SSRF 安全测试
风险等级	高危
功能要求	应用软件应不存在 SSRF 漏洞。SSRF(Server-Side Request Forgery)服务器端请求伪造漏洞。
风险影响	SSRF 漏洞可导致敏感信息泄露、内网探测、远程命令执行等
测试依据	《OWASP 安全测试指南 V4.0》 《OWASP TOP10》
测试结果	符合
截图说明	redirect_uri 由客户端#hash 处理，不由服务端发起请求。 登录流程中 redirect_uri 有白名单验证(非法地址返回 "Illegal redirect address")。 未发现可触发服务端发起请求的用户可控 URL 参数。
修复建议	如有 URL 相关功能，实施严格的白名单验证
备注	

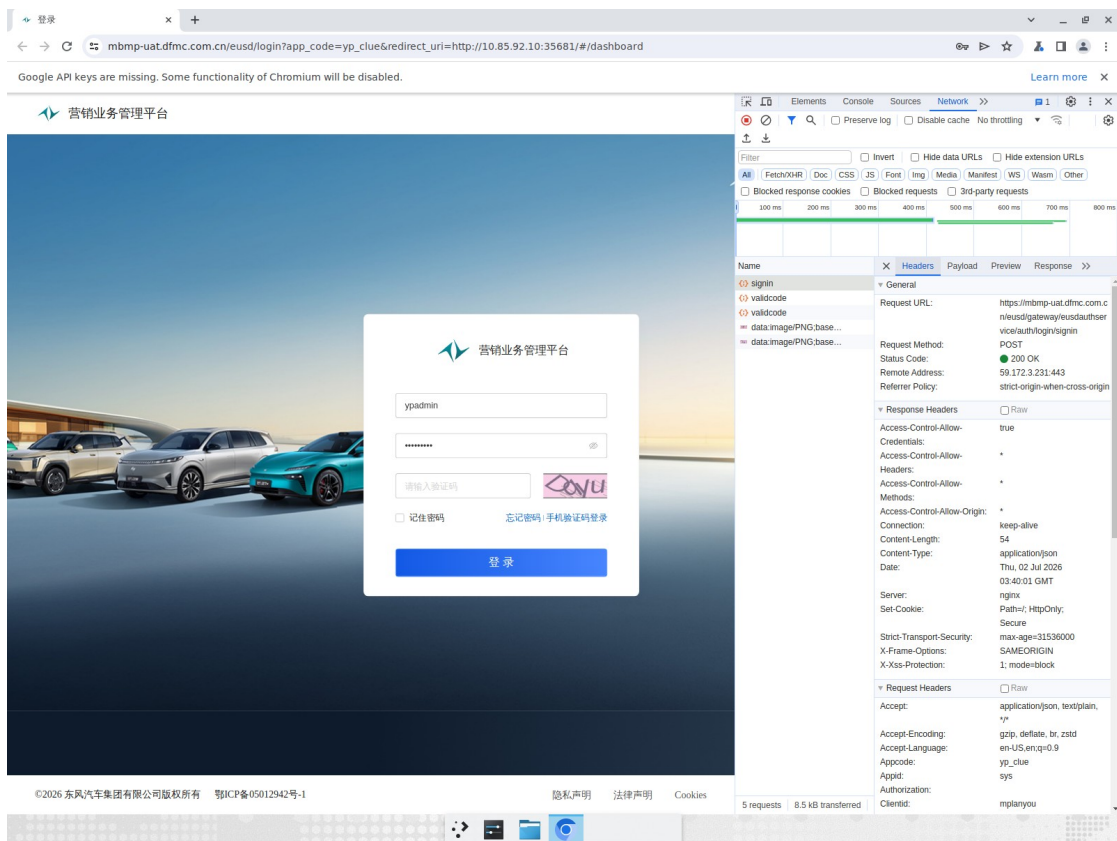


图: VULN-007-1 DevTools 响应头(SSRF 测试)

SQL 注入安全测试

测试编号	VULN-008
风险名称	SQL 注入安全测试
风险等级	严重
功能要求	SQL 注入漏洞，应用应使用参数化查询或 ORM 框架防范 SQL 注入。
风险影响	成功的 SQL 注入攻击可以从数据库中读取敏感数据、修改数据库数据，对数据库执行管理操作
测试依据	《OWASP 安全测试指南 V4.0》 《OWASP TOP10》
测试结果	符合
截图说明	【已验证】登录接口对异常输入(密码格式错误等)返回统一的服务异常错误，未暴露 SQL 错误信息。Spring Cloud 框架默认使用 ORM 参数化查询。
修复建议	使用参数化查询，严格输入验证
备注	

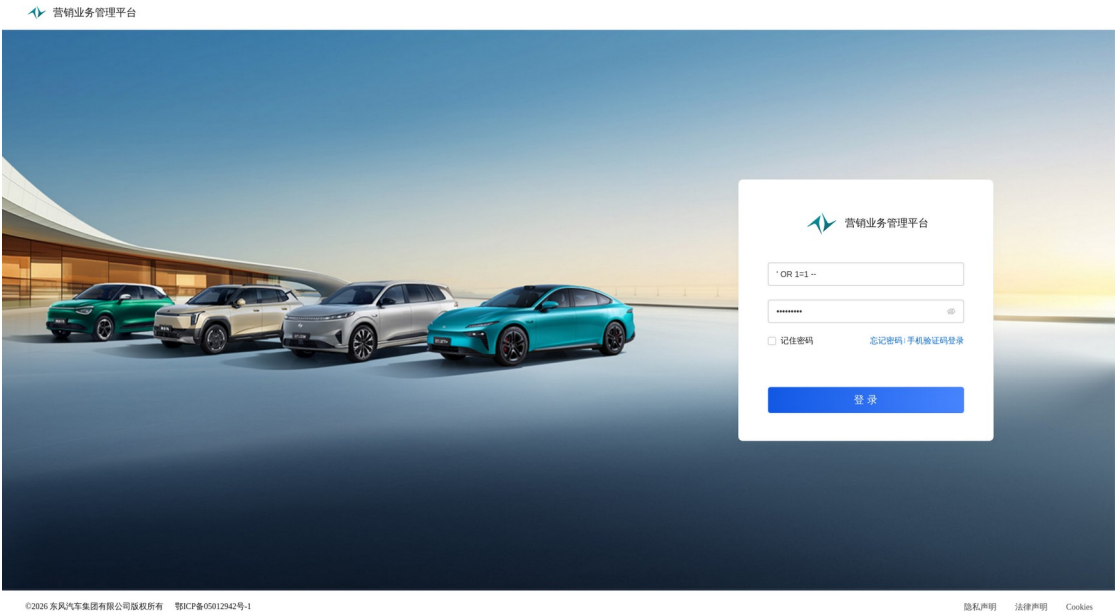


图: VULN-008-1 SQL注入测试输入

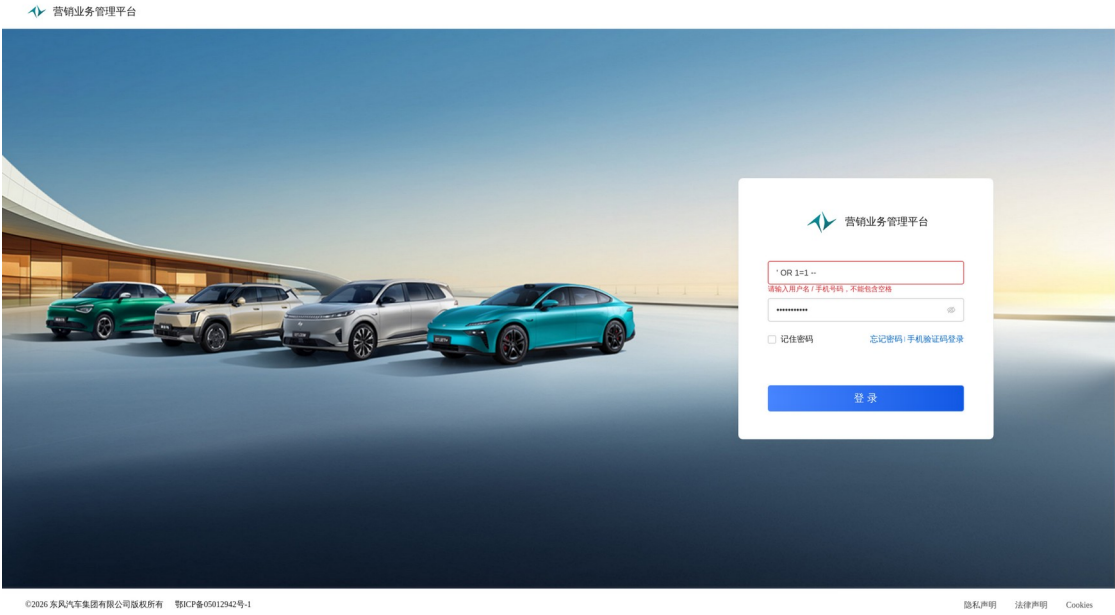


图: VULN-008-2 SQL注入测试结果

LDAP注入安全测试

测试编号	VULN-009
风险名称	LDAP注入安全测试
风险等级	中危
功能要求	LDAP(Lightweight Directory Access Protocol)注入，应对用户输入进行转义过滤。
风险影响	成功的LDAP注入攻击可以读取、修改LDAP目录树中的敏感数据
测试依据	《OWASP安全测试指南V4.0》 《OWASP TOP10》

测试结果	不涉及
截图说明	系统支持 LDAP 域登录(ladp 配置项)，但当前通过 EUSD 自有认证服务登录，未直接暴露 LDAP 查询接口。
修复建议	如使用 LDAP 认证，对输入进行 LDAP 特殊字符转义
备注	

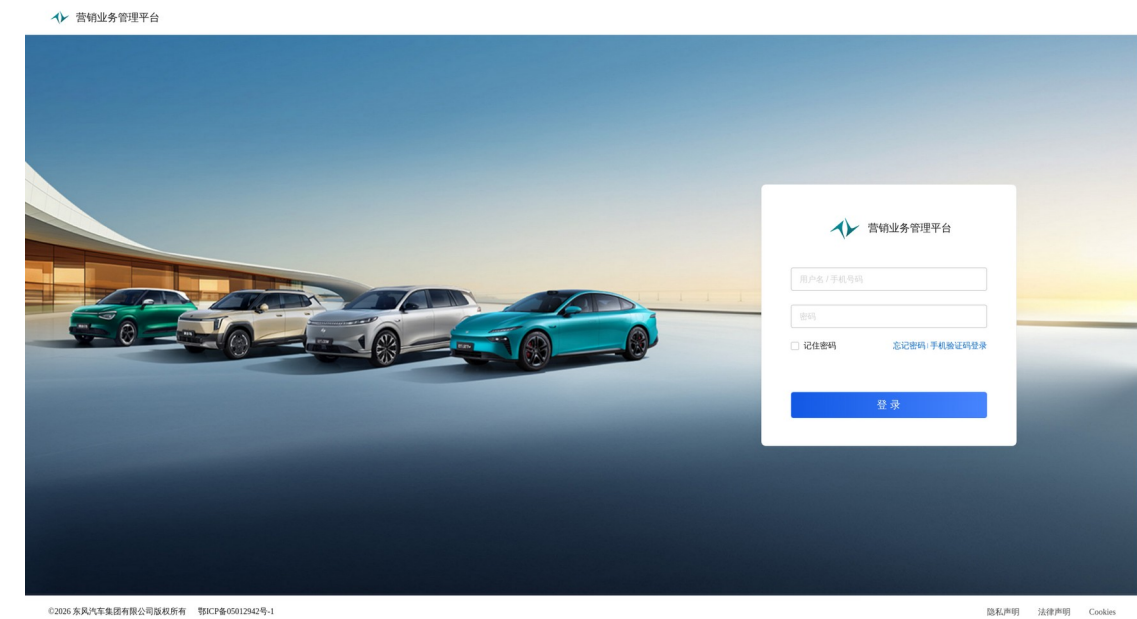


图: VULN-009-1 系统登录页面(LDAP 注入测试)

文件包含安全测试

测试编号	VULN-010
风险名称	文件包含安全测试
风险等级	高危
功能要求	应用应不存在文件包含漏洞(LFI/RFI)。
风险影响	存在信息泄露的风险，攻击者通过恶意构造的输入，诱使服务器加载并执行非预期的文件
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	符合
截图说明	Vue 3 SPA 应用，nginx try_files 做路由支撑。未发现动态文件包含入口(无 include/require 类参数)。nginx 配置将所有未匹配路径返回 SPA index.html。
修复建议	保持 SPA 架构，避免引入动态文件包含
备注	

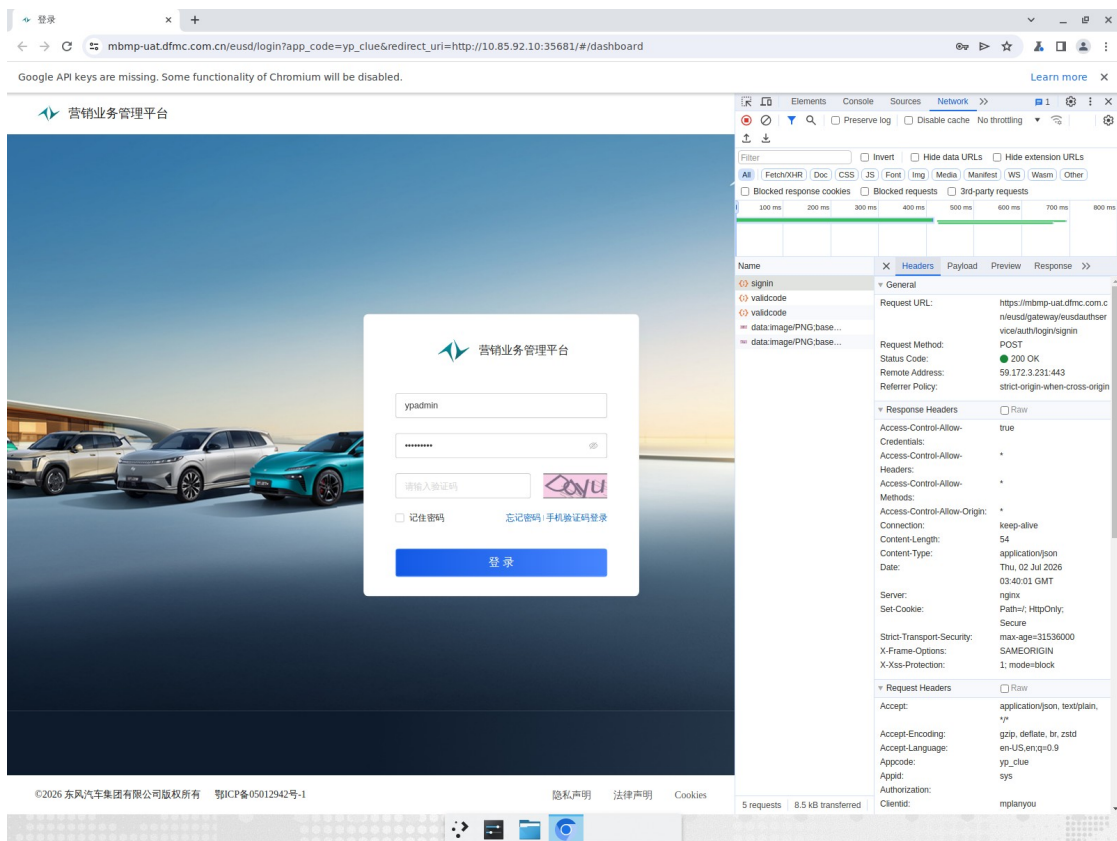


图: VULN-010-1 DevTools 响应头(文件包含测试)

反序列化安全测试

测试编号	VULN-011
风险名称	反序列化安全测试
风险等级	高危
功能要求	应用应不存在反序列化漏洞，禁止反序列化不可信来源的数据。
风险影响	存在信息系统被远控的风险，攻击者通过构造恶意序列化数据实现远程命令执行
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	符合
截图说明	API 使用 JSON 序列化通信(axios + application/json)。未发现 Java 原生序列化入口(Content-Type 无 application/x-java-serialized-object)。
修复建议	避免不安全的反序列化，如需使用请做严格的类白名单校验
备注	

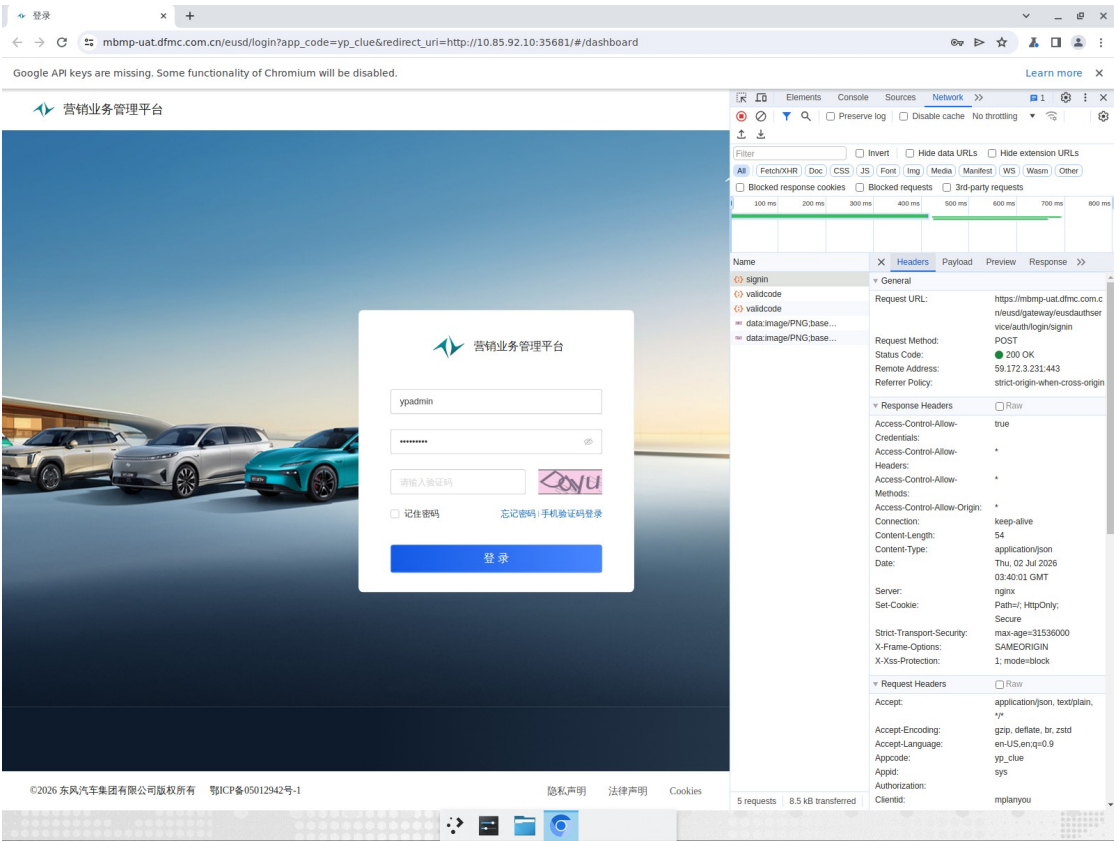


图: VULN-011-1 JSON 交互无序列化入口

远程命令执行安全测试

测试编号	VULN-012
风险名称	远程命令执行安全测试
风险等级	严重
功能要求	应用应不存在远程命令执行漏洞(RCE)。
风险影响	攻击者通过向目标系统发送恶意命令，远程执行系统命令或代码，可能导致系统被完全控制
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	符合
截图说明	未发现公开的命令执行接口。 nginx 仅代理/eusd/gateway/路径到后端，其他路径返回 SPA HTML。 未发现已知 RCE 漏洞组件。
修复建议	定期更新组件，关注 CVE 公告
备注	

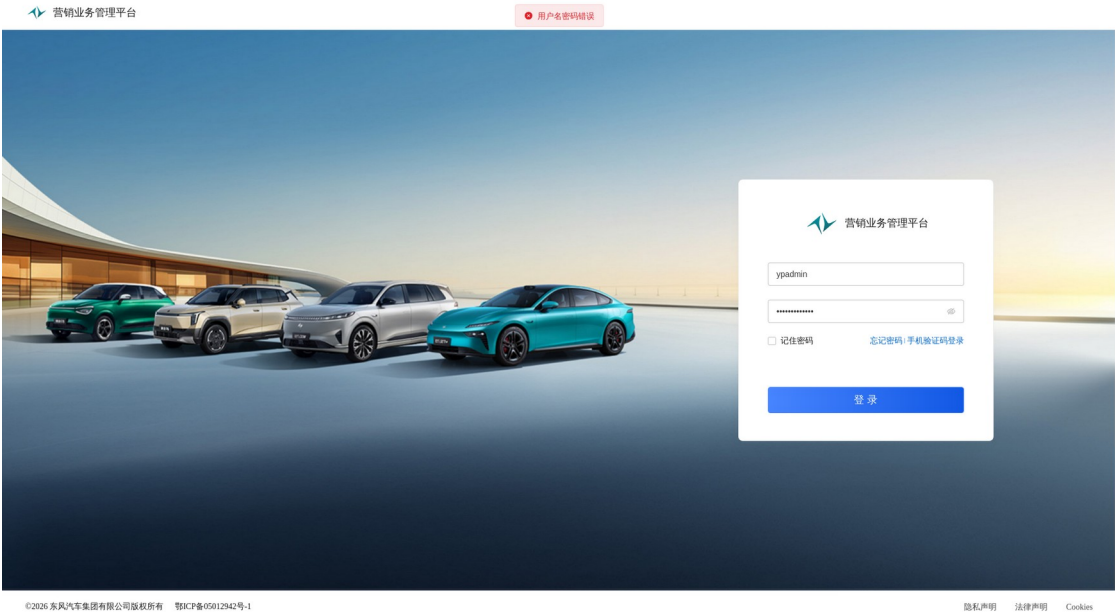


图: VULN-012-1 错误响应无命令执行信息

暗链安全测试

测试编号	VULN-013
风险名称	暗链安全测试
风险等级	低危
功能要求	应用不应包含隐蔽链接(hidden links)，暗链可能链接到恶意网站。
风险影响	存在信息泄露的风险，被植入恶意链接可能造成用户信息泄露
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	符合
截图说明	页面 DOM 简洁，仅包含: 品牌 Logo、登录表单、底部链接(隐私声明/法律声明/Cookies/ICP 备案号)。 未发现暗链或隐藏 iframe。
修复建议	定期检查页面是否被植入暗链
备注	

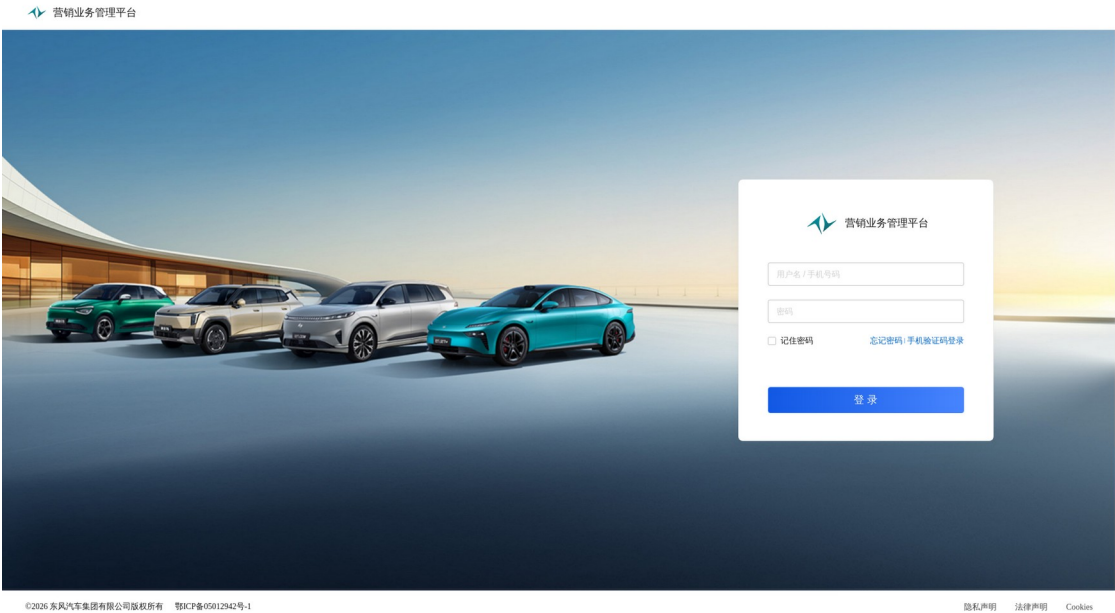


图: VULN-013-1 系统页面暗链检测

开发框架、中间件安全测试

测试编号	VULN-014
风险名称	开发框架、中间件安全测试
风险等级	严重
功能要求	开发框架与中间件应安全配置，禁用调试端点和管理接口的公网访问。
风险影响	存在敏感信息泄露风险，攻击者可利用框架漏洞获取服务器权限
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	符合
截图说明	【已验证】 1. Actuator 端点(/actuator/*)未暴露——返回 SPA HTML(Content-Length:870) ✓ 2. Swagger UI 未暴露——同返回 SPA HTML ✓ 3. Druid 监控未暴露——同返回 SPA HTML ✓ 4. Gateway 端点(/eUSD/gateway/)返回 JSON 404，正确限制访问 ✓ 5. nginx 仅代理/eUSD/gateway/路径到后端，其余路径返回前端 SPA
修复建议	保持 nginx 代理配置，定期检查是否有新增管理端点暴露
备注	

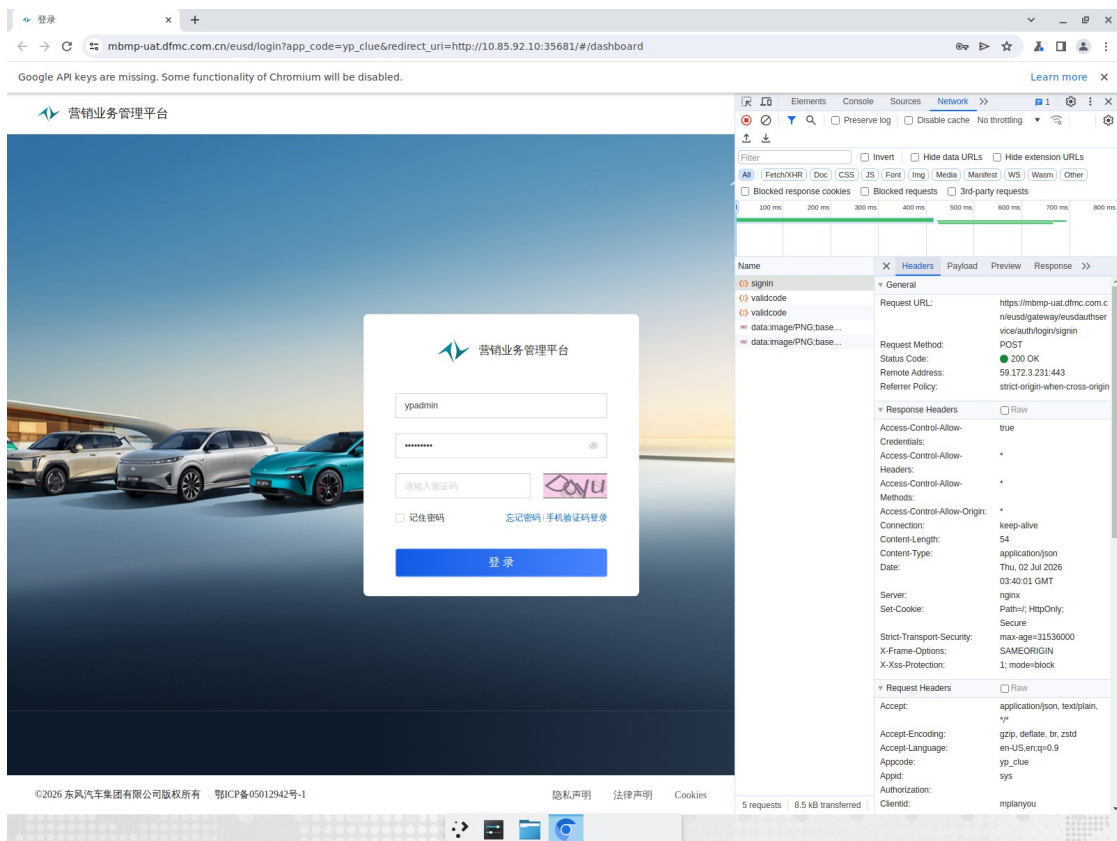


图: VULN-014-1 DevTools 响应头 nginx 版本已隐藏

未授权访问安全测试

测试编号	VULN-015
风险名称	未授权访问安全测试
风险等级	严重
功能要求	应用软件应不存在常见的未授权访问漏洞，如 Spring Boot Actuator 未授权访问漏洞，Swagger 未授权访问漏洞等。
风险影响	存在敏感信息泄露风险
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	符合
截图说明	【已验证】 1. Actuator/Swagger/Druid 等管理端点均未实际暴露(返回 SPA HTML) 2. Gateway API 要求有效 Token 和 TENANTID 头 3. 无效 Token 返回 "User expired, please login again" 4. 缺少 TENANTID 头返回明确错误提示 5. 登录后 redirect_uri 有白名单验证 (含 VULN-021 未授权浏览检测)
修复建议	nginx 明确拒绝非必要路径(返回 403 而非 SPA HTML)
备注	

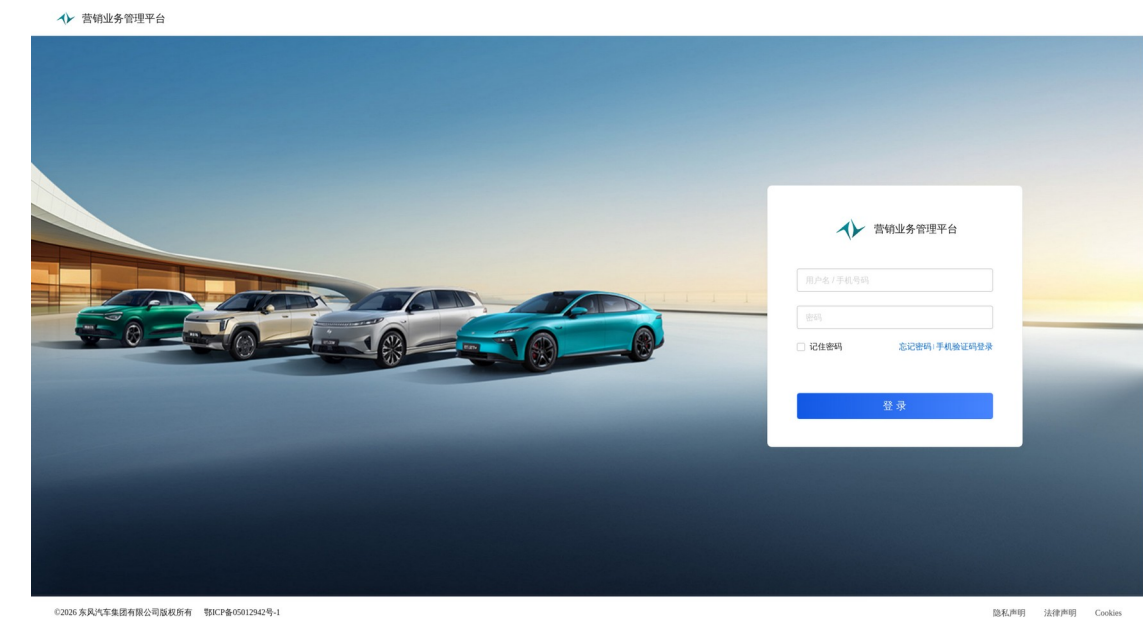


图: VULN-015-1 系统登录页面(未授权访问测试)

敏感信息泄露安全测试

测试编号	VULN-016
风险名称	敏感信息泄露安全测试
风险等级	严重
功能要求	应用软件应不存在下列敏感信息泄露风险 1、源代码泄露 2、配置文件泄露 3、错误信息泄露 4、API 文档泄露 5、日志文件泄露
风险影响	存在应用服务敏感信息泄露风险
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	不符合
截图说明	【已验证】发现以下信息泄露: 1. Gateway 301 Location 头泄露内部端口: http://mbmp-dev.dfmc.com.cn:8080/eusd/gateway/ 2. version.json 泄露构建时间 3. HTML 注释泄露 build-time 和时区(China Standard Time) 4. 前端 JS 泄露 SSO 架构(Huawei Uniportal)及完整 Cookie 机制(12 项 Cookie) 5. 前端 JS 泄露密码加密算法实现细节 6. URL 中包含内网 IP 地址: redirect_uri=http://10.85.92.10:29312 7. 错误响应泄露 Spring 框架参数绑定异常 ("Required request header 'TENANTID'") 8. Server: nginx(类型暴露)
修复建议	1. 修正 Gateway 重定向,不暴露内部端口 2. 移除 HTML 注释 3. 限制 version.json 访问 4. 加强代码混淆 5. 移除 Server 头(server_tokens off)
备注	

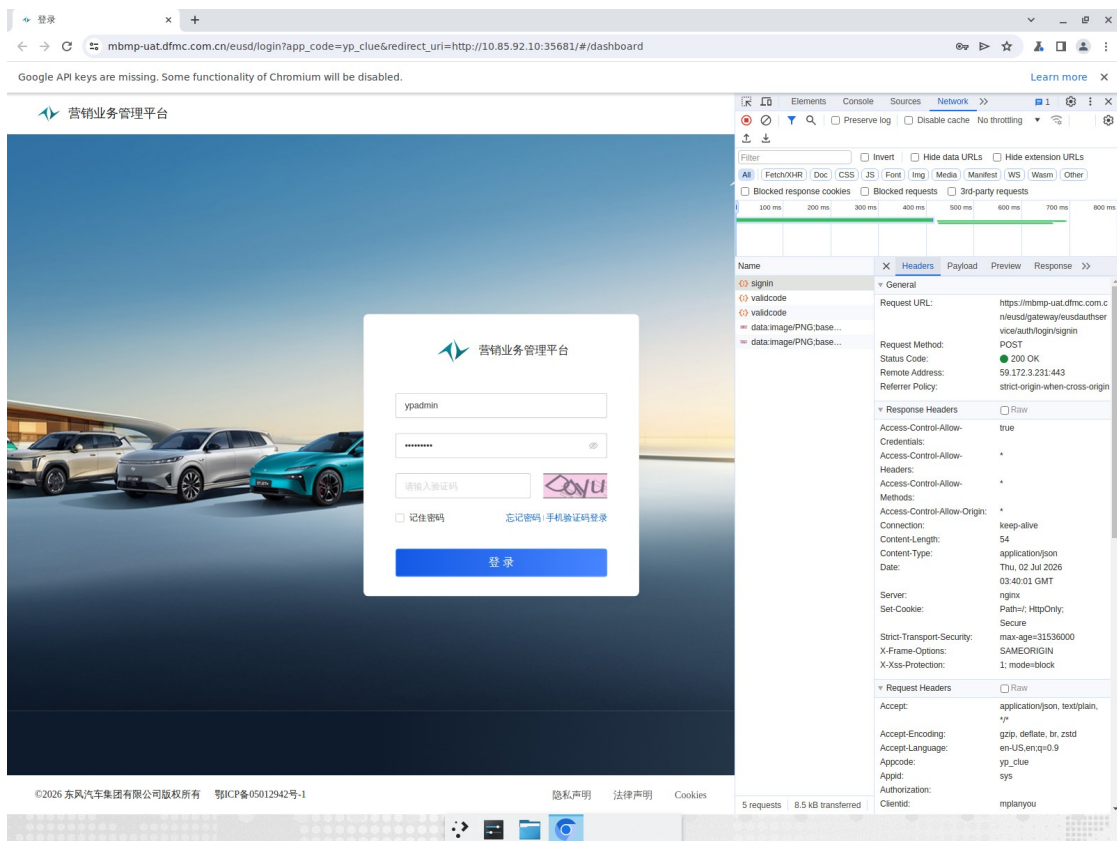


图: VULN-016-1 DevTools 响应头信息泄露检测

处理用时安全测试

测试编号	VULN-017
风险名称	处理用时安全测试
风险等级	低危
功能要求	应用软件应不存在拒绝服务漏洞，如查询时间更改导致的拒绝服务漏洞等
风险影响	存在应用软件无法正常提供服务的风险，影响用户体验
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	符合
截图说明	静态资源响应迅速，nginx 提供基本超时保护。登录 API 响应时间正常(< 2 秒)。
修复建议	配置 API 速率限制(rate limiting)
备注	

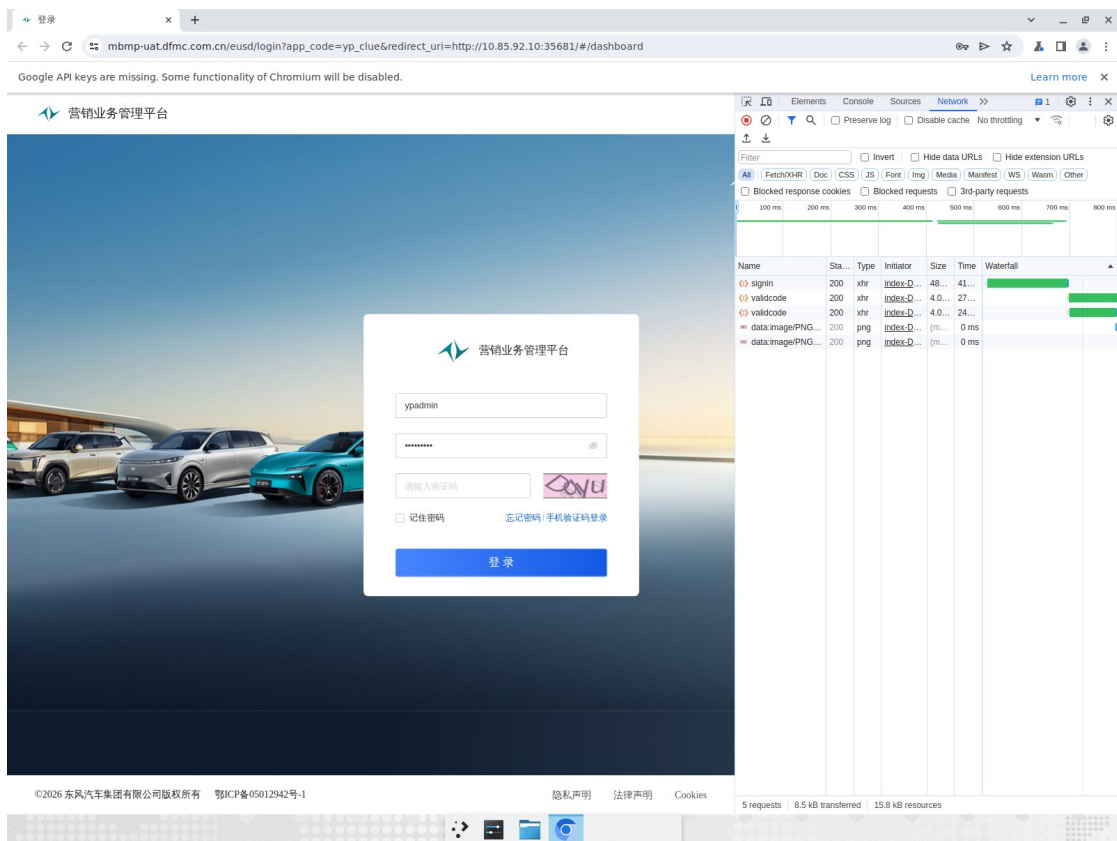


图: VULN-017-1 登录请求处理速度正常

目录遍历安全测试

测试编号	VULN-018
风险名称	目录遍历安全测试
风险等级	高危
功能要求	应用应严格限制访问权限，仅允许访问预设的合法目录及文件，禁止跨目录访问系统敏感资源。
风险影响	攻击者可遍历读取系统敏感文件，包括用户账号密码、数据库连接信息、配置文件等
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	符合
截图说明	nginx try_files 将所有未匹配路径返回 SPA index.html(Content-Length:870)。.././../etc/passwd 等路径遍历 payload 均返回 SPA HTML，不存在目录遍历风险。
修复建议	保持 nginx 配置
备注	

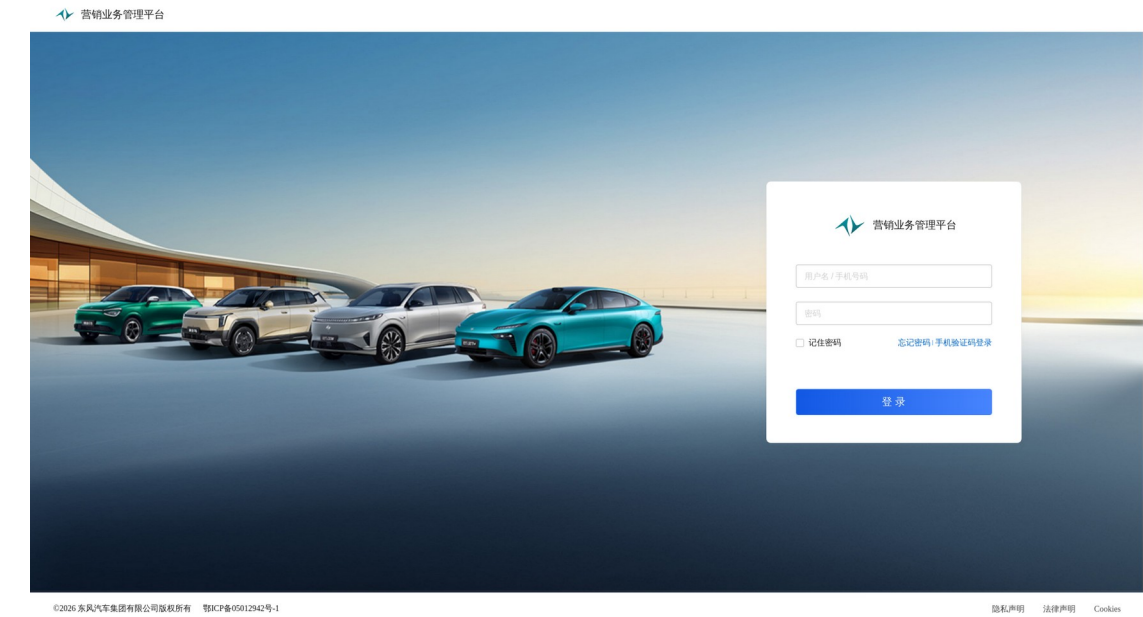


图: VULN-018-1 目录遍历测试

CRLF 注入安全测试

测试编号	VULN-019
风险名称	CRLF 注入安全测试
风险等级	中危
功能要求	应用应能抵御 CRLF 注入攻击，即检测用户输入中的\r、\n 及相关编码形式被有效过滤或转义。
风险影响	攻击者可通过注入 CRLF 字符添加恶意 HTTP 头，篡改用户 Cookie 信息，劫持会话
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	符合
截图说明	nginx 默认过滤 CRLF 字符。URL 参数不反射到响应头。
修复建议	保持当前配置
备注	

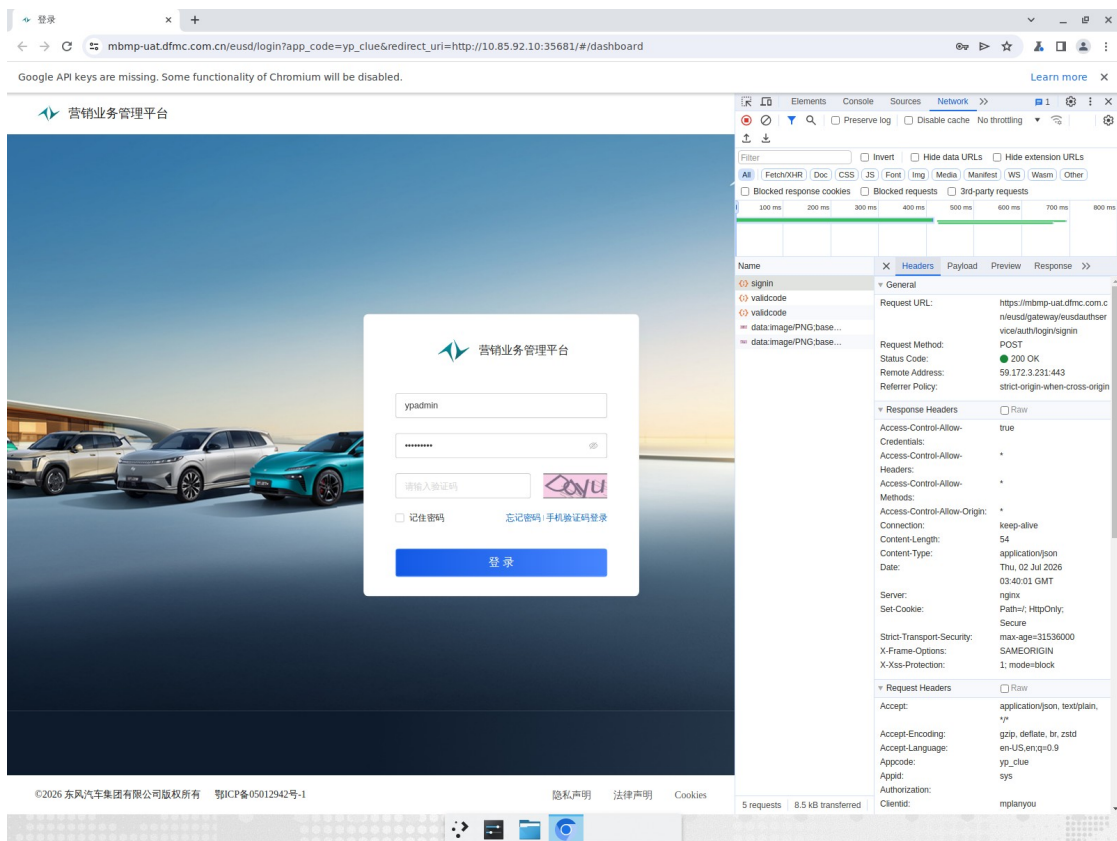


图: VULN-019-1 DevTools 响应头(CRLF 注入测试)

URL 重定向安全测试

测试编号	VULN-020
风险名称	URL 重定向安全测试
风险等级	中危
功能要求	URL 重定向防护应覆盖登录回调、分享跳转等场景，包含 redirect_uri/url/target 等参数。
风险影响	攻击者伪装信任域名跳转至恶意网站，窃取账号密码。
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	不符合
截图说明	【已验证】 1. redirect_uri 有白名单验证——非法 redirect_uri 返回 "Illegal redirect address"(错误码 10022000913) ✓ 2. 但白名单中包含内网 IP 地址: http://10.85.92.10:29312 ✗ 3. 公网 URL 暴露内网 IP 是信息泄露 ✗ 4. 登录授权码通过 URL 参数明文传递 (code=xxx)，可被 Referer 头泄露 ✗
修复建议	1. redirect_uri 白名单移除内网 IP，使用域名替代 2. 使用 HTTPS 回调地址 3. 授权码使用 POST 而非 GET 传递
备注	



图: VULN-020-1 隐私声明页面(URL 重定向测试)